



Ethicontrol OÜ, 14338530
 Orumetsa tn 5/1-15 Maardu Harjumaa 74111
 Tornimäe 5, 2nd Floor, 10145 Tallinn
 ethicontrol.com
 info@ethicontrol.com
 +1 (302) 451 94 55, +372 668 2755

SAAS SERVICES ORDER FORM

Customer: BanBif - Inter-American Finance Bank LEI (Legal Entity Identifier): G6RQYH0IRIK3ZW7ADP84 Tax Number: RUC 20101036813	Contact: Lisetti Macedo Valderrama
Address: Avenida Ricardo Rivera Navarrete 600, San Isidro, Lima, Peru, 15046 Billing email: comprobanteselect@banbif.com.pe	Phone: +51 965 004 006 Direct: Mobile: E-Mail: LMACEDO@banbif.com.pe
Fees: Year 1 - March 15, 2025 - March 14, 2026 - 5483,16 USD Year 2 - March 15, 2026 - March 14, 2027 - 4583,16 USD Year 3 - - March 15, 2027 - March 14, 2028 - 4583,16 USD payable in advance, subject to the terms of Section 4 herein. Hourly rate for custom development tasks is 40 USD.	Initial Service Term: Three years

HOJA DE PEDIDO DE SERVICIOS SAAS

Cliente: BanBif - Banco Interamericano de Finanzas Número de registro: LEI (Legal Entity Identifier): G6RQYH0IRIK3ZW7ADP84 Número de identificación fiscal: RUC 20101036813	Contacto: Lisetti Macedo Valderrama
Dirección: Avenida Ricardo Rivera Navarrete 600, San Isidro, Lima, Peru, 15046 Correo electrónico de facturación: comprobanteselect@banbif.com.pe	Teléfono: +51 965 004 006 Directo: Móvil: E-Mail: LMACEDO@banbif.com.pe
Pagos: Cuotas:	Duración inicial del servicio: Tres años



Año 1 - 15 de marzo de 2025 - 14 de marzo de 2026 - 5483,16 USD

Año 2 - 15 de marzo de 2026 - 14 de marzo de 2027 - 4583,16 USD

Año 3 - 15 de marzo de 2027 - 14 de marzo de 2028 - 4583,16 USD

pagaderos por adelantado, con sujeción a lo dispuesto en la Sección 4 del presente documento.

La tarifa por hora para tareas de desarrollo personalizado es de 40 USD.



Services: Ethicontrol Ethics Management Platform - Advanced Plan (the “Service(s)”).

Servicios: Plataforma de gestión ética Ethicontrol - Plan Avanzado (los «Servicios»).

Code	List of components and services	Lista de componentes y servicios	Adv'd USD/month
Reporting / intake channels		Informes/ canales de admisión	
R1	Web-intake portal	El portal web intacto	X
R2	Dedicated portal: banbif.ethicontrol.com	El portal dedicado: banbif.ethicontrol.com	X
R3	Dedicated mailbox: banbif@ethics.email	El correo electrónico dedicado: banbif@ethics.email	X
R4	Branding for your company/organisation	Marca para su EMPRESA	X
R5	Vocabulary customisations	Personalizaciones de vocabulario	X
R7	Included languages	Idiomas incluidos	English Spanish
R8	Included jurisdictions/countries	Jurisdicciones/países incluidos	5
R9	Multiple-level unit hierarchy (levels)	Jerarquía de unidades de varios niveles	3
R10	Additional domains of choice	Dominios adicionales de elección	X
R11	Custom web-intake	Entrada web personalizada	X
R12	Custom reporter's portal	Portal de reporteros personalizado	X
R13	Machine translation of reports	Traducción automática de informes	X
Incident management		Administración de incidentes	
I1	Notifications and reminders	Notificaciones y recordatorios	X
I2	Control Panel / Incident register	Panel de control / Registro de incidencias	X
I3	Feedback with anonymous reporters directly from the managers interface	Reseñas con reporteros anónimos directamente desde la interfaz del administrador	X
I4	Classification / categorisation	Clasificación / categorización	X
I5	Set priorities and statuses of incidents	Establecer prioridades y estados de incidentes	X
I6	Delegation of cases	Delegación de casos	X
I7	Split of access rights between users	Separación de derechos de acceso entre usuarios	X
I8	Default process workflow	Flujo de trabajo del proceso predeterminado	X
I9	Incident Registration by Managers: Incident drafts + Internal Memos + Incident Report	Registro de Incidencias por Gestores: Borradores de Incidencias + Memos Internos + Informe de Incidencias	X
I10	Incident import	Importación de incidentes	X
I11	Escalations	Escalaciones	X
I12	Automations	Automatización	X
Case management		Gestión de casos	
C1	Team messages	Mensajes de equipo	X



C2	Case team	equipo de caso	X
C3	Case materials	Materiales de caso	X
C4	Involved	Involucrado	X
C5	Case team conclusions	Conclusiones del equipo del caso	X
C6	Case activity log	Registro de actividad del caso	X
C7	Case report with PDF export	Informe de caso con la exportación PDF	X
C8	Case facts	Hechos resueltos	X
C9	Case connections	Conexión de casos	X
C10	Search	Búsqueda	X
C11	Management decision	Soluciones de gestión	X
C12	Disciplinary actions	Acciones disciplinarias	X
C13	Corrective actions	Acciones correctas	X
C14	Custom roles	Roles especiales	X
C15	Task workflows	Flujos de trabajo de tareas	X
C16	Templates	Plantillas	X
C17	Split of access rights by regions, divisions and organizational hierarchy	Separación de derechos de acceso por regiones, divisiones y jerarquía organizativa	X
Analytics and reporting		Análisis e informes	
A1	Case table export into XLS	Exportación de tablas de casos a XLS	X
A2	General outlook	Panorama general	X
A3	Export of charts into PNG, JPG, SVG	Exportación de gráficos a PNG, JPG, SVG	X
A4	Groups: - Categories - Units - Channels - Assigned - Segments - Disciplinary actions	Grupos: - Categorías - Unidades - Canales - Asignado - Segmentos - Acciones disciplinarias	X
A5	Response rate	Tasa de respuesta	X
A8	Case memorandum report generator	Generador de informes de memorandos de casos	X
A6	Investigation duration	Duración de la investigación	X
A7	Quality of response and investigation	Calidad de la respuesta y la investigación	X
A9	Period outlook with weekly and monthly	Perspectiva del período con semanal y mensual	X
A10	Consolidated report with PDF export	Informe consolidado con exportación a PDF	X
A11	Quantitative report	Informe cuantitativo	X
Data and security		Datos y seguridad	
D1	Certified under ISO 27001 Information Security Management System	Certificado bajo el Sistema de Gestión de Seguridad de la Información ISO 27001	X



D2	Certified under ISO 27701 Privacy management system	Certificado bajo ISO 27701 Sistema de gestión de privacidad	X
D3	Certified Data Center - Linode - Germany - A shared server	Centro de datos certificado - Linode - Alemania - Un servidor compartido	X
D4	File storage	Almacenamiento de archivos con un límite de 10 GB	50GB
D5	Active web application firewall (WAF) - protection against common types of attacks (OWASP TOP 10)	Firewall de aplicaciones web activas (WAF): protección contra tipos comunes de ataques (OWASP TOP 10)	X
D6	Encryption of communication channels	Cifrado de canales de comunicación	X
D7	Encryption at rest (OS and database level)	Cifrado en reposo (nivel de sistema operativo y base de datos)	X
D8	Audit log	Registro de auditoría	X
D9	Multi-factor authentication (MFA; encompassing authentication, or 2FA, along with similar terms)	Autenticación de múltiples factores (MFA; autenticación integral o 2FA, junto con términos similares)	X
D10	Single sign-on (SSO)	Inicio de sesión único (SSO)	X
Training and support		Entrenamiento y soporte	
T1	Advice on implementation	Asesoramiento en la implementación	16 hours
T2	Graphic and text materials for a communication campaign (standard set of posters, stickers, letters, web-page template)	Materiales gráficos y de texto para una campaña de comunicación (conjunto estándar de carteles, pegatinas, cartas, plantilla de página web)	X
T3	Model code of business ethics	Código modelo de ética EMPRESA rial	X
T4	Model hotline regulations	Reglamento modelo de línea directa	X
T5	Model regulations for internal investigations	Reglamento modelo para investigaciones internas	X
T6	Free support 24/7	Soporte gratuito 24/7	X
T7	Live user training (2hr)	Capacitación de usuarios en vivo (2 horas)	2
T8	Support widget in the app	Widget de soporte en la aplicación	X
T9	User manual / Knowledge base and support portal	Manual de usuario / Base de conocimiento y portal de soporte	X
T10	Video explainer for whistleblowers branded for client	Video explicativo para denunciantes de marca para el cliente	X
T11	Custom NDA	Acuerdo de confidencialidad personalizado	X
T12	Service level agreement (SLA)	Acuerdo de nivel de servicio (SLA)	X
SaaS monthly subscription (USD) / Suscripción mensual SaaS (USD)			439.00
Total	per month (USD)		439.00
	per annum (USD)		5,268.00



Setup fees (USD)/Tarifas de instalación (USD)			
	Integration setup fee (AD / SSO)	Tarifa de instalación de la integración (AD / SSO)	900
			6,168.00
	Discount in case of Annual advance payment with a 3-year contract (13%)	Descuento en caso de pago anual por adelantado con un contrato de 3 años (13%)	13%
			684.84
			5,483.16

SAAS SERVICES AGREEMENT CONTRATO DE SERVICIOS SAAS

This SaaS Services Agreement ("Agreement") is entered into on this **26th day of February, 2024** (the "Effective Date") between Ethicontrol OU with a place of business at Ethicontrol ("Company"), and the Customer listed above ("Customer").

This Agreement includes and incorporates the above **SAAS SERVICES ORDER FORM**, as well as the attached Terms and Conditions and Annexes:

- Annex 1 TERMS AND CONDITIONS
- Annex 2 DATA PROCESSING AGREEMENT (DPA)
- Annex 3 BANBIF FUNCTIONAL REQUIREMENTS
- Annex 4 TECHNICAL REQUIREMENTS
- Annex 5 ETHICONTROL PORTAL TERMS AND CONDITIONS
- Annex 6 COMPANY AND SERVICE QUESTIONNAIRE
- Annex 7 INFORMATION SECURITY POLICIES
- Annex 8 REGULATORY CLAUSES

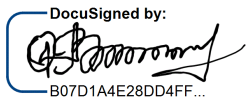
There shall be no force or effect to any different terms of any related purchase order or similar form even if signed by the parties after the date hereof.

El presente Contrato de Servicios SaaS («Contrato») se establece **el día 26 de febrero de 2024** (la «Fecha de entrada en vigor») entre Ethicontrol OU con domicilio social en Ethicontrol («Empresa»), y el Cliente indicado anteriormente («Cliente»).

El presente Contrato incluye e incorpora el anterior **HOJA DE PEDIDO DE SERVICIOS SAAS**, así como los Términos y Condiciones y Anexos adjuntos:

- Anexo 1 TÉRMINOS Y CONDICIONES
- Anexo 2 CONTRATO DE TRATAMIENTO DE DATOS (DPA)
- Anexo 3 REQUERIMIENTOS FUNCIONALES DE BANBIF
- Anexo 4 REQUERIMIENTOS TÉCNICOS
- Anexo 5 TERMINOS Y CONDICIONES DEL PORTAL DE ETHICONTROL
- Anexo 6 CUESTIONARIO EMPRESA Y SERVICIO
- Anexo 7 POLÍTICAS DE SEGURIDAD DE LA INFORMACIÓN
- Anexo 8 CLÁUSULAS REGULATORIAS

No tendrán validez ni efecto los términos diferentes de cualquier orden de compra relacionada o formulario similar, aunque hayan sido firmados por las partes con posterioridad a la fecha del presente documento.

Ethicontrol, OU:	BanBif - Inter-American Finance Bank:
By/Por:  DocuSigned by: B07D1A4E28DD4FF... Name/Nombre: Oleg Lagodiyenko Title/Posición: CEO 3/17/2025	By/Por:  Firmado por: 46F75473290B4C5... Name/Nombre: José Antonio Osorio Balarezo Title/Posición: Gerente de administración y seguridad/Administration and Security Manager  Firmado por: 8A98F7D532AC4EA... Name/Nombre: Elvira Catherine Prevost Zarate/ Title/Posición: Vicepresidente de Personas y Cultura/ Vice-President for People and Culture



Annex 1

TERMS AND CONDITIONS

1. SAAS SERVICES AND SUPPORT

1.1 Subject to the terms of this Agreement, Company will use commercially reasonable efforts to provide Customer the Services in accordance with the Service Level Terms attached hereto as Annex 2. As part of the registration process, Customer will identify an administrative user name and password for Customer's Company account. Company reserves the right to refuse registration of, or cancel passwords it deems inappropriate.

1.2 Subject to the terms hereof, Company will provide Customer with reasonable technical support services in accordance with the Company's standard practice.

2. RESTRICTIONS AND RESPONSIBILITIES

2.1 Customer will not, directly or indirectly: reverse engineer, decompile, disassemble or otherwise attempt to discover the source code, object code or underlying structure, ideas, know-how or algorithms relevant to the Services or any software, documentation or data related to the Services ("Software"); modify, translate, or create derivative works based on the Services or any Software (except to the extent expressly permitted by Company or authorized within the Services); use the Services or any Software for time sharing or service bureau purposes or otherwise for the benefit of a third; or remove any proprietary notices or labels. With respect to any Software that is distributed or provided to Customer for use on Customer premises or devices, Company hereby grants Customer a non-exclusive, non-transferable, non-sublicensable license to use such Software during the Term only in connection with the Services.

2.2 Customer represents, covenants, and warrants that Customer will use the Services only in compliance with Company's standard published policies then in effect (the "Policy") <https://ethicontrol.com/en/terms-of-business> and all applicable laws and regulations. Customer hereby agrees to indemnify and hold harmless Company against any damages, losses, liabilities, settlements and expenses (including without limitation costs and attorneys' fees) in connection with any claim or action that arises from an

Anexo 1

TÉRMINOS Y CONDICIONES

1. SERVICIOS Y ASISTENCIA DE SAAS

1.1 Sujeto a los términos de este Contrato, la Empresa hará todos los esfuerzos comercialmente razonables para proporcionar al Cliente los Servicios de acuerdo con los Términos de Nivel de Servicio que se adjuntan como Anexo 2. Como parte del proceso de registro, el Cliente identificará un nombre de usuario administrativo y una contraseña para la cuenta de la Empresa del Cliente. La Empresa se reserva el derecho a rechazar el registro o a cancelar las contraseñas que considere inapropiadas.

1.2 Sujeto a los términos del presente, la Empresa proporcionará al Cliente servicios de soporte técnico razonables de acuerdo con la práctica habitual de la Empresa.

2. RESTRICCIONES Y RESPONSABILIDADES

2.1 El Cliente no podrá, directa o indirectamente: realizar ingeniería inversa, descompilar, desensamblar o intentar descubrir el código fuente, código objeto o estructura subyacente, ideas, conocimientos o algoritmos relevantes para los Servicios o cualquier software, documentación o datos relacionados con los Servicios («Software»); modificar, traducir o crear trabajos derivados basados en los Servicios o cualquier Software (excepto en la medida expresamente permitida por la Empresa o autorizada dentro de los Servicios); utilizar los Servicios o cualquier Software con fines de tiempo compartido u oficina de servicios o de otro modo en beneficio de un tercero; o eliminar cualquier aviso o etiqueta de propiedad. Con respecto a cualquier Software que se distribuya o proporcione al Cliente para su uso en las instalaciones o dispositivos del Cliente, la Empresa concede al Cliente una licencia no exclusiva, intransferible y no sublicenciable para utilizar dicho Software durante el Periodo de vigencia únicamente en relación con los Servicios.

2.2 El Cliente declara, acuerda y garantiza que el Cliente utilizará los Servicios únicamente de conformidad con las políticas estándar publicadas por la Empresa y vigentes en ese momento (la «Política») <https://ethicontrol.com/en/terms-of-business> y con todas las leyes y normativas aplicables. Por la presente, el Cliente acepta indemnizar y eximir de responsabilidad a la Empresa por cualquier daño, pérdida, responsabilidad, acuerdo y gasto (incluidos, entre otros, costes y



alleged violation of the foregoing or otherwise from Customer's use of Services. Although Company has no obligation to monitor Customer's use of the Services, Company may do so and may prohibit any use of the Services it believes may be (or alleged to be) in violation of the foregoing.

2.3 Customer shall be responsible for obtaining and maintaining any equipment and ancillary services needed to connect to, access or otherwise use the Services, including, without limitation, modems, hardware, servers, software, operating systems, networking, web servers and the like (collectively, "Equipment"). Customer shall also be responsible for maintaining the security of the Equipment, Customer account, passwords (including but not limited to administrative and user passwords) and files, and for all uses of Customer account or the Equipment with or without Customer's knowledge or consent.

3. CONFIDENTIALITY; PROPRIETARY RIGHTS

3.1 Each party (the "Receiving Party") understands that the other party (the "Disclosing Party") has disclosed or may disclose business, technical or financial information relating to the Disclosing Party's business (hereinafter referred to as "Proprietary Information" of the Disclosing Party). Proprietary Information of Company includes non-public information regarding features, functionality and performance of the Service. Proprietary Information of Customer includes non-public data provided by Customer to Company to enable the provision of the Services ("Customer Data").

The Receiving Party agrees:

- (i) to take reasonable precautions to protect such Proprietary Information, and
- (ii) not to use (except in performance of the Services or as otherwise permitted herein) or divulge to any third person any such Proprietary Information.

The Disclosing Party agrees that the foregoing shall not apply with respect to any information after five (5) years following the disclosure thereof or any information that the Receiving Party can document

- (a) is or becomes generally available to the public, or
- (b) was in its possession or known by it prior to receipt from the Disclosing Party, or
- (c) was rightfully disclosed to it without restriction by a third party, or

honorarios de abogados) en relación con cualquier reclamación o acción que surja de una supuesta infracción de lo anterior o del uso de los Servicios por parte del Cliente. Aunque la Empresa no tiene obligación de supervisar el uso que el Cliente haga de los Servicios, podrá hacerlo y podrá prohibir cualquier uso de los Servicios que considere que pueda ser (o presuntamente sea) contrario a lo anterior.

2.3 El Cliente será responsable de obtener y mantener cualquier equipo y servicios auxiliares necesarios para conectarse a los Servicios, acceder a ellos o utilizarlos de cualquier otro modo, incluyendo, sin limitación, módems, hardware, servidores, software, sistemas operativos, redes, servidores web y similares (colectivamente, el «Equipo»). El Cliente también será responsable de mantener la seguridad del Equipo, la cuenta del Cliente, las contraseñas (incluidas, entre otras, las contraseñas administrativas y de usuario) y los archivos, así como de todos los usos de la cuenta del Cliente o del Equipo con o sin el conocimiento o consentimiento del Cliente.

3. CONFIDENCIALIDAD; DERECHOS DE PROPIEDAD

3.1 Cada una de las partes (la «Parte Receptora») entiende que la otra parte (la «Parte Divulgadora») ha divulgado o puede divulgar información empresarial, técnica o financiera relacionada con el negocio de la Parte Divulgadora (en lo sucesivo, «Información Privilegiada» de la Parte Divulgadora). La Información Privilegiada de la Empresa incluye información no pública relativa a las características, funcionalidad y rendimiento del Servicio. La Información Privilegiada del Cliente incluye datos no públicos proporcionados por el Cliente a la Empresa para permitir la prestación de los Servicios («Datos del Cliente»).

La Parte Receptora se compromete a:

- (i) tomar precauciones razonables para proteger dicha Información Privilegiada, y
- (ii) no utilizar (excepto en el desempeño de los Servicios o según lo permitido en el presente documento) ni divulgar a terceros dicha Información Privilegiada.

La Parte Divulgadora acuerda que lo anterior no se aplicará con respecto a cualquier información después de los cinco (5) años siguientes a la divulgación de la misma o cualquier información que la Parte Receptora pueda documentar que

- (a) esté o pase a estar generalmente a disposición del público, o
- (b) estaba en su posesión o era conocida por ella antes de recibirla de la Parte Divulgadora, o
- (c) le fue legítimamente revelada sin restricciones por un tercero, o



(d) was independently developed without use of any Proprietary Information of the Disclosing Party or
(e) is required to be disclosed by law.

3.2 Customer shall own all right, title and interest in and to the Customer Data, as well as any data that is based on or derived from the Customer Data and provided to Customer as part of the Services. Company shall own and retain all right, title and interest in and to

(a) the Services and Software, all improvements, enhancements or modifications thereto,
(b) any software, applications, inventions or other technology developed in connection with Implementation Services or support, and
(c) all intellectual property rights related to any of the foregoing.

3.3 Notwithstanding anything to the contrary, Company shall have the right collect and analyze data and other information relating to the provision, use and performance of various aspects of the Services and related systems and technologies (including, without limitation, information concerning Customer Data and data derived therefrom), and Company will be free (during and after the term hereof) to

(i) use such information and data to improve and enhance the Services and for other development, diagnostic and corrective purposes in connection with the Services and other Company offerings, and

(ii) disclose such data solely in aggregate or other de-identified form in connection with its business. No rights or licenses are granted except as expressly set forth herein.

4. PAYMENT OF FEES

4.1 Customer will pay Company the then applicable fees described in the Order Form for the Services and Implementation Services in accordance with the terms therein (the "Fees"). If Customer's use of the Services exceeds the Service Capacity set forth on the Order Form or otherwise requires the payment of additional fees (per the terms of this Agreement), Customer shall be billed for such usage and Customer agrees to pay the additional fees in the manner provided herein. Company reserves the right to change the Fees or applicable charges and to institute new charges and Fees at the end of the Initial Service Term or then current renewal term, upon thirty (30) days prior notice to Customer (which may be sent by email). If Customer believes that Company has billed Customer incorrectly, Customer must contact Company no

(d) fue desarrollada de forma independiente sin utilizar ninguna Información Privilegiada de la Parte Divulgadora o
(e) la ley exige su divulgación.

3.2 El Cliente será el propietario de todos los derechos, títulos e intereses sobre los Datos del Cliente, así como de cualquier dato basado o derivado de los Datos del Cliente y proporcionado al Cliente como parte de los Servicios. La Empresa será propietaria y conservará todos los derechos, títulos e intereses sobre

(a) los Servicios y el Software, así como todas las mejoras, ampliaciones o modificaciones de los mismos,
(b) cualquier software, aplicación, invención u otra tecnología desarrollada en relación con los Servicios de implementación o soporte, y
(c) todos los derechos de propiedad intelectual relacionados con cualquiera de los anteriores.

3.3 Sin perjuicio de cualquier disposición en contrario, la Empresa tendrá derecho a recopilar y analizar datos y otra información relativa a la prestación, uso y rendimiento de diversos aspectos de los Servicios y sistemas y tecnologías relacionados (incluyendo, sin limitación, información relativa a los Datos del Cliente y datos derivados de los mismos), y la Empresa tendrá libertad (durante y después de la vigencia del presente) para

(i) utilizar dicha información y datos para mejorar y perfeccionar los Servicios y para otros fines de desarrollo, diagnóstico y corrección en relación con los Servicios y otras ofertas de la Empresa, y

(ii) divulgar dichos datos únicamente de forma agregada o no identificada en relación con su actividad empresarial. No se concede ningún derecho ni licencia, salvo los establecidos expresamente en el presente documento.

4. PAGOS

4.1 El Cliente abonará a la Empresa las cuotas aplicables en cada momento descritas en la Orden de Pedido por los Servicios y los Servicios de Implantación de acuerdo con los términos de la misma (las «Cuotas»). Si el uso de los Servicios por parte del Cliente excede la Capacidad de Servicio establecida en la Orden de Pedido o requiere el pago de cuotas adicionales (según los términos de este Contrato), se facturará al Cliente por dicho uso y el Cliente acepta pagar las cuotas adicionales en la forma prevista en este documento. La Empresa se reserva el derecho a modificar las Tarifas o los cargos aplicables y a establecer nuevos cargos y Tarifas al final del Período Inicial de Servicio o del período de renovación vigente, previa notificación al Cliente con treinta (30) días de antelación (que podrá enviarse por correo electrónico). Si el Cliente



later than 60 days after the closing date on the first billing statement in which the error or problem appeared, in order to receive an adjustment or credit. Inquiries should be directed to Company's customer support department.

4.2 Company may choose to bill through an invoice, in which case, full payment for invoices issued in any given month must be received by Company thirty (30) days after the mailing date of the invoice. Unpaid amounts are subject to a finance charge of 1.5% per month on any outstanding balance, or the maximum permitted by law, whichever is lower, plus all expenses of collection and may result in immediate termination of Service. Customer shall be responsible for all taxes associated with Services other than EU taxes based on Company's net income.

5. TERM AND TERMINATION

5.1 Subject to earlier termination as provided below, this Agreement is for the Initial Service Term as specified in the Order Form, and shall be automatically renewed for additional periods of the same duration as the Initial Service Term (collectively, the "Term"), unless either party requests termination at least thirty (30) days prior to the end of the then-current term.

5.2 In addition to any other remedies it may have, either party may also terminate this Agreement upon sixty (60) days' notice (or without notice in the case of nonpayment). Customer will pay in full for the Services up to and including the last day on which the Services are provided. Upon any termination, Company will make all Customer Data available to Customer for electronic retrieval for a period of thirty (30) days, but thereafter Company may, but subsequently the Company must delete the Client Data. All sections of this Agreement which by their nature should survive termination will survive termination, including, without limitation, accrued rights to payment, confidentiality obligations, warranty disclaimers, and limitations of liability.

6. WARRANTY AND DISCLAIMER

6.1 Company shall use reasonable efforts consistent with prevailing industry standards to maintain the Services in a

considera que la Empresa le ha facturado incorrectamente, deberá ponerse en contacto con la Empresa a más tardar 60 días después de la fecha de cierre del primer extracto de facturación en el que aparezca el error o problema, con el fin de recibir un ajuste o abono. Las consultas deberán dirigirse al departamento de atención al cliente de la Empresa.

4.2 La Empresa podrá optar por facturar mediante factura, en cuyo caso, la Empresa deberá recibir el pago íntegro de las facturas emitidas en un mes determinado treinta (30) días después de la fecha de envío de la factura. Las cantidades impagadas están sujetas a un cargo financiero del 1,5% mensual sobre cualquier saldo pendiente, o el máximo permitido por la ley, el que sea menor, más todos los gastos de cobro, y pueden dar lugar a la terminación inmediata del Servicio. El Cliente será responsable de todos los impuestos asociados a los Servicios que no sean los impuestos de la UE basados en los ingresos netos de la Empresa.

5. DURACIÓN Y RESCISIÓN

5.1 Sujeto a rescisión anticipada según lo dispuesto a continuación, el presente Contrato tendrá una duración igual a la del Periodo Inicial de Servicio especificado en la Orden de Pedido, y se renovará automáticamente por periodos adicionales de la misma duración que el Periodo Inicial de Servicio (conjuntamente, el «Periodo»), a menos que cualquiera de las partes solicite su rescisión al menos treinta (30) días antes de la finalización del periodo vigente en ese momento.

5.2 Además de cualquier otro recurso que pudiera corresponderle, cualquiera de las partes también podrá rescindir el presente Contrato con un preaviso de sesenta(60) días (o sin preaviso en caso de impago). El Cliente pagará la totalidad de los Servicios hasta el último día de prestación de los mismos, inclusive. Tras cualquier rescisión, la Empresa pondrá a disposición del Cliente todos los Datos del Cliente para su recuperación electrónica durante un periodo de treinta (30) días, pero posteriormente la Empresa deberá eliminar los Datos del Cliente. Todas las secciones de este Acuerdo que por su naturaleza deban sobrevivir a la rescisión sobrevivirán a la rescisión, incluidos, entre otros, los derechos de pago acumulados, las obligaciones de confidencialidad, las renunciaciones de garantía y las limitaciones de responsabilidad.

6. GARANTÍA Y EXENCIÓN DE RESPONSABILIDAD

6.1 La Empresa se esforzará en la medida de lo razonable y de conformidad con las normas vigentes en el sector



manner which minimizes errors and interruptions in the Services and shall perform the Implementation Services in a professional and workmanlike manner. Services may be temporarily unavailable for scheduled maintenance or for unscheduled emergency maintenance, either by Company or by third-party providers, or because of other causes beyond Company's reasonable control, but Company shall use reasonable efforts to provide advance notice in writing or by e-mail of any scheduled service disruption.

6.2 However, company does not warrant that the services will be uninterrupted or error free; nor does it make any warranty as to the results that may be obtained from use of the services. Except as expressly set forth in this section, the services and implementation services are provided "as is" and company disclaims all warranties, express or implied, including, but not limited to, implied warranties of merchantability and fitness for a particular purpose and non-infringement.

7. INDEMNITY

7.1 Company shall hold Customer harmless from liability to third parties resulting from infringement by the Service of any United States / EU patent or any copyright or misappropriation of any trade secret, provided Company is promptly notified of any and all threats, claims and proceedings related thereto and given reasonable assistance and the opportunity to assume sole control over defense and settlement; Company will not be responsible for any settlement it does not approve in writing.

The foregoing obligations do not apply with respect to portions or components of the Service:

- (i) not supplied by Company,
- (ii) made in whole or in part in accordance with Customer specifications,
- (iii) that are modified after delivery by Company,
- (iv) combined with other products, processes or materials where the alleged infringement relates to such combination,
- (v) where Customer continues allegedly infringing activity after being notified thereof or after being informed of modifications that would have avoided the alleged infringement, or
- (vi) where Customer's use of the Service is not strictly in accordance with this Agreement.

para mantener los Servicios de forma que se reduzcan al mínimo los errores y las interrupciones de los mismos, y prestará los Servicios de Implementación de forma profesional y diligente. Los Servicios pueden no estar disponibles temporalmente por mantenimiento programado o por mantenimiento de emergencia no programado, ya sea por la Empresa o por terceros proveedores, o debido a otras causas fuera del control razonable de la Empresa, pero la Empresa hará todo lo razonablemente posible para notificar con antelación por escrito o por correo electrónico cualquier interrupción programada del servicio.

6.2 No obstante, la empresa no garantiza que los servicios sean ininterrumpidos o estén libres de errores; tampoco ofrece garantía alguna en cuanto a los resultados que puedan obtenerse del uso de los servicios. Salvo que se establezca expresamente en esta sección, los servicios y los servicios de implementación se proporcionan «tal cual» y la empresa rechaza todas las garantías, expresas o implícitas, incluidas, entre otras, las garantías implícitas de comerciabilidad e idoneidad para un fin determinado y de no infracción.

7. INDEMNIDAD

7.1 La Empresa eximirá al Cliente de toda responsabilidad frente a terceros derivada de la infracción por parte del Servicio de cualquier patente de Estados Unidos/UE o de cualquier derecho de autor o de la apropiación indebida de cualquier secreto comercial, siempre y cuando se notifique puntualmente a la Empresa de todas y cada una de las amenazas, reclamaciones y procedimientos relacionados con las mismas y se le proporcione asistencia razonable y la oportunidad de asumir el control exclusivo de la defensa y la resolución; la Empresa no será responsable de ninguna resolución que no apruebe por escrito.

Las obligaciones anteriores no se aplican con respecto a partes o componentes del Servicio

- (i) no suministrados por la Empresa,
- (ii) fabricados total o parcialmente de acuerdo con las especificaciones del Cliente,
- (iii) que sean modificados después de la entrega por la Empresa,
- (iv) combinados con otros productos, procesos o materiales cuando la presunta infracción se refiera a dicha combinación,
- (v) cuando el Cliente continúe con la actividad presuntamente infractora tras haber sido notificado de la misma o tras haber sido informado de las modificaciones que habrían evitado la presunta infracción, o
- (vi) cuando el uso del Servicio por parte del Cliente no se ajuste estrictamente a lo dispuesto en el presente Contrato.



7.2 If, due to a claim of infringement, the Services are held by a court of competent jurisdiction to be or are believed by Company to be infringing, Company may, at its option and expense

- (a) replace or modify the Service to be non-infringing provided that such modification or replacement contains substantially similar features and functionality,
- (b) obtain for Customer a license to continue using the Service, or
- (c) if neither of the foregoing is commercially practicable, terminate this Agreement and Customer's rights hereunder and provide Customer a refund of any prepaid, unused fees for the Service.

8. LIMITATION OF LIABILITY

8.1 Notwithstanding anything to the contrary, except for bodily injury of any person or willful misconduct or gross negligence, company and its suppliers (including but not limited to all equipment and technology suppliers), officers, affiliates, representatives, contractors and employees shall not be responsible or liable with respect to any subject matter of this agreement or terms and conditions related thereto under any contract, negligence, strict liability or other theory:

- (a) for error or interruption of use or for loss or inaccuracy or corruption of data or cost of procurement of substitute goods, services or technology or loss of business;
- (b) for any indirect, exemplary, incidental, special or consequential damages; unless arising from the Company's fundamental breaches in the provision of the Services;
- (c) for any matter beyond company's reasonable control, unless arising from the failure to implement timely corrective action; or
- (d) for any amounts that, together with amounts associated with all other claims, exceed the fees paid by customer to company for the services under this agreement in the 12 months prior to the act that gave rise to the liability.

In each case, whether or not the company has been advised of the possibility of such damages, it undertakes to take reasonable steps to mitigate any loss to the Customer arising from a failure to provide the service.

7.2 Si, debido a una reclamación por infracción, un tribunal de jurisdicción competente considera que los Servicios infringen o cree que la Empresa infringe, la Empresa podrá, a su elección y a sus expensas

- (a) sustituir o modificar el Servicio para que no infrinja la ley, siempre que dicha modificación o sustitución contenga características y funcionalidades sustancialmente similares,
- (b) obtener para el Cliente una licencia para seguir utilizando el Servicio, o bien
- (c) si ninguna de las anteriores opciones es comercialmente viable, rescindir este Contrato y los derechos del Cliente en virtud del mismo y proporcionar al Cliente un reembolso de cualquier pago anticipado y no utilizado de los pagos por el Servicio.

8. LIMITACIÓN DE RESPONSABILIDAD

8.1 Sin perjuicio de cualquier disposición en contrario, salvo en caso de lesiones corporales de una persona o dolo o culpa grave, la empresa y sus proveedores (incluidos, entre otros, todos los proveedores de equipos y tecnología), directivos, afiliados, representantes, contratistas y empleados no serán responsables con respecto a ningún asunto del presente Contrato o de los términos y condiciones relacionados con el mismo en virtud de ningún contrato, negligencia, responsabilidad objetiva u otra teoría:

- (a) por error o interrupción de uso o por pérdida o inexactitud o corrupción de datos o coste de adquisición de bienes, servicios o tecnología sustitutivos o pérdida de negocio;
- (b) por cualquier daño indirecto, ejemplar, incidental, especial o consecuente, salvo que deriven de incumplimientos esenciales de la Empresa en la prestación de los Servicio;
- (c) por cualquier asunto que escape al control razonable de la empresa, salvo que derive de la falta de implementación de medidas correctivas oportunas; o
- (d) por cualquier importe que, junto con los importes asociados a todas las demás reclamaciones, supere los pagos efectuados por el cliente a la empresa por los servicios contemplados en este Contrato en los 12 meses anteriores al hecho que dio lugar a la responsabilidad.

En cada caso, independientemente de que la empresa haya sido advertida o no de la posibilidad de tales daños, se compromete a adoptar medidas razonables para mitigar cualquier afectación al Cliente derivada de una falla en la prestación del servicio.



9. MISCELLANEOUS

9.1 If any provision of this Agreement is found to be unenforceable or invalid, that provision will be limited or eliminated to the minimum extent necessary so that this Agreement will otherwise remain in full force and effect and enforceable. This Agreement is not assignable, transferable or sublicensable by Customer except with Company's prior written consent.

9.2 Company may transfer and assign any of its rights and obligations under this Agreement with the knowledge and acceptance of the customer; and it must be demonstrated that the new company to which the rights are transferred must be a qualified company and that it will be able to fully and efficiently perform the service'.

This Agreement is the complete and exclusive statement of the mutual understanding of the parties and supersedes and cancels all previous written and oral agreements, communications and other understandings relating to the subject matter of this Agreement, and that all waivers and modifications must be in a writing signed by both parties, except as otherwise provided herein.

9.3 No agency, partnership, joint venture, or employment is created as a result of this Agreement and Customer does not have any authority of any kind to bind Company in any respect whatsoever. In any action or proceeding to enforce rights under this Agreement, the prevailing party will be entitled to recover costs and attorneys' fees.

9.4 All notices under this Agreement will be in writing and will be deemed to have been duly given when received, if personally delivered; when receipt is electronically confirmed, if transmitted by facsimile or e-mail; the day after it is sent, if sent for next day delivery by recognized overnight delivery service; and upon receipt, if sent by certified or registered mail, return receipt requested. This Agreement shall be governed by the laws of the European Union without regard to its conflict of laws provisions.

9.5 Customer agrees to reasonably cooperate with the Company to serve as a reference account upon request.

9. VARIOS

9.1 Si alguna de las disposiciones del presente Contrato resultara inaplicable o inválida, dicha disposición se limitará o eliminará en la medida mínima necesaria para que el presente Contrato siga siendo plenamente vigente y aplicable. El Cliente no podrá ceder, transferir ni sublicenciar el presente Contrato, salvo previo consentimiento por escrito de la Empresa.

9.2 La Empresa podrá transferir y ceder cualquiera de sus derechos y obligaciones en virtud del presente Contrato con el conocimiento y la aceptación del Cliente; y deberá demostrarse que la nueva empresa a la que se transfieren los derechos debe ser una empresa cualificada y que será capaz de realizar plena y eficazmente el servicio».

Este Acuerdo es la declaración completa y exclusiva del entendimiento mutuo de las partes y sustituye y anula todos los acuerdos, comunicaciones y otros entendimientos previos, escritos y orales, relacionados con el objeto de este Acuerdo, y que todas las renunciaciones y modificaciones deben constar por escrito y estar firmadas por ambas partes, salvo que se disponga lo contrario en el presente documento.

9.3 No se crea ninguna agencia, sociedad, empresa conjunta o empleo como resultado de este Contrato y el Cliente no tiene autoridad de ningún tipo para obligar a la Empresa en ningún aspecto. En cualquier acción o procedimiento para hacer valer los derechos en virtud del presente Contrato, la parte vencedora tendrá derecho a recuperar los costes y honorarios de abogados.

9.4 Todas las notificaciones en virtud del presente Contrato se realizarán por escrito y se considerarán debidamente efectuadas cuando se reciban, si se entregan personalmente; cuando se confirme electrónicamente la recepción, si se transmiten por fax o correo electrónico; al día siguiente de su envío, si se envían para su entrega al día siguiente mediante un servicio de entrega al día siguiente reconocido; y en el momento de su recepción, si se envían por correo certificado o registrado, con acuse de recibo. El presente Contrato se regirá por la legislación de la Unión Europea, sin tener en cuenta sus disposiciones en materia de conflicto de leyes.

9.5 El Cliente se compromete a cooperar razonablemente con la Empresa para servir como cuenta de referencia cuando ésta lo solicite.



10. Service Level Terms

10.1 The Services shall be available 99%, measured monthly, excluding scheduled maintenance.

10.1.1 The Company shall make all reasonable efforts to provide advance written or email notice of any scheduled service interruptions that may affect Customer's access to the service. Such notice shall be provided at least 3 (three) days in advance, except in cases of emergency maintenance, where notice shall be given as soon as practicable.

10.1.2 If Customer requests maintenance during these hours, any uptime or downtime calculation will exclude periods affected by such maintenance. Further, any downtime resulting from outages of third party connections or utilities or other reasons beyond Company's control will also be excluded from any such calculation.

10.1.3 Company will credit Customer percentage of Service fees according to the table:

Monthly Uptime Percentage	Service Credit
Less than 99.0% but greater than or equal to 98.0%	5%
Less than 98.0% but greater than or equal to 97.0%	10%
Less than 97.0% but greater than or equal to 95.0%	15%
Less than 95.0% but greater than or equal to 90.0%	25%
Less than 90.0%	40%

10.2 Downtime shall begin to accrue as soon as Customer (with notice to Company) recognizes that downtime is taking place by submitting a ticket at <https://help.ethicontrol.com>, and continues until the availability of the Services is restored.

10. Condiciones del nivel de servicio

10.1 Los Servicios estarán disponibles al 99%, medido mensualmente, excluyendo el mantenimiento programado.

10.1.1 La Empresa hará todos los esfuerzos razonables para notificar por escrito o por correo electrónico con antelación cualquier interrupción programada del servicio que pueda afectar al acceso del Cliente al servicio. Dicha notificación se realizará con un mínimo de 3 (tres) días de antelación, excepto en casos de mantenimiento de emergencia, en los que la notificación se realizará tan pronto como sea posible.

10.1.2 Si el Cliente solicita mantenimiento durante estas horas, cualquier cálculo de tiempo de actividad o de inactividad excluirá los periodos afectados por dicho mantenimiento. Además, cualquier tiempo de inactividad resultante de cortes de conexiones de terceros o servicios públicos u otras razones fuera del control de la Empresa también se excluirá de cualquier cálculo.

10.1.3 La Empresa abonará al Cliente un porcentaje de las tarifas del Servicio de acuerdo con la tabla:

Porcentaje mensual de tiempo de actividad	Crédito de servicio
Menos del 99,0% pero mayor o igual al 98,0%.	5%
Menos del 98,0% pero mayor o igual al 97,0%.	10%
Menos del 97,0% pero mayor o igual al 95,0%.	15%
Menos del 95,0% pero mayor o igual al 90,0%.	25%
Menos del 90,0%.	40%

10.2 El tiempo de inactividad comenzará a devengarse tan pronto como el Cliente (con notificación a la Empresa) reconozca que se está produciendo un tiempo de inactividad enviando un ticket a <https://help.ethicontrol.com>, y continuará hasta que se restablezca la disponibilidad de los Servicios.



10.3 To be eligible to receive a service credit for Company's failure to meet the Service Level Commitment ("Service Credit"), Customer must submit a ticket at <https://help.ethicontrol.com> with all fields fully and accurately completed within five (5) days after the end of the calendar month in which the alleged failure occurred and provide any other reasonably requested information or documentation. The failure to provide such notice will forfeit the right to receive downtime credit.

10.4 Company's monitoring and logging infrastructure is the sole source of truth for determining whether Company has met the Service Level Commitment.

10.5 If Company confirms a failure to meet the Service Level Commitment, Company will apply the Service Credit, which will be calculated as described above, against a future payment due from Customer, provided that Customer's account is fully paid up, without any overdue payments or disputes. No refunds or cash value will be given for unused Service Credits or any other fines imposed by the Agreement or Annexes. Service Credits may not be transferred or applied to any other Company account or Product. The aggregate maximum Service Credit applied to an invoice will not exceed 100% of the amount invoiced per month for the affected service in that invoice billing period (which, since Service Credits are applied to future payments, is not the month in which the affected Cloud Product was unavailable).

10.4 Remaining details according to the Ethicontrol Default SLA policy as stated
<https://ethicontrol.com/en/terms-of-business>

11. Retention of data

11.1 Upon termination or expiration of this Agreement, Company shall ensure the secure deletion of all Customer Data in accordance with industry best practices and applicable data protection regulations. Specifically, Company agrees to:

11.1.1 Data Retention Period: Retain Customer Data for no longer than 30 days following termination, unless otherwise required by law or agreed in writing.

11.1.2 Deletion Standards: Permanently delete all Customer Data from active systems and securely overwrite or destroy backups using industry-standard method ISO/IEC 27040.

10.3 Para tener derecho a recibir un crédito de servicio por el incumplimiento del Compromiso de nivel de servicio por parte de la Empresa («Crédito de servicio»), el Cliente deberá enviar un ticket a <https://help.ethicontrol.com> con todos los campos cumplimentados de forma completa y precisa en los cinco (5) días siguientes al final del mes natural en el que se produjo el supuesto fallo y proporcionar cualquier otra información o documentación razonablemente solicitada. De no hacerlo, perderá el derecho a recibir el crédito por tiempo de inactividad.

10.4 La infraestructura de supervisión y registro de la Empresa es la única fuente de verdad para determinar si la Empresa ha cumplido el Compromiso de Nivel de Servicio.

10.5 Si la Empresa confirma un incumplimiento del Compromiso de Nivel de Servicio, la Empresa aplicará el Crédito de Servicio, que se calculará como se ha descrito anteriormente, contra un pago futuro adeudado por el Cliente, siempre que la cuenta del Cliente esté totalmente pagada, sin pagos atrasados ni disputas. No se concederán reembolsos ni valor en efectivo por los Créditos de Servicio no utilizados ni por ninguna otra multa impuesta por el Contrato o los Anexos. Los Créditos de Servicio no podrán transferirse ni aplicarse a ninguna otra cuenta o Producto de la Empresa. El Crédito de Servicio máximo total aplicado a una factura no superará el 100% del importe facturado al mes por el servicio afectado en ese periodo de facturación (que, dado que los Créditos de Servicio se aplican a pagos futuros, no es el mes en el que el Producto en la nube afectado no estuvo disponible).

10.4 Detalles restantes según la política de SLA por defecto de Ethicontrol, tal y como se indica en <https://ethicontrol.com/en/terms-of-business>.

11. Eliminación de datos

11.1 Tras la rescisión o expiración del presente Contrato, la Empresa garantizará la eliminación segura de todos los Datos del Cliente de conformidad con las mejores prácticas del sector y la normativa aplicable en materia de protección de datos. En concreto, la Empresa se compromete a:

11.1.1 Periodo de Retención de Datos: Conservar los Datos del Cliente durante no más de 30 días tras la finalización, a menos que la ley exija lo contrario o se acuerde por escrito.

11.1.2 Normas de eliminación: Eliminar permanentemente todos los Datos del Cliente de los sistemas activos y sobrescribir o destruir de forma segura las copias de seguridad utilizando el método estándar del sector ISO/IEC 27040.



11.1.3 Certification of Deletion: Upon request, provide written confirmation verifying the secure disposal of Customer Data.

11.1.4 Third-Party Hosting: Ensure that any third-party service providers engaged in data processing also comply with these deletion obligations.

11.1.5 Company shall not retain, use, or disclose Customer Data beyond the period necessary for performing post-termination obligations (if any) or as legally required.

11.1.3 Certificación de eliminación: Previa solicitud, proporcionar una confirmación por escrito que verifique la eliminación segura de los Datos del cliente.

11.1.4 Alojamiento de terceros: Asegúrese de que cualquier proveedor de servicios de terceros que participe en el procesamiento de datos también cumpla con estas obligaciones de eliminación.

11.1.5 La Empresa no conservará, utilizará ni divulgará los Datos del cliente más allá del periodo necesario para cumplir con las obligaciones posteriores a la finalización (si las hubiera) o según lo exija la ley.



Annex 2

Data Processing Agreement (DPA)

pursuant to art. 28 General Data Protection Regulation (GDPR)
by and between

- the Controller

BanBif - Inter-American Finance Bank
Avenida Ricardo Rivera Navarrete 600, San Isidro, Lima,
Peru, 15046
banbif.com.pe
0-801-0-0456

- the Processor

Ethicontrol OÜ, 14338530
Orumetsa tn 5/1-15 Maardu Harjumaa 74111
Tornimäe 5, 2nd Floor, 10145 Tallinn
ethicontrol.com
info@ethicontrol.com
+372 668 2755

1. Subject matter, term, personal data processed, and categories of data subjects

(1) Subject matter

- o The processing activities that the Processor shall carry out are strictly limited to those necessary to fulfill the scope of the main contract signed by the parties on [March 4, 2025].
- o The Processor shall carry out the following processing activities on behalf of the Controller:
Register whistleblowing reports, Process web intake, Accept calls from whistleblowers, Register calls from whistleblowers, Maintain whistleblowing register database

(2) Term

Anexo 2

Acuerdo de Procesamiento de Datos (DPA)

de conformidad con el art. 28 del Reglamento General de Protección de Datos (GDPR)
por y entre

- el Controlador

BanBif - Banco Interamericano de Finanzas
Avenida Ricardo Rivera Navarrete 600, San Isidro, Lima,
Peru, 15046
banbif.com.pe
0-801-0-0456

- el Procesador

Ethicontrol OÜ, 14338530
Orumetsa tn 5/1-15 Maardu Harjumaa 74111
Tornimäe 5, 2nd Floor, 10145 Tallinn
ethicontrol.com
info@ethicontrol.com
+372 668 2755

1. Objeto, duración, datos personales tratados y categorías de sujetos de datos

(1) Objeto

- o Las actividades de tratamiento que llevará a cabo el Procesador se limitan estrictamente a las necesarias para cumplir el alcance del contrato principal firmado por las partes el [4 de marzo de 2025].
- o el Procesador llevará a cabo las siguientes actividades de tratamiento en nombre del Controlador:
Registrar informes de denuncia de irregularidades, Procesar la entrada web, Aceptar llamadas de denunciantes, Registrar llamadas de denunciantes, Mantener la base de datos del registro de denuncias de irregularidades.

(2) Duración



- o The term of this DPA corresponds to the term of the main contract.

- o La vigencia de este APD corresponde a la del contrato principal.

(3) Categories of personal data

- o The categories of personal data processed are:
 - personally identifiable information (e.g. name, surname, email, address)
 - incident information

(3) Categorías de datos personales

- o Las categorías de datos personales tratados son
 - información de identificación personal (por ejemplo, nombre, apellidos, correo electrónico, dirección)
 - información sobre incidentes

(4) Categories of Data Subjects

- o The personal data collected and processed related to:
 - whistleblowers
 - ethics and speak up hotline users
 - internet users or toll free line callers
 - employees, associates, staff members
 - internal consultants
 - authorised agents

(4) Categorías de sujetos de datos

- o Los datos personales recogidos y tratados se refieren a:
 - denunciantes de irregularidades
 - usuarios de la línea sobre ética y denuncia
 - usuarios de Internet o de la línea gratuita
 - empleados, asociados, miembros del personal
 - consultores internos
 - agentes autorizados

2. Technical and Organisational Measures

(1) Prior to the execution of this DPA, the Processor undertakes to adopt all the necessary technical and organisational security measures and to provide the Controller with a document whereby all such measures are described in detail, also in specific reference to the present agreement.

Such measures are subject to the Controller's scrutiny and to its prior approval. Upon the Controller's approval, such security measures, documented as above, will become an integral and substantial part of this agreement and are hereby incorporated by reference. Insofar as an inspection/audit by the Controller shows the necessity for amendments, such amendments shall be implemented by mutual agreement.

(2) The Processor warrants that it has taken all the security measures in accordance with Article 28 Paragraph 3 Point c, and Article 32 GDPR in particular in conjunction with Article 5 Paragraph 1, and Paragraph 2 GDPR. Such measures shall guarantee data security and a protection level adequate to the level of risk concerning confidentiality, integrity, availability, and resilience of the systems. According to Article 32, par. 1 GDPR the following must be taken into account when assessing the appropriateness of the security measures

2. Medidas técnicas y organizativas

(1) Antes de la ejecución del presente APD, el Procesador se compromete a adoptar todas las medidas de seguridad técnicas y organizativas necesarias y a facilitar al Controlador un documento en el que se describen detalladamente todas esas medidas, también en referencia específica al presente Contrato.

Dichas medidas están sujetas al examen del Controlador y a su aprobación previa. Una vez aprobadas por el Controlador, dichas medidas de seguridad, documentadas como se ha indicado anteriormente, pasarán a formar parte integrante y sustancial del presente Contrato y se incorporan al mismo por referencia. En la medida en que una inspección/auditoría del Controlador ponga de manifiesto la necesidad de introducir modificaciones, éstas se llevarán a cabo de mutuo acuerdo.

(2) El Procesador garantiza que ha adoptado todas las medidas de seguridad de conformidad con el artículo 28, apartado 3, letra c), y el artículo 32 del RGPD, en particular en relación con el artículo 5, apartado 1, y el apartado 2 del RGPD. Dichas medidas garantizarán la seguridad de los datos y un nivel de protección adecuado al nivel de riesgo relativo a la confidencialidad, integridad, disponibilidad y resiliencia de los sistemas. De conformidad con el artículo 32, par. 1 del RGPD, al evaluar la idoneidad de las medidas de seguridad



adopted: whether or not the measures can be reasonable considered to be state-of-the-art, the implementation costs, the nature, scope and purposes of processing as well as the likelihood of data breaches and the severity of risks to the rights and freedoms of natural persons.

(3) The technical and organisational measures are subject to technical and technological progress and development. Hence, the Processor may adopt alternative adequate measures which are up to date with the changed technological environment. When doing so, the processing security level may not be reduced. Substantial changes must be documented.

3. Data subjects rights

(1) The Processor undertakes to provide full cooperation and assistance, as it may be reasonably possible, in order to assist the Controller in responding to data subjects' requests for the exercising of their rights.

(2) In particular, the Processor undertakes to (i) immediately communicate to the Controller any request received by data subjects concerning the exercising of their rights and, if feasible and appropriate, to (ii) enable the Controller to design and deploy all the technical and organisational measures necessary to answer the data subjects' requests.

(3) Notwithstanding the fact that the Controller bears the responsibility to respond to the data subjects' requests, the Processor can accept to be tasked with the fulfillment of some specific requests, provided that such tasks do not require disproportionate efforts from the Processor and that the Controller provides detailed instructions in writing.

4. Further duties of the Processor

In addition to complying with the provisions of this DPA, the Processor commits to meet all applicable statutory requirements set forth at Articles 28 to 33 GDPR. To this end, the Processor warrants compliance with the following:

4.1 Appointment of a Data Protection Officer (DPO) The current DPO is:

Dr. Oleg Lagodiyenko, Tallinn, ID 38305310154

5.1.1 The Processor shall inform the Controller without delay about any changes of Data Protection Officer.

4.2 Confidentiality

Processing activities under this DPA shall only be performed by individuals (such as employees, agents, or staff members) that have been instructed by the Processor on the appropriate way to process data and have been

adoptadas deberán tenerse en cuenta los siguientes elementos: si las medidas pueden considerarse razonablemente de vanguardia, los costes de aplicación, la naturaleza, el alcance y los fines del tratamiento, así como la probabilidad de que se produzcan violaciones de los datos y la gravedad de los riesgos para los derechos y libertades de las personas físicas.

(3) Las medidas técnicas y organizativas están sujetas al progreso y desarrollo técnico y tecnológico. Por lo tanto, el Procesador podrá adoptar medidas alternativas adecuadas que estén al día con los cambios del entorno tecnológico. Al hacerlo, no podrá reducirse el nivel de seguridad del tratamiento. Los cambios sustanciales deberán documentarse.

3. Derechos de los sujetos de los datos

(1) el Procesador se compromete a prestar plena cooperación y asistencia, en la medida en que sea razonablemente posible, para ayudar al Controlador a responder a las solicitudes de los interesados para el ejercicio de sus derechos.

(2) En particular, el Procesador se compromete a (i) comunicar inmediatamente al responsable del tratamiento cualquier solicitud recibida por los interesados relativa al ejercicio de sus derechos y, si es factible y apropiado, a (ii) permitir al Controlador diseñar y desplegar todas las medidas técnicas y organizativas necesarias para responder a las solicitudes de los interesados.

(3) A pesar de que el Controlador tiene la responsabilidad de responder a las solicitudes de los interesados, el encargado del tratamiento puede aceptar que se le encomiende el cumplimiento de algunas solicitudes específicas, siempre que dichas tareas no requieran esfuerzos desproporcionados por parte del Procesador y que el Controlador proporciona instrucciones detalladas por escrito.

4. Otras obligaciones del Procesador

Además de cumplir las disposiciones de la presente DPA, el Procesador se compromete a cumplir todos los requisitos legales aplicables establecidos en los artículos 28 a 33 GDPR. A tal fin, el Procesador garantiza el cumplimiento de lo siguiente:

4.1 Nombramiento de un responsable de la protección de datos (RPD) El actual RPD es:

Dr. Oleg Lagodiyenko, Tallin, ID 38305310154

5.1.1 El Procesador informará sin demora al Controlador sobre cualquier cambio de Responsable de Protección de Datos.

4.2 Confidencialidad

Las actividades de Procesamiento en virtud de esta DPA sólo serán realizadas por personas (como empleados, agentes o miembros del personal) que hayan sido instruidas por el Procesador sobre la forma adecuada de



contractually subjected to confidentiality pursuant to art. 28 par. 3 (b) and art. 32 GDPR. The Processor, and any person acting under its authority who has access to the personal data, shall not process that data unless acting upon instructions given by the Controller — including the powers granted under this DPA — unless they are required to do so by statutory law.

4.3 Technical and Organisational Measures

Implementation of, and compliance with, all appropriate technical and organisational measures in the framework of this DPA, in particular as set forth at art. 32 GDPR. The Processor shall periodically monitor the internal processes and the technical and organisational measures to ensure that processing activities pertaining to it are carried out in accordance with the requirements of applicable data protection law and the protection of data subjects' rights. The Processor shall grant verifiability of the technical and organisational measures to the Controller as part of the Controller's supervisory powers referred to in sec. 7 of this contract.

4.4 Cooperation with Supervisory Authorities

The Controller and the Processor shall cooperate, on request, with the supervisory authority. The Controller shall be informed immediately of any inspections and measures executed by the supervisory authority, insofar as they relate to the activities under this DPA. This also applies insofar as the Processor is under investigation or is party to an investigation by a competent authority in connection with infringements to any provision regarding the processing of personal data in connection with the processing of this DPA. Insofar as the Controller is subject to an inspection by the supervisory authority, an administrative fine, a preliminary injunction or criminal procedure, a liability claim by a Data Subject or by a third party or any other claim in connection with the processing of data by the Processor as of this DPA, the Processor shall make every effort to support the Controller.

5. Sub-processors

(1) The Controller authorizes the Processor to outsource part of the processing activities pursuant to this DPA to sub-processors as listed in the table below. The sub-processors shall, as legally required, be subject to

procesar los datos y que hayan sido sometidas contractualmente a confidencialidad de conformidad con el art. 28 par. 3 (b) y art. 32 GDPR. El Procesador, y cualquier persona que actúe bajo su autoridad y que tenga acceso a los datos personales, no procesa esos datos a menos que actúe bajo las instrucciones dadas por el Controlador -incluidos los poderes otorgados en virtud de esta DPA- a menos que estén obligados a hacerlo por ley.

4.3 Medidas técnicas y organizativas

Implementación y cumplimiento de todas las medidas técnicas y organizativas apropiadas en el marco de esta DPA, en particular según lo establecido en el art. 32 DEL RGPD. El Encargado del tratamiento supervisará periódicamente los procesos internos y las medidas técnicas y organizativas para garantizar que las actividades de tratamiento que le corresponden se llevan a cabo de conformidad con los requisitos de la legislación aplicable en materia de protección de datos y protección de los derechos de los interesados. El Procesador garantizará la verificabilidad de las medidas técnicas y organizativas al Controlador como parte de los poderes de supervisión del Controlador a los que se hace referencia en la sec. 7 del presente contrato.

4.4 Cooperación con las autoridades de control

El Responsable y el Encargado del tratamiento cooperarán, previa solicitud, con la autoridad de control. El responsable del tratamiento será informado inmediatamente de las inspecciones y medidas ejecutadas por la autoridad de control, en la medida en que guarden relación con las actividades contempladas en el presente APD. Esto también se aplica en la medida en que el Procesador esté siendo investigado o sea parte de una investigación por parte de una autoridad competente en relación con infracciones de cualquier disposición relativa al tratamiento de datos personales en relación con la tramitación del presente APD. En la medida en que el Responsable del tratamiento sea objeto de una inspección por parte de la autoridad de control, de una multa administrativa, de una medida cautelar o de un procedimiento penal, de una reclamación de responsabilidad por parte de un Titular de los datos o de un tercero o de cualquier otra reclamación en relación con el tratamiento de datos por parte del Procesador a partir de la presente APD, el Procesador hará todo lo posible por apoyar al Responsable del tratamiento.

5. Sub-procesadores

(1) El Controlador autoriza al Procesador a subcontratar parte de las actividades de procesamiento en virtud del presente DPA a los sub-procesadores que se enumeran en la siguiente tabla. Los sub-procesadores estarán sujetos a las mismas obligaciones contractuales derivadas



the same contractual obligations resulting from this agreement, pursuant to art. 28 par. 4 GDPR.

[paragraph (2) is optional, only if sub-processors are already commissioned].

(2) At the date of signature of this agreement, the parties mutually acknowledge and agree that the Processor currently commissions the following sub-processors on the condition of a contractual agreement in accordance with Article 28 paragraph 4 GDPR:

del presente Contrato, de conformidad con el art. 28 par. 4 GDPR.

[el apartado (2) es opcional, solo si ya se ha encargado a sub-procesadores].

(2) En la fecha de la firma del presente Contrato, las partes reconocen y acuerdan mutuamente que el Procesador encarga actualmente a los siguientes subprocesadores bajo la condición de un Contrato de conformidad con el artículo 28, apartado 4 GDPR:

Subprocessor name/Nombre del subprocesador	Data shared/Datos compartidos	Tasks/Funciones	Data location/Localización de los datos
Microsoft	IP address/Dirección IP Report details/Detalles del informe	Hosting services for whistleblowing platform and case management/ Servicios de alojamiento para la plataforma de denuncia y gestión de casos	EU/ UE
Mailgun Technologies	IP address/Dirección IP User email/Correo electrónico del usuario Reporter's email/ Correo electrónico del reportero	Business email hosting from Ethicontrol platform mailings - noreply@ethics.email and dedicated email channel company@ethics.email . Alojamiento de correo electrónico EMPRESA rial de Ethicontrol plataforma mailings - noreply@ethics.email y canal de correo electrónico dedicado company@ethics.email .	EU/ UE
Cloudflare	IP address/Dirección IP	Content Delivery Network Used as a web infrastructure and website security, providing content delivery network services, DDoS mitigation, internet security, and distributed domain name server services/ Red de entrega de contenidos Utilizada como infraestructura web y seguridad de sitios web, proporciona servicios de red de entrega de contenidos, mitigación de ataques DDoS, seguridad en Internet y servicios de servidor de nombres de dominio distribuidos.	Local Data Centers located all around the world. Traffic will be automatically routed to the nearest data center./ Local Centros de datos situados en todo el mundo. El tráfico se dirigirá automáticamente al centro de datos más cercano.



Freshdesk	IP address Dirección IP User email/ Correo electrónico del usuario	Helpdesk portal for users. Knowledge base and articles/ Portal de ayuda a los usuarios. Base de conocimientos y artículos	Germany/ Alemania
Waveapps Wave Financial Inc	Client's email/ Correo electrónico del cliente	Accounting and billing for international customers/ Contabilidad y facturación para clientes internacionales	Canada/ Canadá
Wise	Client's email/ Correo electrónico del cliente	Accounting and banking/ Contabilidad y banca	Estonia/ Estonia
Google Inc.	Correo electrónico del cliente y PII del funcionario	Back office/ Oficina interna	EU (Ireland)/ UE (Irlanda)
Usetiful	IP address/Dirección IP	User onboarding/ Integración de usuarios	Estonia / Germany Estonia / Alemania

(3) It is understood between the parties that the communication of personal data to any sub-processor shall only take place after all conditions set out in paragraph (1) for the appointment of sub-processors have been met.

(4) The Processor must maintain and keep updated a list of sub-processors. The Controller shall be notified in written of any change to such list without undue delay, giving the Controller the option to object. In case of objection, the Processor retains the right to terminate the contract in place with the Controller without notice and claim any fee paid for services that have not been rendered.

(5) The Processor shall bear full responsibility and liability for the activities of its sub-processors *vis a vis* the Controller.

(6) Should a sub-processor provide its services outside the EU/EEA, the Processor shall ensure compliance with the rules regarding data transfer abroad, as described under sec. 2 of this DPA.

6. Audits

(1) The Controller has the right to carry out inspections or to have them carried out by an auditor appointed on a case-by-case basis. The auditor shall assess the Processor's compliance with this DPA in its business

(3) Queda entendido entre las partes que la comunicación de datos personales a cualquier subprocesador parcial solo tendrá lugar una vez que se hayan cumplido todas las condiciones establecidas en el apartado (1) para la designación de Procesadores parciales.

(4) El Procesador deberá mantener actualizada una lista de subprocesadores. Se notificará por escrito al Controlador cualquier modificación de dicha lista sin demora indebida, dándole la opción de oponerse. En caso de oposición, el Procesador se reserva el derecho a rescindir el contrato vigente con el Controlador sin previo aviso y a reclamar cualquier pago efectuado por servicios no prestados.

(5) El Procesador será plenamente responsable de las actividades de sus subprocesadores frente al Controlador.

(6) En caso de que un subprocesador preste sus servicios fuera de la UE/EEE, el Procesador garantizará el cumplimiento de las normas relativas a la transferencia de datos al extranjero, tal y como se describe en la sección 2 de la presente DPA.

6. Auditorías

(1) El Controlador tiene derecho a realizar inspecciones o a que las realice un auditor designado caso por caso. El auditor evaluará el cumplimiento de la presente DPA por parte del Encargado del tratamiento en sus operaciones



operations by means of random checks, of which the Processor will be notified in advance.

(2) The Processor shall allow the Controller to verify compliance with its obligations as provided by Article 28 GDPR. The Processor undertakes to give the Controller the necessary information on request and, in particular, to demonstrate the implementation of the technical and organisational measures.

(3) Evidence of the implementation of such measures, which may not only concern the activities under this DPA, may also be provided by

- o compliance with approved Codes of Conduct pursuant to Article 40 GDPR;
- o certification according to an approved certification procedure in accordance with Article 42 GDPR;
- o current auditor's certificates, reports or excerpts from reports provided by independent bodies (e.g. auditor, data protection officer, IT security department, data protection auditor);
- o a suitable certification by IT security or data protection auditing.

(4) The Processor shall not charge any fee to the Controller for enabling inspections. The controller shall pay the auditor.

7. Assistance to the Controller

(1) The Processor shall assist the Controller in complying with the obligations concerning the security of personal data, reporting of data breaches, data protection impact assessments and prior consultations set forth at Articles 32 to 36 of the GDPR, including

- ensuring adequate protection standards through technical and organisational measures, taking into account the type, circumstances and purposes of processing, the likelihood of data breaches and the severity of the risk to natural persons possibly resulting thereof
- ensuring immediate detection of infringements
- reporting data breaches without undue delay to the Controller and within maximum 48 hours after the incident has been known to the processor and with a comprehensive description
- assisting the Controller in answering to data subjects' requests for the exercising of their rights

comerciales mediante controles aleatorios, de los que se informará previamente al Procesador.

(2) El Procesador permitirá al Controlador verificar el cumplimiento de sus obligaciones según lo dispuesto en el artículo 28 del GDPR. El Procesador se compromete a proporcionar al Controlador la información necesaria previa solicitud y, en particular, a demostrar la aplicación de las medidas técnicas y organizativas.

(3) Las pruebas de la aplicación de tales medidas, que no solo pueden referirse a las actividades contempladas en el presente DPA, también pueden consistir en

- o el cumplimiento de códigos de conducta aprobados de conformidad con el artículo 40 del RGPD
- o la certificación con arreglo a un procedimiento de certificación aprobado de conformidad con el artículo 42 del GDPR;
- o certificados actuales de auditores, informes o extractos de informes facilitados por organismos independientes (por ejemplo, auditor, responsable de protección de datos, departamento de seguridad informática, auditor de protección de datos);
- o una certificación adecuada de auditoría de seguridad informática o de protección de datos.

(4) El Procesador no cobrará ningún pago al Controlador por permitir las inspecciones. El Controlador pagará al auditor.

7. Asistencia al Controlador

(1) El Procesador asistirá al Controlador en el cumplimiento de las obligaciones relativas a la seguridad de los datos personales, la notificación de violaciones de datos, las evaluaciones de impacto de la protección de datos y las consultas previas establecidas en los artículos 32 a 36 del RGPD, en particular

- garantizar normas de protección adecuadas mediante medidas técnicas y organizativas, teniendo en cuenta el tipo, las circunstancias y los fines del tratamiento, la probabilidad de que se produzcan violaciones de datos y la gravedad del riesgo para las personas físicas que pueda derivarse de las mismas
- garantizar la detección inmediata de las infracciones
- notificar las violaciones de datos sin demora indebida al Controlador y en un plazo máximo de 48 horas después de que el Procesador haya tenido conocimiento del incidente y con una descripción exhaustiva del mismo
- ayudar al Controlador a responder a las solicitudes de los interesados para el ejercicio de



sus derechos

(2) The Processor shall not charge the Controller any fee for support services.

8. Directive powers of the Controller

(1) The Processor shall not process any personal data under this DPA except on the Controller's documented instructions, unless required to do so by Union or Member State law.

(2) In case the Controller should require any change in the processing of personal data set forth by the documented instructions mentioned at sec. 2, the Processor shall immediately inform the Controller if it considers such changes likely to result in infringements to data protection provisions. The Processor may refrain from carrying out any activity that may result in any such infringement.

9. Liability

(1) Each party to this DPA commits to indemnify the other party for damages or expenses resulting from its own culpable infringement of this DPA, including any culpable infringement committed by its legal representative, subcontractors, employees or any other agents. Furthermore, each party commits to indemnify the other party against any claim exerted by third parties due to, or in connection with, any culpable infringement by the respectively other party.

(2) Art. 82 GDPR stays unaffected.

10. Deletion and return of personal data

(1) The Processor shall not create copies or duplicates of the data without the Controller's knowledge and consent, except for backup copies, insofar as they are necessary for ensuring that data is processed correctly, and where the retention of such data is required by law.

(2) After conclusion of the provision of services, the Processor shall, at the Controller's choice, either delete in a data-protection compliant manner or return to the Controller, all the personal data collected and processed under this DPA, unless any applicable legal provision requires further storage of the personal data.

(3) In any case, the Processor may retain beyond termination of the contract all the information necessary to demonstrate the compliance of the processing activities carried out.

(4) The documentation referred to under point (3) above, shall be stored by the Processor in accordance with the applicable retention periods, statutory or otherwise determined. The Processor may hand the documentation over to the Controller upon termination of the agreement.

(2) El Procesador no cobrará al Controlador ningún pago por servicios de asistencia.

8. Poderes directivos del Controlador

(1) El Procesador no tratará ningún dato personal en virtud de la presente APD salvo siguiendo las instrucciones documentadas del Controlador, a menos que así lo exija la legislación de la Unión o de los Estados miembros.

(2) En caso de que el Controlador exija cualquier cambio en el tratamiento de datos personales establecido por las instrucciones documentadas mencionadas en el apartado 2, el Procesador informará inmediatamente al Controlador si considera que dichos cambios pueden dar lugar a infracciones de las disposiciones sobre protección de datos. El Procesador podrá abstenerse de llevar a cabo cualquier actividad que pueda dar lugar a tal infracción.

9. Responsabilidad

(1) Cada una de las partes del presente DPA se compromete a indemnizar a la otra parte por los daños o gastos derivados de su propia infracción culpable del presente DPA, incluida cualquier infracción culpable cometida por su representante legal, subcontratistas, empleados o cualquier otro agente. Además, cada parte se compromete a indemnizar a la otra parte por cualquier reclamación ejercida por terceros debido a, o en relación con, cualquier infracción culpable de la otra parte.

(2) El art. 82 GDPR no se ve afectado.

10. Supresión y devolución de datos personales

(1) El Procesador no creará copias o duplicados de los datos sin el conocimiento y consentimiento del Controlador, excepto copias de seguridad, en la medida en que sean necesarias para garantizar que los datos se procesan correctamente, y cuando la ley exija la conservación de dichos datos.

(2) Una vez concluida la prestación de servicios, el Procesador, a elección del Controlador, suprimirá de manera conforme con la protección de datos o devolverá al Controlador todos los datos personales recogidos y procesados en virtud del presente APD, a menos que alguna disposición legal aplicable exija que se sigan almacenando los datos personales.

(3) En cualquier caso, el Encargado del tratamiento podrá conservar, una vez finalizado el contrato, toda la información necesaria para demostrar la conformidad de las actividades de tratamiento realizadas.

(4) La documentación mencionada en el punto (3) anterior, será almacenada por el Procesador de acuerdo con los periodos de retención aplicables, legales o determinados de otro modo. El Encargado del



In such case, the Processor is relieved from any obligation to keep such documentation.

Tratamiento podrá entregar la documentación al Controlador a la finalización del Contrato. En tal caso, el Encargado del tratamiento quedará exento de toda obligación de conservar dicha documentación.



Annex 3

BANBIF FUNCTIONAL REQUIREMENTS

To assist in this assessment, we categorize the features based on their current status and the effort required to align them with your company's needs. Here are the categories we use:

Available as is - the feature is already present within the Ethicontrol system and suits your needs by default.

Available with notice - the feature is already present within the Ethicontrol system and suits your needs by default but additional details to be considered.

Available with adjustments - the feature is present, but the way it looks or works is slightly different from what is expected by your Company. This difference is a matter of presentation rather than architecture - is easily adjustable during the initial setup and will not require any additional efforts from both sides.

Low hanging fruit - Currently, the feature cannot be delivered today, but maybe released in a month's time. Some additional development will be needed to meet the requirement.

Not available, but feasible (short term or mid/long term) - the feature is within our development roadmap, but currently not released. The feature will be available within 12-24 months. Additional speedup of a feature release is a negotiable option or a subject for additional fees.

Not available, not feasible - the feature is not available and will not be included in the development roadmap in the upcoming 12 months.

Anexo 3

REQUERIMIENTOS FUNCIONALES DE BANBIF

Para ayudarle en esta evaluación, clasificamos las funciones en función de su estado actual y del esfuerzo necesario para adaptarlas a las necesidades de su empresa. Estas son las categorías que utilizamos:

Disponible - la función ya está presente en el sistema Ethicontrol y se adapta a sus necesidades por defecto.

Disponible con aviso: la función ya está presente en el sistema Ethicontrol y se adapta a sus necesidades por defecto, pero hay que tener en cuenta detalles adicionales.

Disponible con ajustes - la función está presente, pero su aspecto o funcionamiento difiere ligeramente de lo esperado por su empresa. Esta diferencia es más una cuestión de presentación que de arquitectura, se puede ajustar fácilmente durante la configuración inicial y no requiere esfuerzos adicionales por ambas partes.

Fruta que cuelga baja - Actualmente, la función no puede entregarse hoy, pero puede lanzarse dentro de un mes. Será necesario algún desarrollo adicional para cumplir el requisito.

No disponible, pero factible (a corto o medio/largo plazo) - la función está en nuestra hoja de ruta de desarrollo, pero actualmente no está disponible. La función estará disponible en un plazo de 12 a 24 meses. La aceleración adicional del lanzamiento de una función es una opción negociable o sujeta a tarifas adicionales.

No disponible, no factible - la función no está disponible y no se incluirá en la hoja de ruta de desarrollo en los próximos 12 meses.

ITEM	ID. Ref	CRITERIOS DE EVALUACIÓN	EVALUATION CRITERIA	Respuesta de Ethicontrol	Response from Ethicontrol
1. PERFIL USUARIO 1. USER PROFILE	1.1	Registro de denuncias	Register of complaints	Disponible. Registro de solicitudes a través de diversos canales (formulario web, correo electrónico)	Available. Registration of requests through various channels (web form, email)
	1.2	Seguimiento de la denuncia	Follow-up to the complaint	Disponible. Tenemos un Centro de intercambio de información.	Available. We have an Information Clearinghouse.
	1.3	Consulta de casos registrados (Solo de sus casos)	Consultation of registered cases (Only your cases)	Disponible. Nuestra plataforma admite derechos de acceso divididos.	Available. Our platform supports split access rights.
	1.4	Carga de evidencias en diversos formatos	Uploading evidence in various formats	Disponible.	Available.
	1.5	Preguntas Frecuentes	Frequently Asked Questions	Disponible	Available
	1.6	Guía de uso para los colaboradores.	User's guide for partners.	Disponible	Available
	1.7	Visualización de información pública (Como boletines éticos o pop-up)	Visualisation of public information (such as ethical newsletters or pop-up)	Disponible	Available

	1.8	Información de contacto del equipo de relaciones laborales	Contact information for the industrial relations team	Disponibile	Available
	1.9	Envío de notificación automática de aviso al buzón de Relaciones Laborales y copia a colaborador denunciante con el código único.	Automatic notification is sent to the Labour Relations mailbox and a copy is sent to the reporting employee with the unique code.	Disponibile	Available
	1.1	Chat bot sobre denuncias	Whistleblowing chat bot	Disponibile	Available
	1.11	Registro de la denuncia con opción de identificarse y opción de anónimo	Registration of the complaint with the option to identify and the option of anonymity	Disponibile	Available
	1.12	Referencias de las categorías creadas (acoso, anticorrupción)	References of created categories (harassment, anti-corruption)	Disponibile	Available
	1.13	Generación de disclaimers de uso de la plataforma	Generation of disclaimers for use of the platform	Disponibile	Available
		TOTAL 1. PERFIL USUARIO		TOTAL 1. USER PROFILE	
2. PERFIL COMITÉ 2. COMMITTEE PROFILE	2.1	Seguimiento de casos	Case monitoring	Disponibile	Available
	2.2	Búsquedas avanzadas con filtros	Advanced searches with filters	Disponibile	Available
	2.3	Revisión de casos pendientes	Review of pending cases	Disponibile	Available
	2.4	Actualización del estado de casos reportados	Update on the status of reported cases	Disponibile	Available
	2.5	Generar el informe para el comité (Se pueda visualizar la información de la investigación de todos los casos para el comité, incluido los informes cargados que resuelven el caso).	Generate the report for the committee (The investigation information of all cases can be displayed for the committee, including the uploaded reports resolving the case).	Disponibile	Available
	2.6	Notificación de aviso por correo electrónico al área de Relaciones Laborales y al Comité	Notification of notice by e-mail to the Industrial Relations area and to the Committee.	Disponibile	Available

	2.7	Revisión de casos terminados	Review of closed cases	Disponible	Available
	2.8	Búsqueda avanzadas con filtros en casos terminados	Advanced search with filters on completed cases	Disponible	Available
		TOTAL 2. PERFIL COMITÉ		TOTAL 2. COMMITTEE PROFILE	
3. PERFIL ADMINISTRADOR 3. ADMINISTRATOR PROFILE	3.1	Seguimiento de casos	Case monitoring	Disponible	Available
	3.2	Crear y administrar un comité	Creating and administering a committee	Disponible	Available
	3.3	Configuración de parametrías (categorías, tipos de denuncias, estado, localidad)	Configuration of parameters (categories, types of complaints, status, locality)	Disponible	Available
	3.4	Administración del diseño de la herramienta (logo, colores, tipo de letra)	Tool design management (logo, colours, fonts)	Disponible	Available
	3.5	Administración la información pública	Administration public information	Disponible	Available
	3.6	Configuración de la estructura de notificaciones	Notification structure configuration	Disponible	Available
	3.7	Administración de preguntas frecuentes.	FAQ administration.	Disponible	Available
	3.8	Análisis e informes: + informe de actividad de los usuarios, informe analítico personalizado	Analytics and reporting: + user activity report, customised analytics report	Disponible	Available
	3.9	Creación, modificación y eliminación de los estados de las denuncias (ingresado, en análisis, en investigación) y los grupos (pendientes o finalizados)	Creation, modification and deletion of the status of the complaints (filed, under analysis, under investigation) and the groups (pending or finalised).	Disponible	Available
	3.1	Tiempo de ocurrencia de la irregularidad (diaria, semanal, mensual, etc)	Time of incident (daily, weekly, monthly, etc.)	Disponible	Available
	3.11	Constancia de las infracciones	Evidence of wrongdoing	Disponible	Available



	3.12	Ejemplos de mala conducta por categoría de la denuncias	Examples of misconduct by category of complaint	Disponibile	Available
	3.13	Histórico de casos	Case history	Disponibile	Available
	3.14	Creación y suspensión de categorías (activas e inactivas)	Creation and suspension of categories (active and inactive)	Disponibile	Available
	3.15	Asignación y eliminación de miembros de comité por categorías	Assignment and removal of committee members by category	Disponibile	Available
		TOTAL 3. PERFIL ADMINISTRADOR		TOTAL 3. ADMINISTRATOR PROFILE	

**Annex 4****TECHNICAL REQUIREMENTS****Anexo 4****REQUERIMIENTOS TÉCNICOS**

Requerimiento		Aplicación	Respuesta Proveedor	Details	Detalle	Pro	Advance
La solución permite la integración segura con Azure AD , Active Directory , otros IDaaS. Indicar qué protocolos seguros usan.	The solution enables secure integration with Azure AD, Active Directory, other IDaaS. Indicate what secure protocols they use.	Requerido	Cumple	Ethicontrol's platform allows users to log in with a corporate ID (MS Azure AD, Okta, Ping etc.) to the platform. SAML 2.0	La plataforma de Ethicontrol permite a los usuarios iniciar sesión con un ID corporativo (MS Azure AD, Okta, Ping, etc.) en la plataforma. SAML 2.0	Cumple	No cumple
La solución debe contar con el módulo de gestión de usuarios. Este modulo debe contar con controles de seguridad tales como : Gestión de Roles y perfiles, Gestión de cuentas, Gestion de Contraseñas, etc.	The solution must have the user management module. This module must have security controls such as: Role and profile management, account management, password management, etc.	Requerido	Cumple			Cumple	Cumple
La solución soporta el uso de MFA para la autenticación de los usuarios.	The solution supports the use of MFA for user authentication.	Requerido	Cumple			Cumple	Cumple
La solución permite la autenticación/autorización con protocolos seguros. Por ejemplo Open ID,SAML 2.0,Oauth 2.0 ,etc.	The solution allows authentication/authorization with secure protocols. For example Open ID, SAML 2.0, Oauth 2.0, etc.	Requerido	Cumple	SAML 2.0	SAML 2.0	Cumple	No cumple
La solución cumple con los estándares internacionales de Desarrollo Seguro? Como referencia OWASP, OWASP Mobile, ASVS, OWASP API's,entre otros según aplique.	Does the solution comply with international Secure Development standards? As a reference OWASP, OWASP Mobile, ASVS, OWASP API's, among others as applicable.	Requerido	Cumple Parcial			Cumple Parcial	Cumple Parcial
La solución debe pasar por pruebas de código seguro, incluyendo Pruebas de Seguridad de Aplicaciones Estáticas (SAST) y Pruebas de Seguridad de Aplicaciones Dinámicas (DAST).	The solution must pass secure code testing, including Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST).	Requerido	Cumple			Cumple	Cumple
La solución puede integrarse desde un entorno público con las medidas de seguridad que aseguren la	The solution can be integrated from a public environment with security	Requerido	Cumple Parcial	We use WAF, HTTPS/TLS, IP Whitelist, rate limit	Utilizamos WAF, HTTPS/TLS, IP Whitelist, límite de tasa	Cumple Parcial	Cumple Parcial



comunicación. (p.e. uso de WAF, OAuth 2.0, HTTPS/TLS, Mutual Authentication, IP Whitelist, rate limit, etc). Detallar	measures that ensure communication. (e.g. use of WAF, OAuth 2.0, HTTPS/TLS, Mutual Authentication, IP Whitelist, rate limit, etc.). Detail						
La solución puede integrarse bajo un esquema privado con las medidas de seguridad que aseguren la comunicación. Detallar los mecanismos de Seguridad (p.e. VPN, MPLS, Mutual Authentication, Whitelist, entre otros) Detallar.	The solution can be integrated under a private scheme with security measures that ensure communication. Detail the Security mechanisms (e.g. VPN, MPLS, Mutual Authentication, Whitelist, among others) Detail.		Cumple Parcial	We use WAF, HTTPS/TLS, IP Whitelist, rate limit	Utilizamos WAF, HTTPS/TLS, IP Whitelist, límite de tasa	Cumple Parcial	Cumple Parcial
Las APIS deben ser seguras para todas las funcionalidades. p.e Autenticación /Autorización con OAuth 2.0, rate limit, uso de scopes, etc. Detallar.	APIS must be secure for all functionalities. e.g. Authentication/Authorization with OAuth 2.0, rate limit, use of scopes, etc. Detail.	Requerido	Cumple			Cumple	Cumple
Arquitectura de la aplicación y sus componentes de seguridad.	Application architecture and its security components.	Requerido	Cumple	Request access for SAD here https://app.conveyor.com/profile/ethicontrol	Solicite acceso para SAD aquí https://app.conveyor.com/profile/ethicontrol	Cumple	Cumple
De contar con un modelo Multitenant o SingleTenant, se debe asegurar el aislamiento de cómputo y datos entre los clientes. Detallar	If you have a Multitenant or SingleTenant model, the isolation of computing and data between clients must be ensured. Detail	Requerido	Cumple			Cumple	No cumple
La solución debe proteger la información de autenticación de usuario. (p.e hashing/encryptacion, auditoria, etc) Detallar	The solution must protect user authentication information. (e.g. hashing/encryption, auditing, etc.) Detail	Requerido	Cumple			Cumple	Cumple
La data en transito debe encontrarse encriptada haciendo uso de protocolos seguros, p.e HTTPS, TLS 1.2, SFTP, SSH, Detallar	Data in transit must be encrypted using secure protocols, e.g. HTTPS, TLS 1.2, SFTP, SSH, Detail	Requerido	Cumple			Cumple	Cumple
La solución debe deshabilitar el uso de los métodos de cifrado RSA, DES, 3DES, IDEA y RC2 en los certificados asociados con TLS 1.2, garantizando así el uso de algoritmos de cifrado más seguros y modernos.	The solution should disable the use of RSA, DES, 3DES, IDEA, and RC2 encryption methods on certificates associated with TLS 1.2, ensuring the use of more secure and modern encryption algorithms.	Requerido	Cumple			Cumple	Cumple
La data en reposo debe encontrarse encriptada mediante criptografía robusta (p.e AES 256+, RSA 2048, etc.). Detallar	Data at rest must be encrypted using robust cryptography (e.g. AES 256+, RSA 2048, etc.). Detail	Requerido	Cumple			Cumple	Cumple



Se debe contar con procedimientos de eliminacion/devolucion de activos de informacion y se debe contar con procedimientos y herramientas para borrado seguro de la información(p.e basados en NIST 800-88). Detallar	There must be procedures for the elimination/return of information assets and there must be procedures and tools for secure erasure of information (e.g. based on NIST 800-88). Detail	Requerido	Cumple			Cumple	Cumple
Se debe contar con un proceso de Patch Management el cual mantenga la aplicación actualizada y segura. Detallar.	You must have a Patch Management process which keeps the application updated and secure. Detail.	Requerido	Cumple			Cumple	Cumple
Se debe contar con segmentación de red en sus entornos de producción, Certificación y desarrollo,	You must have network segmentation in your production, Certification and development environments,	Requerido	Cumple			Cumple	Cumple
Se debe contar con herramientas de Seguridad de proteccion de perimetro integrados a la solución, (p.e Firewall, IPS, IDS, Proxy, Balanceador,WAF, entre otros).	Perimeter protection security tools must be integrated into the solution (e.g. Firewall, IPS, IDS, Proxy, Balancer, WAF, among others).	Requerido	Cumple			Cumple	Cumple
Evidenciar mediante reportes que se han ejecutados pruebas de ethical hacking (EH) sobre la aplicación, infraestructura, servicios, etc en el ultimo año.El Ethical Hacking deberá ser realizado por un proveedor especializado reconocido por la industria.	Evidence through reports that ethical hacking (EH) tests have been carried out on the application, infrastructure, services, etc. in the last year. Ethical Hacking must be carried out by a specialized provider recognized by the industry.	Requerido	Cumple			Cumple	Cumple
El Centro de Datos, donde está desplegada la plataforma, debe contar con certificación TIER 3 o superior. Detallar(si es propio o si usa un proveedor de nube, % disponibilidad,% indisponibilidad)	The Data Center, where the platform is deployed, must have TIER 3 certification or higher. Detail (if your own or if you use a cloud provider, % availability, % unavailability)	Requerido	Cumple			Cumple	Cumple
La solución cuenta con un módulo de auditoría. Los logs de Auditoría deben tener como mínimo los siguientes campos: ID Usuario, TimeStamp (fecha y hora), inicio/cierre de sesión, éxito/fracaso de inicio de sesión, IP/Host Origen, opción o recurso utilizado, acción ejecutada, código de retorno (Exitoso o Fallido).Detallar	The solution has an audit module. Audit logs must have at least the following fields: User ID, TimeStamp (date and time), login/logout, login success/failure, IP/Host Origin, option or resource used, action executed, code return (Successful or Failed).Detail	Requerido	Cumple Parcial	Audit log is included in Advanced plan. User activity report (User ID, TimeStamp (date and time), login/logout, login success, IP/Host Origin) is a Pro plan feature Login failures and code return are present in tech log which is not accessible from User interface.	El registro de auditoría está incluido en el plan Avanzado. El informe de actividad del usuario (ID de usuario, marca de tiempo (fecha y hora), inicio/cierre de sesión, éxito de inicio de sesión, IP/Origen del host) es una función del plan Pro. Los fallos de inicio de sesión y los códigos devueltos están presentes en el registro técnico,	Cumple	Cumple Parcial



					al que no se puede acceder desde la interfaz de usuario.		
La solución debe asegurar que los datos sensibles (Cliente, Tarjetas de Pago, etc.) deben encontrarse protegidos en los registros de logs si aplica. Detallar	The solution must ensure that sensitive data (Customer, Payment Cards, etc.) must be protected in the log records if applicable. Detail	Requerido		Not applicable	No aplicable	No aplicable	No aplicable
Se deben ejecutar procesos de auditorías externas al menos una vez al año. Detallar	External audit processes must be carried out at least once a year. Detail	Requerido	Cumple Parcial	We passed audits in 2024, 2023 and 2022. After recertification according to 2024 audit results we don't plan any audits in 2025.	Hemos superado las auditorías de 2024, 2023 y 2022. Tras la recertificación de acuerdo con los resultados de la auditoría de 2024, no tenemos prevista ninguna auditoría en 2025.	Cumple Parcial	Cumple Parcial
La solución hace uso de Certificados digitales para su protección (emitida por una CA autorizada) . Detallar	The solution makes use of digital Certificates for protection (issued by an authorized CA). Detail	Requerido	Cumple			Cumple	Cumple
La solución debe hacer uso de un modulo de almacenamiento seguro de secretos y llaves (p.e KeyVault,Secret Manager,KMS)	The solution must make use of a secure secret and key storage module (e.g. KeyVault, Secret Manager, KMS)	Requerido	Cumple Parcial	We use it internally. Please note that it doesn't mean integration with client provided vaults.	Lo utilizamos internamente. Tenga en cuenta que no significa la integración con bóvedas proporcionadas por el cliente.	Cumple Parcial	Cumple Parcial



Annex 5

ETHICONTROL PORTAL TERMS AND CONDITIONS

Anexo 5

TERMINOS Y CONDICIONES DEL PORTAL DE ETHICONTROL

Client Related Policies for Ethicontrol Platform

Fair usage policy

Why do we have a Fair Usage Policy?

Ethicontrol SaaS product is a multi-tenant service. This means that SaaS services are used concurrently by a number of subscribers. If a single customer places very high demands on the service then it is possible that this will affect the experience for other users. The vast majority of our customers use their service considerably and their usage levels during peak hours don't disproportionately affect the shared network and service capacity. Even though only a very small number of our customers may use the service inappropriately, their activity has the potential to affect the service for others. Our Fair Use Policy manages the inappropriate use and makes sure the service can be used fairly by everyone.

Support

Support is typically provided free of charge as part of the Services we offer. To ensure that all customers have equal access to support, we may restrict or suspend access to support for any customer that consuming more support time, or logging more support issues than a typical customer with similar users and a similar subscription.

Storage

Within your SaaS environment you can store documents to record correspondence as well as data and transactions in the database. To make sure that there is enough storage for everyone, we may limit the amount of data you can save. By default it is 10 GB. The amount of storage may depend on your type of contract and number of users. We've made sure that almost all customers have plenty of disk space when the solutions are used normally. You can always request the actual size of your data storage from our service desk. You can also free up more storage by removing data yourselves, or asking us to help you with our clean-up-service. If we detect that your organisation structurally saves more data than we consider to be fair and normal, we'll contact you to discuss the situation. It's possible to expand your storage and, if appropriate we will only charge a maximum of the published and publicly available Microsoft Azure / AWS / Linode storage charge for the relevant storage solution plus 20%. At that point we'll contact you to discuss alternative storage options.

Network Traffic and Bandwidth

To prevent a negative effect of excessive network traffic on your user experience or that of others, we monitor the traffic. We compare your use to the average use of all our SaaS customers with the same contract. With normal use you don't have to worry about the network bandwidth available to you. If we detect a situation that could lead to a decrease in service, we will contact you to discuss the situation. In some situations, we can intervene by limiting the available bandwidth.

Amount of sent and received emails

To prevent spam, we use worldwide blacklists, and spam blockers among other things. To guarantee smooth email traffic from our SaaS products for you and our other customers, we monitor the mail servers. Spam and blacklisting could happen when excessive amounts of emails are sent from the SaaS environments, for example. We maintain very broad margins based on the average use of our SaaS customers with similar contracts. With normal use, you won't notice a thing. When we detect abnormal values that could negatively impact the service, we may limit the number of emails you can send, or take other action as appropriate. Before we do this, or in urgent situations immediately after doing so, we'll always contact you to discuss possible solutions.

Compute and Load

To prevent a negative effect of excessive use of compute resources, on your user experience or that of others, we monitor the compute resources. We compare your use to the average use of all our SaaS customers with the same contract. With normal use you don't have to worry about the compute services available to you. Where increased usage is caused by the normal growth of users and customers, we will scale the resources available. If we detect a situation that reflects abnormal use or that could lead to a decrease in service, we will contact you to discuss the situation. In some situations, we can intervene by limiting the available compute resource.

Urgent and Extreme Cases

In an urgent or extreme case, for example where services are likely to be significantly impacted, or where we believe your system or ours is under attack (a DDOS - denial of service attack for instance) or where we believe your system or ours has been compromised (for example a hacker or potential a security breach) we may stop the services, or temporarily block your access to them. Before we do this, or in urgent situations immediately after doing so, we'll always contact you to discuss possible solutions. In some cases, even without an attack or breach, if your use of the services continues to



impact other users, is expected to do so, or is generating costs to us that are not normal when compared to other customers on the same contract and make our service to you unprofitable to maintain, we may isolate your services from the multi-tenanted environments and pass the costs onto you. Before we do this, or in urgent situations immediately after doing so, we'll always contact you to discuss possible solutions.

Terms of use

Legal use only

The Customer shall not access, store, distribute or transmit any Viruses, or any material during the course of its use of the Services that:

- (a) is unlawful, harmful, threatening, defamatory, obscene, infringing, harassing or racially or ethnically offensive;
- (b) facilitates illegal activity;
- (c) in a manner that is otherwise illegal or causes damage or injury to any person or property; and Ethicontrol reserves the right, without liability or prejudice to its other rights to the Customer, to disable the Customer's access to any material that breaches the provisions of this clause.

Law enforcement

Ethicontrol shall fully co-operate with any law enforcement authorities or court order requesting or directing Ethicontrol to disclose the identity or locate anyone posting any material in breach of clause LEGAL USE clause.

Respect for intellectual property

The Customer shall not:

- (a) except as may be allowed by any applicable law which is incapable of exclusion by agreement between the parties:
 - (i) and except to the extent expressly permitted under this Agreement, attempt to copy, modify, duplicate, create derivative works from, frame, mirror, republish, download, display, transmit, or distribute all or any portion of the Services or Product Description (as applicable) in any form or media or by any means; or
 - (ii) attempt to reverse compile, disassemble, reverse engineer or otherwise reduce to human-perceivable form all or any part of the Services;
- or
- (b) access all or any part of the Services and Product Description in order to build a product or service which competes with the Services and/or the Product Description; or
- (c) use the Services and/or Product Description to provide services to third parties; or
- (d) license, sell, rent, lease, transfer, assign, distribute, display, disclose, or otherwise commercially exploit, or otherwise make the Services and/or Product Description available to any third party, or
- (e) attempt to obtain, or assist third parties in obtaining, access to the Services and/or Product Description.

Unauthorised use prevention

The Customer shall use all reasonable endeavours to prevent any unauthorised access to, or use of, the Services and/or the Product Description and, in the event of any such unauthorised access or use, promptly notify Ethicontrol. The rights provided under this Service Agreement are granted to the Customer only, and shall not be considered granted to any subsidiary or holding company of the Customer. Only one subscription to the Services may be activated by any company, person or other entity. Duplicate subscriptions for any company, person or entity shall be considered a material breach of the Service Agreement. The Customer undertakes to ensure that all Users comply with this Agreement and acknowledge that Customer shall remain responsible and liable for the acts or omissions of all Users to the same extent as if Customer had carried out such acts or omissions itself. Responsibility for the security of any usernames and passwords issued (including those of any Users) rests with Customer. If Customer has reason to believe that their credentials or User account details have been obtained by another without consent, the Customer should contact Ethicontrol immediately to suspend the account.

Data Breach Notification Policy

This policy defines what qualifies as a breach of user data, what actions will be taken in the event of user data exposure or compromise, and the timeline for action. This policy applies to user data stored on Ethicontrol.com. It does not apply to self-hosted / on-premises instances or instances hosted with other providers than Ethicontrol.com

Data Classification - What information is covered by this policy

This policy covers "private user data" stored by Ethicontrol.com, and includes:



- Client's database
- Client's files
- Encrypted Passwords
- Private Email Addresses

Note: Ethicontrol.com does not store any "personally identifiable information" (PII) such as (i) Private Addresses, (ii) Credit Card Numbers, (iii) Bank Account Information, (iv) ID numbers (e.g. passport, driver's license, social security, national identification, etc.). Ethicontrol.com and subdomains also does not store any "personal health information" (PHI). Therefore, laws and regulations relating to PII and PHI do not apply.

What qualifies as a breach?

A breach of user data is the unintended or accidental exposure of private user data. This can be caused by accidents, misconfigurations, or malicious actions performed by an external attacker or team member. An event is considered a data breach when there is evidence that private user data has been exposed to the public or to an untrusted third party. Trusted third parties may have authorized access to user data under a signed Non-Disclosure Agreement (NDA). Such trusted third parties include but are not limited to:

- Cloud service providers
- Database consultants
- Security auditors
- Financial auditors

Some examples of a user data breach would include:

- Compromise of a database server that contains private user data with evidence that an attacker may have had access to or copied the data off-site.
- Compromise of an application server account that has access to private user data and evidence that the attacker has downloaded or accessed private data.
- Theft of a device known to contain private user data.
- Web application attack used to download a list of all user emails and encrypted passwords.

What is not considered a breach?

Examples of security incidents that would not be considered a breach of private user data:

- Compromise of an application server that does not contain or have access to private user data.
- Compromise of a team member application account that does not have access to private user data.
- Malware infection on a server or team member computer system that does not contain private user data.
- Compromise of non-sensitive user data such as login IP addresses, login history, project permissions.
- Unintentional disclosure of project names, group names, issue titles, or project or user metadata unless this data can cause damage to the user or their business.
- Discovery of a vulnerability that could have been used to compromise private data, but for which there is no evidence of exploitation.
- Theft of a team member's mobile device that does not contain private user data.
- Theft of a team member's private keys, tokens, or other credentials provided there is no evidence they were used to access private user data.

You can check out these [common non-vulnerabilities](#) that will not be considered as a breach.

Who will be notified in the event of a data breach

If Ethicontrol has detected evidence of a breach of Ethicontrol.com or Ethicontrol Hosted private user data, all affected users will be notified via the configured email address for their accounts. Emails will contain information on what data was exposed or compromised, when, and for how long (to the extent this information is available). For a breach that exposes private data for a large number of users, the public will also be informed via the



configured email addresses for their accounts, and additional means of communication will be considered (e.g. press release, the blog, etc.) on a case by case basis.

Notification timing

Ethicontrol will endeavor to notify users within 24 hours of breach discovery. This may be delayed when necessary to comply with requests by law enforcement.

Report security issue

We know how much work goes in to pen testing!

To avoid frustration, you can check out these [common non-vulnerabilities](#) that don't qualify for rewards.

Got a valid issue? Awesome! Please include:

- A summary of the problem
- A severity rating of 1 — 5 (1 being least severe, 5 being most ie. you can easily hijack, impersonate or access any other account or data)
- A PoC or breakdown of how to replicate the issue
- The operating system name and version as well as the web browsers name and version that you used to replicate the issue

Send to security (at) ethicontrol.com

Rewards

We're eternally grateful for all of those who put in hard work to identify weaknesses within Ethicontrol.

For reports that are not [common non-vulnerabilities](#), we like to reward those who responsibly disclose vulnerabilities with an acknowledgement, swag or bounty money.

Whisky and biscuits can be also provided during one to one meeting.

Acknowledgements

We appreciate the work that goes into finding and disclosing security flaws in Ethicontrol and would like to thank the following individuals and organisations:

- [Alexey Yankovsky, ISACA](#)
- [Yyriy Lysak](#)

System requirements for users

Web intake users

Computer and processor 1 gigahertz (GHz) or faster

Memory 2 GB RAM

Hard disk 3 GB available disk space

Display - any screen resolution

Operating system - for the best experience, use the latest version of any operating system.

Browser - any

Incident and case management users

Computer and processor 1 gigahertz (GHz) or faster x86-bit or x64-bit processor with SSE2 instruction set

Memory 4 GB RAM



Hard disk 3 GB available disk space

Display - for the better experience use displays with resolution starting from 768 px width (medium sized tablets and bigger)

Operating system - any

Browser

Chrome 21+ (recommended)

Firefox 28+

Edge 12+

Safari 7+

Opera 17+

Android 6.0+

Internet Explorer is NOT supported.

Default SLA policy

Version: 30/05/2023

Service Level Terms

SaaS

The Services shall be available 99%, measured monthly, excluding holidays and weekends and scheduled maintenance. If the Customer requests maintenance during these hours, any uptime or downtime calculation will exclude periods affected by such maintenance. Further, any downtime resulting from outages of third-party connections or utilities or other reasons beyond the Company's control will also be excluded from any such calculation. Customer's sole and exclusive remedy, and Company's entire liability, in connection with Service availability, shall be that for each period of downtime lasting longer than five hours, Company will credit Customer 5% of Service fees for each period of 30 or more consecutive minutes of downtime; provided that no more than one such credit will accrue per day.

Downtime shall begin to accrue as soon as Customer (with notice to Company) recognizes that downtime is taking place, and continues until the availability of the Services is restored. To receive downtime credit, the Customer must notify the Company in writing within 24 hours from the time of downtime, and failure to provide such notice will forfeit the right to receive downtime credit.

Such credits may not be redeemed for cash and shall not be cumulative beyond a total of credits for one (1) week of Service Fees in any one (1) calendar month in any event. The company will only apply a credit to the month in which the incident occurred. Company's blocking of data communications or other Services by its policies shall not be deemed to be a failure of the Company to provide adequate service levels under this Agreement.

Support

Our Support portal help.ethicontrol.com is available 24/7 and is multilingual. There is a Knowledge base with user manual articles. Users can create support tickets using chatbots, email, or support portals.

Besides, Help widgets are visible in the client user interface. The widgets are connected to the **Support portal and our support team**.

By default, we provide technical support during working hours from Monday to Friday. The standard support level is included in all tariff plans.

Our normal support level is up to 24h for the first response and up to 40h to resolve the issue. The exact timing should depend on the severity of the issue.

Suggested severity levels:

Emergency — impacts human wellbeing; Very High level of associated risk; Anything related to breach/loss of data.

Critical — clients cannot use/access the Ethicontrol platform or services; the phone line (or any other intake channel) is busy or not working. Major Service Outage — contributing to the loss of day-to-day business operations. Major interruption in the functionality, resulting in a capacity decrease of more than 70% (of the entire system).



Moderate — some Ethicontrol services are unavailable, but reporters/whistleblowers can still communicate with a client and the client's users can access case management, respond to reporters, and document cases; some cases are inaccessible; workflows/statuses issues; access rights issues; notification/reminder/emails issues.

- Service outage resulting in loss of business operation
- Service incapacity requiring immediate action results in a capacity decrease of more than 30%.
- The defect does not fail but causes failures in some components
- Operation of an existing network, system, or services is severely degraded or significant aspects of hotline services are negatively affected by inadequate performance.

Low — everything else which does not require immediate or expedite resolution and can “wait” at least a week.

- No outage or loss of functionality of the component(s) or services
- Minimal operational impact.
- Operational performance of the network, system, or services is impaired while most of the hotline services remain functional.

The severity level is used to rank the service requests.

The service level commitment “Maximum response time” and “Maximum resolution time” are measured from the time a client contacts the Ethicontrol support or account manager (for critical issues).

Default Response objectives

Incident Severity Definition (Helpdesk)	Response	Resolution
Emergency	4 business hours	2-8 business Hrs.
Critical	8 business hours	24 hours
Medium	16 business hours	5 business days
Low	24 business hours	10 business days

Escalation Management (Critical Incident)

- Alert appropriate client personnel that an emergency (critical incident) has occurred, which may require their urgent attention.
- Escalation process for clients –
 - 1st line of defence — Support portal, email support@ethicontrol.com.
 - 2nd line of defence — Support engineer email supportteam@ethicontrol.com, which should deal with 90% of cases. CC — account manager.
 - 3rd line of defence — Ethicontrol engineers. CC — CTO, account manager
 - Ultimate escalation — CEO, CC — CTO, account manager
- Default Point of Contact — support@ethicontrol.com

Disclaimer for on-premise Solution



The Vendor accepts no responsibility for issues that are NOT the responsibility of the vendor and should be cared for by the Customer:

- Deficiencies/issues caused by the Customer infrastructure or Customer's servers where Ethicontrol applications are hosted.
- Behaviour of Customer equipment, facilities, or applications. Customer network maintenance or any other issues within the Customer infrastructure
- Circuits provided by telephone companies or other common carriers
- Tampering of Ethicontrol applications either by customer, Customer's agents, or by unauthorized third parties, including but not limited to property owners and their agents.
- Any external Internet supplier, Service Provider, or an Internet exchange point.
- The customer's network is being compromised by unauthorized access.
- The deliverability of emails to recipients.
- The redundancy and continuity of the services.
- Acts of God, acts of nature, acts of civil or military authority, governmental actions, fires, civil disturbances, terrorism, and interruptions of power or transportation problems.
- Any delay or performance failure caused by Customer's failure to perform any obligations under this Agreement.

The compliance with local data privacy and Information/IT Security rules, laws, and regulations applicable to federal government entities is the Customer's responsibility. The vendor accepts no responsibility for breaches of reporters' anonymity or confidentiality for reasons that are under the control of the Customer's network and server infrastructure.



Annex 6

COMPANY AND SERVICE QUESTIONNAIRE

Anexo 6

CUESTIONARIO EMPRESA Y SERVICIO

1. CUESTIONARIO EMPRESA / 1. COMPANY QUESTIONNAIRE								
<<Esta información debe ser generada por area solicitante de la nueva plataforma>> / <<This information must be generated by the applicant area of the new platform>>>.								
1. INFORMACIÓN SOLICITANTE / 1. APPLICANT INFORMATION								
Id	Item	Item	Yes/No	Aplica Si /No	Details	Detalle	Comment	Comentario
1.1	Initiative Code	Código de la Iniciativa	YES	SI	https://ethicontrol.com/en/integrity-policy	https://ethicontrol.com/en/integrity-policy	<<If you do not have a code, explain why>>>	<<Si no se posee código, explicar motivo>>>
1.2	VP	VP	YES	SI	Oleg Lagodiyenko	Oleg Lagodiyenko		
1.3	Product Manager	Product Manager	YES	SI	Oleg Lagodiyenko	Oleg Lagodiyenko		
1.4	Product Line	Linea de Producto	NO	NO		Ethicontrol		
1.5	Product	Producto	YES	SI	Eticontrol	Ethicontrol		
1.6	Requirement met by regulations?	¿Requerimiento alcanzado por regulaciones?	YES	SI	We met the requirements of different regulation including Peru's Whistleblower Protection Law (Law No. 30364 (2018). Ethicontrol provides a strong foundation for compliance with Law No. 29733 (Personal Data Protection Law), especially in areas of data security, confidentiality, and subject rights. We obtained critical certification like ISO 27001 and ISO 27701. Ethicontrol hosts its servers within data centers located elsewhere, depending on client needs. Ethicontrol's Data Center in the U.S. is compliant with SSAE 16 Type II and ISO 27001 standard, and is located in San Jose, California. In addition, Ethicontrol has data centers in the UAE and other locations which require national data isolation.	Cumplimos con los requisitos de diferentes normativas, incluida la Ley de Protección de Denunciantes de Perú (Ley n.º 30364 (2018). Ethicontrol proporciona una base sólida para el cumplimiento de la Ley N° 29733 (Ley de Protección de Datos Personales), especialmente en áreas de seguridad de datos, confidencialidad y derechos de los sujetos. Obtuvimos certificaciones críticas como ISO 27001 e ISO 27701. Ethicontrol aloja sus servidores en centros de datos ubicados en otros lugares, dependiendo de las necesidades del cliente. El centro de datos de Ethicontrol en Estados Unidos	<<If YES, detail normal/regulatory>>.	<<Si la respuesta es SI, detallar normal/regulador>>



						cumple con las normas SSAE 16 Tipo II e ISO 27001, y se encuentra en San José, California. Además, Ethicontrol dispone de centros de datos en los Emiratos Árabes Unidos y otros lugares que requieren aislamiento de datos a nivel nacional.		
1.7	Environments required for the product	Ambientes que se requieren para el producto	YES	SI	Since this is a SaaS solution, a browser is sufficient for online access	Al tratarse de una solución SaaS, es suficiente un navegador para acceder en Internet.	<<Specify relevant details. If more than one instance is required in any of the environments, this must be specified. If the Other option was selected, justify.>>	<<Especificar detalle relevantes. Si se requiere mas de una instancia en alguno de los ambientes, se debe especificar. Si se seleccionó la opción Otros, justificar.>>
1.8	Will it support critical business processes?	¿Soportará procesos críticos del Negocio?	YES	SI	1. Compliance and Legal Risk Management 2. Whistleblowing and Reporting 3. Incident Management 4. Data Security and Privacy 5. Governance and Transparency 6. Regulatory Reporting	1. Cumplimiento y gestión de riesgos jurídicos 2. Denuncias e informes 3. Gestión de incidentes 4. Seguridad y privacidad de los datos 5. Gobernanza y transparencia 6. Información reglamentaria	<<If YES, indicate these processes>>.	<<Si la respuesta es SI, indicar dichos procesos>>
<<Esta información debe ser generada por el proveedor de la nueva plataforma y su equipo técnico>> / <<This information must be generated by the new platform provider and its technical team>>.								
2. INFORMACIÓN EMPRESA								
Id		Item	Yes/No	Aplica Si/No	Details	Detalle	Comment	Comentario
2.10	Supplier Name (Implementer and/or Seller)	Nombre del Proveedor(Implementador y/o Vendedor)	YES	SI	Ethicontrol	Ethicontrol		<<Algún comentario relevante>>
2.11	Manufacturer Name	Nombre del Fabricante	YES	SI	Ethicontrol	Ethicontrol		<<Algún comentario relevante>>
2.12	Nationality of the Supplier (Implementer and/or Seller)	Nacionalidad del Proveedor(Implementador y/o Vendedor)	YES	SI	Estonian	Estonian		<<Algún comentario relevante>>
2.13	Manufacturer	Nacionalidad del	YES	SI	Estonian	Estonian		<<Algún comentario



	Nationality	Fabricante						relevante>>
2.14	Implemented countries	Países implementados	YES	SI	US, Ukraine, UAE, KSA, Kenya, Poland, Greece, Rumania, Tanzania and more	EE.UU., Ucrania, EAU, KSA, Kenia, Polonia, Grecia, Rumanía, Tanzania, etc.		<<Algún comentario relevante>>
2.15	Banking Clients in the Region (LATAM)	Clientes de Banca en la Region(LATAM)	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.16	Years of the Supplier (Implementer and/or Seller) in the Market	Años del Proveedor(Implementador y/o Vendedor) en el Mercado	YES	SI	11 years	11 años		<<Algún comentario relevante>>
2.17	Years of the Company in the Market	Años del Empresa en el Mercado	YES	SI	7 years	7 años		<<Algún comentario relevante>>
2.18	Years of the Provider (Implementer and/or Seller) in the Banking Sector in Peru	Años del Proveedor(Implementador y/o Vendedor) en el Sector Bancario en Perú	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.19	Number of Employees of the supplier based in LATAM	Cantidad de Empleados del proveedor con base en LATAM	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.20	Percentage of income allocated to Product Innovation and Evolution	Porcentaje de ingresos destinados a la Innovación e Evolución del Producto	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.21	Indicate the references of your main clients.	Indicar las referencias de sus principales clientes.	YES	SI	Client References Attached	Se adjuntan referencias de clientes		<<Algún comentario relevante>>
2.22	Solution installations performed by the provider	Instalaciones de la Solución realizadas por el proveedor	YES	SI	Approximate roadmap attached	Se adjunta hoja de ruta aproximada		<<Algún comentario relevante>>



2.23	Manufacturer Financial Health (Billing, Growth, Country Risk, etc.)	Salud Financiera del Fabricante (Facturación, Crecimiento, Riesgo País, etc)	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.24	Focus on Manufacturer Financial Industry	Foco en Industria Financiera del Fabricante	NO	NO		<<Precisar>>		<<Algún comentario relevante>>
2.25	Client References (Client Visits, Success Stories)	Referencias de Clientes (Visitas a Clientes, Casos de Éxito)	YES	SI	Client References Attached	Se adjuntan referencias de clientes		<<Algún comentario relevante>>
2.26	Percentage of income allocated to Product Innovation and Evolution	Porcentaje de ingresos destinados a la Innovación e Evolución del Producto	NO	NO		<<Precisar>>		<<Algún comentario relevante>>

2. CUESTIONARIO PLATAFORMA Y PROYECTO							
<<Esta información debe ser completada por el proveedor de la nueva plataforma y su equipo técnico>>							
1. INFORMACIÓN PLATAFORMA							
Id	Item	Item	YES/NO	Aplica Si /No	Details	Detalle	Comentario
1.1	Commercial name of the platform/service	Nombre comercial de la plataforma/servicio	YES	SI	Ethicontrol	Ethicontrol	<<Brindar detalle adicionales de ser necesario.>>
1.2	Current version of the platform/service	Versión actual de la plataforma/servicio	YES	SI	1.24	1.24	<<Brindar detalle adicionales de ser necesario.>>
1.3	Version to install	Versión a instalar	NO	SI	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalle adicionales de ser necesario.>>
1.4	Positioning in MQ Gartner	Posicionamiento en MQ Gartner	NO	NO		<<Precisar>>	<<Brindar detalle adicionales de ser necesario.>>

1.5	Positioning at Forrester	Posicionamiento en Forrester	NO	NO		<<Precisar>>	<<Brindar detalle adicionales de ser necesario.>>
1.6	Do you have clients in Peru who have the same product installed?	¿Cuenta con clientes en el Perú que tengan instalado el mismo producto?	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.7	Is a Logical Architecture Diagram available?	¿Se dispone de Diagrama de Arquitectura Lógica?	YES	SI	https://app.conveyor.com/profile/ethicontrol	https://app.conveyor.com/profile/ethicontrol	<<Brindar detalle adicionales de ser necesario.>>
1.8	Is a Physical Architecture Diagram available?	¿Se dispone de Diagrama de Arquitectura Física?	YES	SI	https://app.conveyor.com/profile/ethicontrol	https://app.conveyor.com/profile/ethicontrol	<<Brindar detalle adicionales de ser necesario.>>
1.9	Is there an Information Architecture Diagram available?	¿Se dispone de Diagrama de Arquitectura de Información?	YES	SI	https://app.conveyor.com/profile/ethicontrol	https://app.conveyor.com/profile/ethicontrol	<<Brindar detalle adicionales de ser necesario.>>
1.10	Is there an Enterprise Architecture Diagram available?	¿Se dispone de Diagrama de Arquitectura Empresarial?	YES	SI	https://app.conveyor.com/profile/ethicontrol	https://app.conveyor.com/profile/ethicontrol	<<Brindar detalle adicionales de ser necesario.>>
1.11	Years of experience with local/regional banking clients.	Años de experiencia con clientes de Banca local/regional.	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.12	Experience in agile projects	Experiencia en proyectos ágiles	YES	SI	Ethicontrol demonstrates substantial experience with agile project management principles through its implementation of adaptive and iterative methodologies in product development and service delivery. The company emphasizes flexibility and client-centric solutions, which align with agile frameworks. For instance, it allows customizable workflows, provides tailored onboarding processes, and offers robust support structures such as dedicated success managers and customizable SLA options. These practices are indicative of an agile mindset, prioritizing collaboration, adaptability, and continuous improvement. Additionally, Ethicontrol's success in delivering over 100 compliance-related projects globally and its ability to support various industries suggest that it effectively incorporates iterative feedback loops and stakeholder engagement, which are central to agile methodologies.	Ethicontrol demuestra una gran experiencia con los principios de gestión ágil de proyectos mediante la aplicación de metodologías adaptativas e iterativas en el desarrollo de productos y la prestación de servicios. La empresa hace hincapié en la flexibilidad y en las soluciones centradas en el cliente, que se ajustan a los marcos ágiles. Por ejemplo, permite personalizar los flujos de trabajo, proporciona procesos de incorporación a medida y ofrece sólidas estructuras de apoyo, como gestores de éxito dedicados y opciones de SLA personalizables. Estas prácticas son indicativas de una mentalidad ágil, que prioriza la colaboración, la adaptabilidad y la mejora continua. Además, el éxito de Ethicontrol en la entrega de más de 100 proyectos relacionados con el cumplimiento a nivel mundial y su capacidad para apoyar a diversas industrias sugieren que incorpora eficazmente bucles de retroalimentación iterativos y la participación de las partes interesadas, que son fundamentales para las metodologías ágiles.	<<Brindar detalle adicionales de ser necesario.>>



1.13	It has documentation of the Product Improvement Plan (includes technological roadmap).	Cuenta con documentacion del Plan de Mejoras del producto (incluye roadmap tecnologico).	YES	SI	Approximate roadmap attached	Se adjunta hoja de ruta aproximada	<<Brindar detalle adicionales de ser necesario.>>
1.14	It has a Product Compatibility Matrix (SO, BD).	Cuenta con Matriz de Compatibilidad del Producto (SO, BD).	YES	SI	SO	<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.15	Years in the solution market	Años en el mercado de la solución	YES	SI	11 years	<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.16	Installations in LATAM of the product in the last 3 years	Instalaciones en LATAM del producto en los últimos 3 años	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.17	Improvements executed in the last 3 years in the product (RoadMap executed)	Mejoras ejecutadas en los últimos 3 años en producto (RoadMap ejecutado)	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.18	Functional RoadMap of the Platform (3 years)	RoadMap Funcional de la Plataforma (a 3 años)	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
1.19	Years since publication of last version of the platform	Años desde publicación de última la versión de la plataforma	YES	SI	0	0	<<Brindar detalle adicionales de ser necesario.>>
1.20	RoadMap of Technological Evolution of the platform	RoadMap de Evolución Tecnológica de la plataforma	NO	NO		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
2. INFORMACIÓN PROYECTO							
2.1 Implementación del Proyecto							
Id	Item	Item	YES/NO	Aplica Si /No		Detalle	Comentario
2.1.1	Proposed Deadline for the Project	Plazo propuesto para el Proyecto	YES	SI	Timeline attached	Se adjunta cronograma	<<Brindar detalle adicionales de ser necesario.>>



2.1.2	Proposed Implementation Strategy for the Project	Estrategia de Implementación propuesto para el Proyecto	YES	SI	Approximate roadmap attached	Se adjunta hoja de ruta aproximada	<<Brindar detalle adicionales de ser necesario.>>
2.1.3	Supplier Methodology for the Implementation Project	Metodología del Proveedor para el Proyecto de Implantación	YES	SI	Approximate roadmap attached	Se adjunta hoja de ruta aproximada	<<Brindar detalle adicionales de ser necesario.>>
2.1.4	Ability to start delivery with Country Base Model	Capacidad para iniciar entrega con Modelo Base Pais	YES	SI		<<Precisar>>	<<Brindar detalle adicionales de ser necesario.>>
2.1.5	It has a Partner for the implementation and Certification stage	Cuenta con Partner para la impletación y etapa de Certificación	NO	NO		<<Precisar>>	<<Brindar detalle adicionales de ser necesario.>>
2.1.6	Availability to Start the Project (from the signing of the contract)	Disponibilidad para Inicio del Proyecto (desde la firma de contrato)	YES	SI		<<Precisar>>	<<Brindar detalle adicionales de ser necesario.>>
2.1.7	Penalties accepted for the execution of the Project	Penalidades aceptada para la ejecución del Proyecto	YES	SI		<<Indicar>>	<<Brindar detalle adicionales de ser necesario.>>
2.1.8	Payment Milestones	Hitos de Pago	YES	SI	Upfront payment for one year. Any of fee to be paid 14 days after agreement signed.	Pago por anticipado por un año. El pago restante se efectuará 14 días después de la firma del contrato.	<<Detallar los hitos de pago>>
2.2 Pruebas de Concepto							
Id	Item	Item	YES/NO	Aplica Si /No		Detalle	Comentario
2.2.1	<<Compliance with Use Case 1 (Insert use case description)>>	<<Cumplimiento caso de Uso 1 (Colocar descripción caso de uso)>>	YES	SI	https://ethicontrol.com/en/case-1	https://ethicontrol.com/en/case-1	<<Brindar detalle adicionales de ser necesario.>>
2.2.2	<<Compliance Use Case 2 (Insert use case description)>>	<<Cumplimiento caso de Uso 2 (Colocar descripción caso de uso)>>	YES	SI	https://ethicontrol.com/en/case-2	https://ethicontrol.com/en/case-2	<<Brindar detalle adicionales de ser necesario.>>
2.2.3	<<Compliance with Use Case 3 (Insert use case description)>>	<<Cumplimiento caso de Uso 3 (Colocar descripción caso de uso)>>	YES	SI	https://ethicontrol.com/en/case-3	https://ethicontrol.com/en/case-3	<<Brindar detalle adicionales de ser necesario.>>



3. LICENCIAMIENTO							
Id	Item	Item	YES/NO	Aplica Si /No		Detalle	Comentario
3.1	What type of licensing is offered for on-premises installations?	¿Qué tipo de licenciamiento se ofrece para instalaciones on-premises?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.2	What type of licensing is offered for on-demand installations?	¿Qué tipo de licenciamiento se ofrece para instalaciones on-demand?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.3	Are licenses required for each client? (supports fixed and floating licenses)	¿Se requiere licencias por cada cliente? (soporta licencias fijas y flotantes)	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.4	For mobile clients, what is the licensing scheme?	Para clientes mobile, ¿Cuál es el esquema de licenciamiento?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.5	What is the licensing model for central instances?	¿Cuál es el modelo de licenciamiento para instancias centrales?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.6	Are licenses required for installations in non-productive environments?	¿Se requieren licencias para instalaciones en ambientes no productivos?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.7	Is third-party licensing required?	¿Se requiere licenciamiento de terceros de manera obligatoria?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.8	How often are licenses renewed?	¿Con que frecuencia se renuevan las licencias?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.9	Can the licenses be transferred/extended to companies in the corporate group?	¿Las licencias pueden ser transferidas/extendidas a empresas del grupo corporativo?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>



3.10	Is there a corporate licensing model?	¿Se cuenta con un modelo de licenciamiento corporativo?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.11	In addition to licensing, what other associated costs are identified?	Adicional al licenciamiento, ¿Qué otros costos asociados se identifican?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.12	Does the licensing include the delivery of source code?	¿El licenciamiento incluye la entrega de código fuente?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.13	If you want to extend the functionality, is there an additional licensing for developer mode?	Si se desea extender la funcionalidad, ¿existe un licenciamiento adicional para modo developer?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.14	If applicable, do the frameworks, tools and/or SDKs necessary to extend functionality require additional licensing?	Si corresponde, los framework, herramientas y/o SDK's necesarios para extensión de funcionalidad, ¿requieren licenciamiento adicional?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.15	What is the license upgrade strategy?	¿Cuál es la estrategia de upgrade de la licencia?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.16	Are there additional costs for technical support and updates?	¿Se aplican costos adicionales por soporte técnico y actualizaciones?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.17	Does the solution provide licensing options for development and testing environments?	¿La solución proporciona opciones de licenciamiento para entornos de desarrollo y pruebas?	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>
3.18	Are there additional costs associated with customizing or specifically configuring the solution to meet	¿Hay costos adicionales relacionados con la personalización o configuración específica de la	NO	NO	not applicable for SaaS	no aplicable para SaaS	<<Brindar detalles adicionales de ser necesario.>>

	particular business requirements?	solución para cumplir con requisitos empresariales particulares?					
4. SOPORTE Y NIVELES DE SERVICIO							
Id	Item	Item	YES/NO	Aplica Si /No		Detalle	Comentario
4.1	Does the licensing include support or must it be contracted separately?	¿El licenciamiento incluye soporte o se debe contratar por separado?	YES	SI		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>
4.2	What guarantee is offered for the proper functioning of the application (if support and maintenance is not contracted)?	¿Qué garantía se ofrece para el funcionamiento adecuado de la aplicación (en el caso no se contrate soporte y mantenimiento)?	YES	SI	SLA	SLA	<<Brindar detalles adicionales de ser necesario.>>
4.3	What escalation levels are defined for incidents reported in the application and/or peripherals?	¿Qué niveles de escalamiento se definen para incidentes reportados en la aplicación y/o periféricos?	YES	SI	Alert appropriate client personnel that an emergency (critical incident) has occurred, which may require their urgent attention. Escalation process for clients – 1st line of defence — Support portal, email support@ethicontrol.com. 2nd line of defence — Support engineer email support team@ethicontrol.com, which should deal with 90% of cases. CC — account manager. 3rd line of defence — Ethicontrol engineers. CC — CTO, account manager Ultimate escalation — CEO, CC — CTO, account manager Default Point of Contact — support@ethicontrol.com	Alertar al personal adecuado del cliente de que se ha producido una emergencia (incidente crítico) que puede requerir su atención urgente. Proceso de escalada para clientes - 1ª línea de defensa: portal de asistencia, correo electrónico support@ethicontrol.com. 2ª línea de defensa - Ingeniero de soporte, correo electrónico team@ethicontrol.com, que debería ocuparse del 90% de los casos. CC - gestor de cuentas. 3ª línea de defensa: ingenieros de Ethicontrol. CC - CTO, gestor de cuentas Última escalada - CEO, CC - CTO, gestor de cuentas. Punto de contacto por defecto - support@ethicontrol.com	<<Brindar detalles adicionales de ser necesario.>>
4.4	Are there manuals or frequently asked questions documentation?	¿Se cuenta con manuales o documentación de preguntas frecuentes?	YES	SI	https://ethicontrol.com/en/faq	https://ethicontrol.com/en/faq	<<Brindar detalles adicionales de ser necesario.>>
4.5	Are there manuals or escalation level documents?	¿Se cuenta con manuales o documentos de	YES	SI	https://help.ethicontrol.com/en/support/home	https://help.ethicontrol.com/en/support/home	<<Brindar detalles adicionales de ser necesario.>>



		niveles de escalamiento?					
4.6	Are there schemes and procedures for in-person support?	¿Se cuenta con esquemas y procedimientos para soporte presencial?	NO	NO		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
4.7	For support, is the vendor, manufacturer, or third party required to have access to the internal network?	Para el soporte, ¿se requiere que el proveedor, fabricante o un tercero tenga acceso a la red interna?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
4.8	What levels of service are offered?	¿Qué niveles de servicio se ofrecen?	YES	SI	https://ethicontrol.com/en/terms-of-business	https://ethicontrol.com/en/terms-of-business	<<Brindar detalles adicionales de ser necesario.>>
4.9	At what frequency are these service levels measured?	¿En que frecuencia se miden estos niveles de servicios?	YES	SI	On request	Por encargo	<<Brindar detalles adicionales de ser necesario.>>
4.10	What type of reports and in what format are they delivered/generated regarding compliance with SLAs?	¿Qué tipo de informes y en que formato se entregan/generan respecto al cumplimiento de los SLA's?	YES	SI	https://ethicontrol.com/en/terms-of-business	https://ethicontrol.com/en/terms-of-business	<<Brindar detalles adicionales de ser necesario.>>
4.11	Does the provider offer help desk service (online, onsite)?	¿El proveedor ofrece servicio de help desk (online, onsite)?	YES	SI	https://help.ethicontrol.com/en/support/home	https://help.ethicontrol.com/en/support/home	<<Brindar detalles adicionales de ser necesario.>>
4.12	Does the provider offer local or regional technical support service?	¿El proveedor ofrece servicio de soporte tecnico local o regional?	YES	SI	Online	En línea	<<Brindar detalles adicionales de ser necesario.>>
4.13	Does the provider offer 24x7 support service?	¿El proveedor ofrece servicio de soporte 24x7?	YES	SI		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>



4.14	What are the escalation levels offered by the provider (limit SLA)?	¿Cuáles son los niveles de escalamiento que ofrece el proveedor (acotar SLA)?	YES	SI	Alert appropriate client personnel that an emergency (critical incident) has occurred, which may require their urgent attention. Escalation process for clients – 1st line of defence — Support portal, email support@ethicontrol.com. 2nd line of defence — Support engineer email support team@ethicontrol.com, which should deal with 90% of cases. CC — account manager. 3rd line of defence — Ethicontrol engineers. CC — CTO, account manager Ultimate escalation — CEO, CC — CTO, account manager Default Point of Contact — support@ethicontrol.com	Alertar al personal adecuado del cliente de que se ha producido una emergencia (incidente crítico) que puede requerir su atención urgente. Proceso de escalada para clientes - 1ª línea de defensa: portal de asistencia, correo electrónico support@ethicontrol.com. 2ª línea de defensa - Ingeniero de soporte, correo electrónico team@ethicontrol.com, que debería ocuparse del 90% de los casos. CC - gestor de cuentas. 3ª línea de defensa: ingenieros de Ethicontrol. CC - CTO, gestor de cuentas Última escalada - CEO, CC - CTO, gestor de cuentas. Punto de contacto por defecto - support@ethicontrol.com	<<Brindar detalles adicionales de ser necesario.>>
4.15	What is the maximum incident resolution time (limit SLA)?	¿Cuál es el tiempo máximo de resolución de incidentes (acotar SLA)?	YES	SI	https://ethicontrol.com/en/terms-of-business	https://ethicontrol.com/en/terms-of-business	<<Brindar detalles adicionales de ser necesario.>>
4.16	What is the guarantee of the post-implementation solution?	¿Cuál es la garantía de la solución postimplementación?	YES	SI	SaaS means that if you don't like you don't continue the contract	SaaS significa que si no le gusta no continúa el contrato	<<Brindar detalles adicionales de ser necesario.>>
4.17	Is there any additional cost for support?	¿Hay algún costo adicional por el soporte?	NO	NO		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>
4.18	Does support include remote technical assistance and/or remote desktop access to resolve issues?	¿El soporte incluye asistencia técnica remota y/o acceso a escritorio remoto para resolver problemas?	YES	SI		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>
4.19	Does the vendor offer ongoing training services for end users and support staff?	¿El proveedor ofrece servicios de capacitación continua para los usuarios finales y el personal de soporte?	YES	SI		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>
4.20	Is there an online portal for tracking support tickets and getting real-time updates?	¿Existe un portal en línea para el seguimiento de tickets de soporte y la obtención de	YES	SI		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>



		actualizaciones en tiempo real?					
4.21	Is a detailed incident report provided after resolution? Does it include root cause analysis and preventive actions?	¿Se proporciona un informe detallado de incidentes después de su resolución? ¿Incluye análisis de causa raíz y acciones preventivas?	NO	NO		<<Precisar>>	<<Brindar detalles adicionales de ser necesario.>>
5. ENTRENAMIENTO Y CAPACITACIÓN							
Id	Item	Item	YES/NO	Aplica Si /No		Detalle	Comentario
5.1	Does the licensing include any type of training?	¿El licenciamiento incluye algún tipo de capacitación?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.2	If applicable, does the licensing include training for developers?	Si corresponde, ¿El licenciamiento incluye entrenamiento para los desarrolladores?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.3	Are training and/or coaching services offered (in addition to those that can be obtained with licensing, if applicable)?	¿Se ofrecen servicios de capacitación y/o entrenamiento (adicionales a los que se puedan obtener con el licenciamiento en caso corresponda)?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.4	What options are available for training/training? (in person/virtual and in what language).	¿Qué opciones se tiene para la capacitación/entrenamiento? (presencial/virtual y en que idioma).	YES	SI	Virtual, English and Spanish	Virtual, inglés y español, reuniones online	<<Brindar detalles adicionales de ser necesario.>>
5.5	Do the upgrades include documents for training on the new features? (define whether the	¿Los upgrades incluyen documentos para capacitación/entrenamiento en las nuevas funcionalidades?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>



	documents are virtual or physical).	(acotar si los documentos son virtuales o fisicos).					
5.6	Does the provider offer functional/technical documentation of the platform?, considering the following points: - Applications: Detail of the solution modules and respective architecture. - Data: Consider model and data-metadata dictionary of the solution. - Technological: Detail of the infrastructure that supports the solution modules.	¿El proveedor ofrece documentacion funcional/técnica de la plataforma?, considerando los siguientes puntos: - Aplicaciones: Detalle de los módulos de la solución y arquitectura respectiva. - Datos: Considerar modelo y diccionario de datos-metadata de la solución. - Tecnológica: Detalle de la infraestructura que soporta los módulos de la solución.	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.7	Does the provider grant a certification on the training provided?	¿El proveedor otorga una certificación sobre la capacitacion brindada?	NO	NO		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.8	The provider provides the possibility of "mentoring" during the implementation of the platform.	El proveedor brinda la posibilidad de "mentoring" durante la implementación de la plataforma.	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>
5.9	Does the vendor offer regular training content updates to reflect new features or changes to the application?	¿El proveedor ofrece actualizaciones regulares de contenido de capacitación para reflejar las nuevas características o cambios en la aplicación?	YES	SI		<<Indicar>>	<<Brindar detalles adicionales de ser necesario.>>



Annex 7

INFORMATION SECURITY POLICIES

Política de Seguridad de Información para el cumplimiento de Proveedores

1. Objetivo

Definir un modelo integral para gestionar la Seguridad de la Información en los distintos proveedores que tengan una relación vigente e inclusive de los que ya no se encuentren vigentes.

La presente política busca proteger la confidencialidad e integridad y asegurar de manera razonable la disponibilidad de la información de BANBIF en cada uno de sus servicios. BANBIF se reserva el derecho a modificar este documento cuando sea necesario. Los cambios realizados serán divulgados a todas las empresas proveedoras de servicios a las que les aplique utilizando los medios que se consideren pertinentes.

Es responsabilidad de cada proveedor garantizar la lectura y conocimiento de las políticas de seguridad de proveedores de Banbif a su personal, así como de obtener su compromiso de cumplir y respetar dichas normas. Asimismo, se deja por entendido que, al aceptar la cláusula de Seguridad de Información, se compromete a cumplir con las políticas expuestas de acuerdo al servicio que brinde a el Banco.

El proveedor debe imprimir el documento, para luego firmarlo con su representante legal, para finalmente enviarlo al equipo de Seguridad de Información del Banbif al correo SEGURIDADINFO@banbif.com.pe

2. Políticas Generales

- Todos los proveedores de BANBIF deben asegurar que su personal relacionados al servicio no cuenten con antecedentes penales ni policiales.
- Todos los proveedores de BANBIF deben brindar a su personal una charla sobre la confidencialidad de información antes de iniciar el servicio con BANBIF.
- Los proveedores deben cumplir con las normas vigentes como Ley 29733, Reglamento de Seguridad de Información y Ciberseguridad 504 de la SBS, Reglamento de Tarjeta de Débito y Crédito "PCI" de acuerdo a la proporción del servicio.

2.1 Con Respecto a la Confidencialidad de la información

- Toda información (digital o impresa) de BANBIF, a las que tenga acceso los proveedores de servicios con objeto de realización del servicio será considerada información

Anexo 7

POLÍTICAS DE SEGURIDAD DE LA INFORMACIÓN

Information Security Policy for Supplier Compliance

1. Object

Define a comprehensive model to manage Information Security in the different suppliers that have a current relationship and even those that are no longer in force.

This policy seeks to protect the confidentiality and integrity and reasonably ensure the availability of BANBIF's information in each of its services. BANBIF reserves the right to modify this document when necessary. Changes made will be disclosed to all applicable service providers by any means deemed appropriate.

It is the responsibility of each supplier to ensure that its staff are made aware of Banbif's supplier security policies and to obtain their commitment to comply with and respect these rules. It is also understood that, by accepting the Information Security clause, they undertake to comply with the policies set out in accordance with the service they provide to the Bank.

The supplier must print the document, sign it with his legal representative and send it to the Banbif Information Security team at SEGURIDADINFO@banbif.com.pe.

2. General Politics

- All BANBIF providers must ensure that their personnel related to the service do not have a criminal or police record.
- All BANBIF suppliers must provide their staff with a briefing on confidentiality of information prior to commencing service with BANBIF.
- Suppliers must comply with current regulations such as Law 29733, Information Security and Cybersecurity Regulation 504 of the SBS, Debit and Credit Card Regulation 'PCI' according to the proportion of the service.

2.1 Regarding the Confidentiality of the Information

- All information (digital or printed) of BANBIF, to which the service providers have access in order to perform the service will be considered confidential information, according to which, access, exchange and processing of such information will always be carried out in accordance



confidencial, en función de lo cual, el acceso, intercambio y tratamiento de dicha información, se realizará siempre de acuerdo a las finalidades previstas descritas en el contrato de prestación de servicios y manteniendo la debida confidencialidad durante la vigencia del servicio e inclusive después de que finalice la relación con BANBIF.

- Todos los recursos e información a la que haya podido tener acceso o que haya sido necesaria elaborar, modificar o copiar para el correcto desempeño del servicio serán devueltos a BANBIF.
- Todo proveedor debe realizar el borrado seguro de información posterior a la devolución de información que realice en favor de BANBIF, considerando que no debe exceder los 30 días calendarios finalizado la relación contractual.

2.2 Con Respecto a la Propiedad Intelectual

- Los proveedores únicamente podrán utilizar material autorizado por BANBIF para el desarrollo de sus funciones o en su defecto de utilizar algún otro material este debe ser comunicado previamente y aprobado por escrito por BanBif.
- Queda estrictamente prohibido el uso de programas informáticos sin la correspondiente licencia en los sistemas de información de BANBIF.

2.3 Con Respecto al Intercambio de información

- Cualquier tipo de intercambio de información que se produzca entre BANBIF y los proveedores de servicios se entenderá que ha sido realizado dentro del marco establecido por el contrato de prestación de servicios correspondiente, de modo que dicha información no podrá ser utilizada fuera de dicho marco ni para otros fines.
- El proveedor debe garantizar las medidas de seguridad para asegurar la confidencialidad, integridad y disponibilidad al momento del intercambio de información.
- BANBIF se reserva, en función del riesgo identificado, la implantación de medidas de control, registro y auditoría sobre estos recursos de difusión. • El proveedor queda prohibido de realizar las siguientes actividades:

- ✓ Transmitir la información entregada y generada para el servicio a terceras empresas que estén ajenas al contrato, salvo que la exista exigencia reguladora o legal, sin embargo, debe haber previa coordinación para evaluar la entrega y medios empleados, así como los niveles de protección a emplear.
- ✓ Utilizar aplicaciones inseguras para transmitir información a Banbif. ✓ Utilizar la información de BANBIF para fines de estudios profesionales ajenos al servicio contratado.

with the purposes described in the service contract and maintaining due confidentiality during the term of the service and even after the relationship with BANBIF ends.

- All resources and information to which it may have had access or that may have been necessary to elaborate, modify or copy for the proper performance of the service will be returned to BANBIF.
- Every supplier must perform the secure deletion of information after the return of information to BANBIF, considering that it should not exceed 30 calendar days after the end of the contractual relationship.

2.2 With regard to Intellectual Property

- Suppliers may only use material authorised by BANBIF for the performance of their functions or, failing that, if any other material is used, this must be communicated in advance and approved in writing by BanBif.
- It is strictly forbidden to use software without the corresponding licence in BANBIF's information systems.

2.3 Regarding the Exchange of Information

- Any type of exchange of information that takes place between BANBIF and the service providers shall be understood to have been carried out within the framework established by the relevant service provision contract, so that such information may not be used outside such framework or for other purposes.
- The provider must guarantee security measures to ensure confidentiality, integrity and availability when exchanging information.
- BANBIF reserves the right, depending on the risk identified, to implement control, registration and audit measures on these dissemination resources. • The provider is prohibited from engaging in the following activities:

- ✓ Transmitting the information delivered and generated for the service to third companies that are outside the contract, unless there is a regulatory or legal requirement, however, there must be prior coordination to evaluate the delivery and means used, as well as the levels of protection to be used. Use insecure applications to transmit information to Banbif.
 - ✓ Using BANBIF information for purposes of professional studies unrelated to the contracted service.
- Any activity that may damage the image and reputation of BANBIF. Any activity that generates a violation of the applicable legal regulations on information security, personal data protection and related issues.



- ✓ Toda actividad que puedan dañar la imagen y reputación de BANBIF. ✓ Toda actividad que genere una vulneración a las normativas legal aplicable sobre seguridad de la información, protección de datos personales y temas vinculados.

2.4 Con Respecto al Uso Apropiado de los Recursos

Corporativos de BANBIF

Los recursos corporativos de BANBIF a los que tengan acceso los proveedores de servicios serán utilizados exclusivamente para cumplir con las obligaciones y propósitos de la provisión del servicio.

- Utilizar los recursos de BANBIF para actividades ilícitas, ó actividades para afectar de manera negativa la reputación de BANBIF como de diversas empresas, será objeto de denuncia, asimismo, será responsable de las sanciones económicas como de las acciones legales.
- Con el fin de velar por el correcto uso de los recursos, BANBIF podrá implementar los mecanismos de control y auditoría que considere oportunos, ya sea de forma periódica o cuando por razones específicas de seguridad o del servicio resulte conveniente.
- En caso de apreciar que algún proveedor de servicios, o su personal, utiliza incorrectamente recursos o información de BANBIF, se le comunicará tal circunstancia al proveedor para que realice acciones correctivas oportunas y tome medidas preventivas en adelante.

2.5 Con Respecto a la Responsabilidades del personal del proveedor

Los Proveedores deben asegurar de que todo el personal que en el desarrollo de sus funciones para BANBIF puedan tener acceso a la información, app o sistemas de información o cualquier otro recurso de BANBIF respete y cumpla los siguientes requisitos:

- Todo personal de proveedor que tenga acceso a la información de BANBIF es responsable de y por las actividades de sus identificadores de usuario. Por tanto, toda persona debe proteger su usuario y contraseña o método de autenticación asociado a su identificador de usuario, asimismo, todo proveedor es responsable del actuar de su personal.
- El personal del proveedor no debe, ni puede utilizar el usuario de otra persona.
- Todo personal de proveedor con acceso a información de BANBIF debe seleccionar contraseñas de calidad (al menos 8 caracteres, contener letras mayúsculas, minúsculas, dígitos y caracteres especiales, que no contengan ningún tipo de información fácilmente adivinable).
- Todo personal de proveedor con acceso a información de BANBIF debe cambiar las contraseñas por defecto y las temporales en el primer inicio de sesión, y como mínimo una vez cada 90 días y o cuando exista un

2.4 Sobre el uso adecuado de los recursos corporativos de BANBIF

- Los recursos corporativos de BANBIF a los que tengan acceso los prestadores de servicios se utilizarán exclusivamente para el cumplimiento de las obligaciones y fines de la prestación del servicio.
- La utilización de los recursos de BANBIF para actividades ilícitas, o que afecten negativamente a la reputación de BANBIF así como de diversas empresas, será objeto de denuncia, siendo susceptible de sanciones económicas así como de acciones legales.
- Con el fin de garantizar el buen uso de los recursos, BANBIF podrá implantar los mecanismos de control y auditoría que estime oportunos, bien de forma periódica o cuando por razones específicas de seguridad o de servicio sea conveniente.
- En el caso de que algún proveedor de servicios o su personal haga un uso indebido de los recursos o de la información de BANBIF, se notificará al proveedor para que tome las medidas correctoras oportunas y adopte medidas preventivas en el futuro.

2.5 Regarding Supplier Personnel Responsibilities

Suppliers must ensure that all personnel who in the performance of their duties for BANBIF may have access to BANBIF information, app or information systems or any other BANBIF resources respect and comply with the following requirements:

- All supplier personnel who have access to BANBIF information are responsible for and accountable for the activities of their user identifiers. Therefore, every person must protect his or her user and password or authentication method associated with his or her user identifier, and every supplier is responsible for the actions of his or her personnel.
- Provider personnel must not, and may not, use another person's user ID.
- All supplier personnel with access to BANBIF information must select quality passwords (at least 8 characters, containing uppercase letters, lowercase letters, digits and special characters, not containing any easily guessable information).
- All supplier personnel with access to BANBIF information must change default and temporary passwords at the first login, and at least once every 90 days and or when there is a possible indication of knowledge by other users.
- All supplier personnel with access to BANBIF information must ensure that equipment is protected when it is to be left



posible indicio de conocimiento por parte de otros usuarios.

- Todo personal de proveedor con acceso a información de BANBIF debe velar por que los equipos queden protegidos cuando vayan a quedar desatendidos.
- Todo personal de proveedor con acceso a información de BANBIF debe respetar las normas de escritorio limpio, con el fin de proteger los documentos en papel, soportes informáticos y dispositivos portátiles de almacenamiento y reducir los riesgos de acceso no autorizado, pérdida y daño de la información, tanto durante el horario normal de trabajo como fuera del mismo (Almacenamiento bajo llave, bloqueo de equipos desatendidos, protección de los puntos de recepción y envío de información, destrucción segura, etc.)
- Todo personal de proveedor con acceso a información de BANBIF no podrá realizar pruebas para detectar y/o explotar una supuesta debilidad o incidencia de seguridad a menos que este cuente con alguna autorización por escrito por parte de BANBIF.
- Todo personal de proveedor con acceso a sistemas de información de BANBIF está prohibido de capturar tráfico de red, salvo que se estén llevando a cabo tareas de auditoría autorizadas por escrito por parte de BANBIF.

2.6 Con Respecto a los Requisitos de seguridad para los dispositivos

Todos los dispositivos con acceso a información de BANBIF, independientemente de la propiedad de estos, deben cumplir con los lineamientos de seguridad establecidos por BANBIF, siendo estas:

- Todo personal de proveedor solo podrá utilizar dispositivos proporcionados por su contratante o que estos sean suministrados por BANBIF, quedando terminantemente prohibido el uso de dispositivos personales.
- El acceso a los sistemas debe realizarse siempre de forma autenticada, para lo cual debe utilizar un identificador personal y una contraseña asociada. • Todo el software instalado o contenido en el dispositivo debe estar licenciado, dentro del ciclo de vida del producto y en un estado acorde a la licencia de uso.
- Los dispositivos deberán permanecer actualizados con la última versión disponible de parches de seguridad para el software y sistema operativo instalado.
- Los dispositivos deben contar con un sistema de protección anti-malware instalado, activo y actualizado a su última versión disponible, tanto del motor como del fichero de firmas.
- Debe activarse el bloqueo de pantalla para que este se active ante una inactividad, se recomienda que dicha configuración se active en un periodo que se encuentre entre 5 o 10 minutos de inactividad. El desbloqueo debe conllevar el uso de contraseñas, patrones de desbloqueo o mecanismos equivalentes, que

unattended.

• All supplier personnel with access to BANBIF information must adhere to clean desk rules in order to protect paper documents, computer media and portable storage devices and to reduce the risks of unauthorised access, loss and damage to information, both during and outside normal working hours (Locked storage, locking of unattended equipment, protection of receiving and sending points, secure destruction, etc.).

• Any supplier personnel with access to BANBIF information may not conduct tests to detect and/or exploit a suspected security weakness or incident unless authorised in writing by BANBIF.

• All vendor personnel with access to BANBIF information systems are prohibited from capturing network traffic unless they are performing auditing tasks authorized in writing by BANBIF.

2.6 Regarding Security Requirements for Devices

All devices with access to BANBIF information, regardless of their ownership, must comply with the security guidelines established by BANBIF, being these:

• All supplier personnel may only use devices provided by their contractor or that these are supplied by BANBIF, the use of personal devices being strictly prohibited.

• Access to the systems must always be carried out in an authenticated manner, for which a personal identifier and associated password must be used. • All software installed or contained on the device must be

licensed, within the product lifecycle and in a state consistent with the licence for use.

• Devices must remain up to date with the latest available version of security patches for the installed software and operating system.

• Devices must have an anti-malware protection system installed, active and updated to the latest available version of both the engine and the signature file.

• The screen lock must be enabled to be activated upon inactivity, it is recommended that this setting be activated within 5 to 10 minutes of inactivity. Unlocking must involve the use of passwords, unlock patterns or equivalent mechanisms to ensure that the device cannot be used by an unauthorised user.



garanticen que el dispositivo no podrá ser utilizado por un usuario no autorizado.

2.7 Con Respecto a la Comunicación de incidentes de seguridad

Los proveedores se comprometen a comunicar de manera inmediata cualquier incidente, debilidad o amenaza (observada o sospechada) que detecte en los sistemas de información de BANBIF o que haya podido afectar a información propiedad de BANBIF o de sus clientes al Departamento de Seguridad de la Información “**SEGURIDADINFO@banbif.com.pe**”.

Los proveedores se comprometen a comunicar de manera inmediata cualquier incidente que tenga sus aplicativos, así como facilitar una entrevista al personal de Seguridad de Información del BANBIF en caso se vea comprometido la información de los clientes y/o colaboradores de BANBIF.

Los proveedores que brinden servicios de desarrollo de aplicaciones o servicio que involucre el uso de sistemas o aplicaciones que no son de BANBIF en donde se realice almacenamiento, procesamiento y transferencia de datos estos proporcionarán a BANBIF:

- La relación de personas, perfiles, funciones y responsabilidades asociados al servicio prestado, e informará de cualquier cambio (alta, baja, sustitución o cambio de funciones o responsabilidades) que se produzca en dicha relación.
- Los sustentos que aseguren que todo su personal tiene la formación y capacitación apropiada para el desarrollo del servicio provisto, tanto a nivel específico en las materias correspondientes a la actividad asociada a la prestación del servicio, como en materia de seguridad de la información.

2.8 Con Respecto a la Seguridad Física

- Todas las puertas externas deben estar adecuadamente protegidas contra los accesos no autorizados a través de mecanismos de control, por ejemplo, barras, alarmas, cerraduras, tornos, cámaras de vigilancia etc.
- Aplicar un control para la identificación del empleado sea con tarjetas de identificación, tarjetas electrónicas, identificación biométrica, etc, esto con finalidad de prevenir los accesos físicos no autorizados.
- Tener extintores en buen estado y disponibles para su uso.
- En caso de almacenar información de BANBIF en servidores on-premise, estos deben estar ubicados en un área especialmente protegida, que incluya como mínimo las siguientes medidas de seguridad:
 - ✓ Contar con detectores de humo.
 - ✓ Falso techo, falso piso.

2.7 Regarding the Communication of security incidents

Suppliers undertake to immediately report any incident, weakness or threat (observed or suspected) detected in BANBIF's information systems or that may have affected information owned by BANBIF or its clients to the Information Security Department ‘**SEGURIDADINFO@banbif.com.pe**’.

Suppliers undertake to immediately report any incident involving their applications, as well as to facilitate an interview with BANBIF's Information Security personnel in the event that the information of BANBIF's customers and/or collaborators is compromised.

Suppliers that provide application development services or services that involve the use of systems or applications that are not BANBIF's where storage, processing and transfer of data is performed shall provide these to BANBIF:

- The list of persons, profiles, functions and responsibilities associated with the service provided, and shall inform of any changes (registration, deregistration, replacement or change of functions or responsibilities) that occur in said list.
- The supporting documents that ensure that all personnel have the appropriate training and qualifications for the development of the service provided, both at a specific level in the matters corresponding to the activity associated with the provision of the service, as well as in the area of information security.

2.8 With regard to Physical Security

- All external doors must be adequately protected against unauthorised access through control mechanisms, e.g. bars, alarms, locks, turnstiles, surveillance cameras, etc.
- Implement control for employee identification either with ID cards, electronic cards, biometric identification, etc., in order to prevent unauthorised physical access.
- Have fire extinguishers in good condition and available for use.
- In case of storing BANBIF information in on-premise servers, these must be located in a specially protected area, which includes at least the following security measures:
 - ✓ Having smoke detectors.
 - ✓ False ceiling, false floor.
 - ✓ UPS.
 - ✓ Security cameras.
 - ✓ Access logbook.
 - ✓ To have personnel to validate entry or have technological access controls such as: electronic cards, use of



- ✓ Contar con UPS.
- ✓ Contar con cámaras de seguridad.
- ✓ Contar con una bitácora de accesos.
- ✓ Contar con personal que valide los ingresos o contar con controles de acceso de tipo tecnológico como: tarjetas electrónicas, uso de biometría, etc
- ✓ El personal externo no podrá permanecer ni ejecutar trabajos en las áreas especialmente protegidas sin supervisión.

3. Políticas Específicas

3.1. Servicios de Custodia de Información

Los proveedores que brinden servicios de custodia de información (sea en CDs, cintas, backups discos externos e incluso papel impreso) deben proporcionar a BANBIF:

- Las facilidades para permitir que BANBIF realice visitas y pueda verificar el correcto custodio de información de acuerdo a contrato.
- El entendimiento, la documentación, así como los sustentos de controles físicos sobre el ingreso a la empresa, ingreso al sector donde se encuentre la información en custodia.

3.2. Servicios en donde se usa la Infraestructura TIC del proveedor

Los proveedores que brinden servicios en donde se use su infraestructura deben asegurar:

- Tener un registro de activos actualizado en el que se puedan identificar los activos utilizados para la prestación del servicio.
- Tener un procedimiento en el que se detalle las bajas de los activos utilizados para la prestación del servicio.
- Tener un procedimiento que detalle la eliminación segura de dicha información, aplicando funciones de borrado seguro o destruyendo físicamente el activo, para que la información que haya contenido no pueda ser recuperable.
- Que todos los activos utilizados para la prestación del servicio deberán tener un responsable, que se deberá asegurar de que dichos activos incorporan las medidas de seguridad mínimas establecidas por BANBIF, y que al menos deben ser las especificadas en la presente normativa:
- Que exista una normativa de copias de seguridad que garantice la salvaguarda de cualquier dato o información relevante para el servicio prestado.

3.3 Servicios sobre desarrollo de sistemas y/o pruebas de aplicaciones

biometrics, etc.

- ✓ External personnel shall not remain or carry out work in the specially protected areas without supervision.

3. Specific Policies

3.1. Information Custody Services

Suppliers that provide information custody services (whether on CDs, tapes, backups, external disks and even printed paper) must provide BANBIF:

- The facilities to allow BANBIF to make visits and to be able to verify the correct safekeeping of information according to contract.
- The understanding, the documentation, as well as the physical control supports on the entry to the company, entry to the sector where the information in custody is located.

3.2. Services where the provider's ICT infrastructure is used

Providers providing services where their infrastructure is used must ensure:

- Have an up-to-date asset register in which the assets used for the provision of the service can be identified.
- Have a procedure detailing the decommissioning of assets used for the provision of the service.
- Have a procedure detailing the secure disposal of such information by applying secure deletion functions or physically destroying the asset, so that the information contained therein cannot be recovered.
- That all assets used for the provision of the service must have a person in charge, who must ensure that such assets incorporate the minimum security measures established by BANBIF, and which must at least be those specified in these regulations:
- That there is a backup regulation that guarantees the safeguarding of any data or information relevant to the service provided.

3.3 System development and/or application testing services



Los proveedores que realicen trabajos de desarrollo y/o pruebas de aplicaciones para BANBIF deben asegurar:

- Los entornos con los que se lleven a cabo dichas actividades deberán estar aislados entre sí y también aislados de los entornos de producción.
- Todos los accesos a los sistemas de información que alberguen o procesen información deberán estar protegidos, al menos, por un “cortafuegos”, que limite la capacidad de conexión a ellos.
- Todo proceso de desarrollo de software debe seguir buenas prácticas de OWASP
- Todo el proceso de desarrollo debe entregar a BANBIF información sobre el diseño de sistema, la aplicación de modificaciones o cambios (versionamiento), resultados de los test de pruebas funcionales y de seguridad.
- Se debe realizar Ethical Hacking y/o análisis y vulnerabilidades de acuerdo al servicio.
- Las aplicaciones que se desarrollen deberán incorporar validaciones de los datos de entrada que verifiquen que los datos son correctos y apropiados y que eviten la introducción de código ejecutable.
- Siempre que sea necesario se deberán incorporar funciones de autenticación y control de integridad en las comunicaciones entre los diferentes componentes de las aplicaciones
- Se deberá limitar la información de salida ofrecida por las aplicaciones, garantizando que sólo se ofrece aquella pertinente y necesaria.
- El acceso al código fuente de los aplicativos deberá estar limitado al personal del servicio.
- En el entorno de pruebas sólo se utilizarán datos reales cuando hayan sido apropiadamente disociados o siempre que se pueda garantizar que las medidas de seguridad aplicadas sean equivalentes a las existentes en el entorno de producción
- Durante las pruebas de los aplicativos se verificará que no existen canales de fuga de información no controlados, y que por los canales establecidos sólo se ofrece la información prevista.
- Solo se transferirán al entorno de producción aquellos aplicativos que hayan sido expresamente aprobados por BANBIF.

3.4 Servicios sobre uso de aplicaciones

- Todo proveedor que brinde el servicio de uso de una aplicación a BANBIF debe proporcionar:
- Sustentos de pruebas de seguridad como Ethical Hacking y/o análisis de vulnerabilidades.
- Compartir sustentos en caso que la aplicación cumpla con estándares de PCI DSS.

Suppliers performing application development and/or testing work for BANBIF must ensure:

- The environments with which such activities are carried out must be isolated from each other and also isolated from production environments.
 - All accesses to information systems that host or process information must be protected, at least, by a ‘firewall’, which limits the ability to connect to them.
 - All software development processes should follow OWASP best practices.
 - The entire development process must provide BANBIF with information on system design, implementation of modifications or changes (versioning), functional and security test results.
 - Ethical Hacking and/or analysis and vulnerabilities must be performed according to the service.
 - The applications to be developed must incorporate validations of the input data that verify that the data are correct and appropriate and prevent the introduction of executable code.
 - Whenever necessary, authentication and integrity control functions should be incorporated in the communications between the different components of the applications.
- The output information provided by applications should be limited, ensuring that only relevant and necessary information is provided.
- Access to the source code of applications shall be limited to service personnel.
 - Real data shall only be used in the test environment when it has been appropriately decoupled or when it can be ensured that the security measures applied are equivalent to those in the production environment.
 - During application testing, it shall be verified that there are no uncontrolled information leakage channels and that only the intended information is provided through the established channels.
 - Only those applications that have been expressly approved by BANBIF will be transferred to the production environment.

3.4 Application Usage Services

- Any supplier providing an application usage service to BANBIF must provide:
- Substantiation of security testing such as Ethical Hacking and/or vulnerability analysis.
- Sharing of evidence in the event that the application complies with PCI DSS standards.



- Asegurar que la aplicación cuente con cifrado en reposo y en tránsito. • Asegurar que la aplicación cuente con un módulo de gestión de accesos y que proporcione permisos de acuerdo a un perfil de usuario.
- Uso de captcha/ recaptcha/ Doble Factor de Autenticación
- Asegurar que la aplicación cuente con pistas de auditoria.

4. Declaratoria

En señal de conformidad. El proveedor declara haber leído, conocer y aceptar la presente política, asimismo, es responsable del debido conocimiento y cumplimiento por parte de su personal.

- Ensure that the application has encryption at rest and in transit. · Ensure that the application has an access management module and provides permissions according to a user profile.
- Use of captcha/ recaptcha/ Double Factor Authentication.
- Ensure that the application has audit trails.

4. Declaration

As a sign of conformity. The supplier declares that he has read, knows and accepts this policy and is responsible for the proper knowledge and compliance of his personnel.

Anexo 8

CLÁUSULAS REGULATORIAS

1. DECLARACIONES ANTICORRUPCIÓN

La **EMPRESA** declara que conoce las normas vigentes sobre responsabilidad de las personas jurídicas por delitos de corrupción de funcionarios y/o servidores públicos, lavado de activos y financiamiento del terrorismo; así como aquellas normas que prohíben y sancionan dichos delitos y demás normativa que resulte aplicable, relacionada a conductas ilícitas que lesionen o pudieran lesionar los intereses, reputación, patrimonio o activos de **BANBIF**, previstas en el Código Penal y demás leyes penales especiales.

En consecuencia, la **EMPRESA** acepta y declara que:

- (i) Ni la **EMPRESA**, ni ninguno de sus accionistas, socios, asociados, directores, gerentes, apoderados, asesores, funcionarios, empleados, agentes, subsidiarias, filiales, contratistas, sub contratistas, representantes legales, persona natural bajo autoridad de los anteriormente mencionados o en general cualquier persona actuando en nombre, por cuenta o en interés de la **EMPRESA** (en adelante, las "Personas Vinculadas"), han sido condenados por las autoridades nacionales o internacionales por delitos de lavado de activos, minería ilegal, financiamiento de terrorismo, corrupción de funcionarios y/o servidores públicos y/o en general cualquier otro delito con capacidad de generar ganancias ilegales.
- (ii) Ni la **EMPRESA** ni las Personas Vinculadas son responsables por la comisión de cualesquiera de los delitos mencionados en el numeral (i) ante autoridad competente, nacional o internacional; ni han sido incluidos en el Registro de Personas Jurídicas Sancionadas Administrativamente del Poder Judicial (Ley No. 30424).
- (iii) Ni la **EMPRESA** ni ninguna de las Personas Vinculadas ha realizado ni realizará conducta delictiva alguna relacionada con la actividad **EMPRESA** de la **EMPRESA**, que lesione o pudiera lesionar sus intereses o los intereses, reputación, patrimonio o activos de **BANBIF** o pueda implicar un incumplimiento de las normas antes indicadas o de las normas que regulan los procesos de contratación con el Estado peruano o cualquier otro Estado o que puedan resultar en sanciones administrativas, penales, civiles o de otra índole para la **EMPRESA**. A efectos de la

Annex 8

REGULATORY CLAUSES

1. ANTI-CORRUPTION DECLARATIONS

The COMPANY declares that it is aware of the regulations in force on the liability of legal persons for crimes of corruption of officials and/or public servants, money laundering and financing of terrorism; as well as those regulations that prohibit and punish such crimes and other applicable regulations related to unlawful conduct that harm or could harm the interests, reputation, property or assets of **BANBIF**, as provided for in the Criminal Code and other special criminal laws.

Accordingly, the COMPANY agrees and declares that:

Neither the COMPANY, nor any of its shareholders, partners, associates, directors, managers, attorneys-in-fact, advisors, officers, employees, agents, subsidiaries, affiliates, contractors, subcontractors, legal representatives, natural person under authority of the aforementioned or in general any person acting in the name, on behalf or in the interest of the COMPANY (hereinafter, the 'Related Persons'), have been convicted by national or international authorities for crimes of money laundering, illegal mining, financing of terrorism, corruption of officials and/or public servants and/or in general any other crime with the capacity to generate illegal profits.

Neither the COMPANY nor the Related Persons are responsible for the commission of any of the crimes mentioned in paragraph (i) before any competent national or international authority; nor have they been included in the Register of Administratively Sanctioned Legal Entities of the Judiciary (Law No. 30424).

Neither the COMPANY nor any of the Related Persons has carried out or will carry out any criminal conduct related to the COMPANY's business activity, which harms or could harm its interests or the interests, reputation, patrimony or assets of **BANBIF** or could imply a breach of the aforementioned rules or the rules that regulate the contracting processes with the Peruvian State or any other State or that could result in administrative, criminal, civil or any other type of sanctions for the COMPANY. For the purposes of this clause, criminal conduct shall be understood to have taken place when, within the framework of criminal



- presente cláusula, se entenderá realizada una conducta delictiva cuando en el marco de un proceso penal, el Ministerio Público formule acusación contra la **EMPRESA** o las Personas Vinculadas.
- (iv) Los recursos, fondos, dineros, activos, bienes que forman parte de su patrimonio y actividad comercial, provienen de actividades lícitas y no están vinculados con ninguno de los delitos indicados en el numeral (i); y que el destino de los recursos, recibidos en virtud de la relación comercial que mantiene con **BANBIF** no serán destinados para la financiación del terrorismo o cualquier tipo de actividad ilícita o conducta delictiva.
 - (v) Ni la **EMPRESA** ni ninguna de las Personas Vinculadas se encuentran incluidos en alguna de las listas sancionadoras y/o terroristas o relacionadas al lavado de activos y financiamiento del terrorismo administradas por cualquier autoridad nacional o extranjera; ni aquellas mencionadas en el Anexo N° 1 de la Resolución SBS N° 2660- 2015 o cualquier norma que la modifique, derogue y/o sustituya;
 - (vi) Ni la **EMPRESA** ni las Personas Vinculadas vienen siendo denunciados públicamente por cualquier medio de comunicación reconocido y de amplia difusión, por encontrarse vinculados a delitos de lavado de activos, financiamiento de terrorismo o corrupción de funcionarios y/o servidores públicos
 - (vii) Cumple y ha adoptado las medidas razonables para que las Personas Vinculadas cumplan con la obligación de no realizar conductas delictivas que lesionen o pudieran lesionar los intereses, reputación, patrimonio o activos de **BANBIF** y de no cometer cualquiera de los delitos mencionados en el numeral (i).
 - (viii) Ha implementado las medidas tendientes a evitar que sus operaciones y/o estructura puedan ser utilizadas con o sin su conocimiento y/o consentimiento como instrumentos para la realización de conductas delictivas contempladas en el Código Penal peruano, en leyes penales especiales o en cualquier otra norma que los modifique o adicione, especialmente los delitos referidos en el numeral (i).
 - (ix) En caso **BANBIF** incurriera en costos y/o multas establecidas por una resolución administrativa o sentencia firme, como consecuencia del incumplimiento de lo establecido en la presente cláusula, la **EMPRESA** se hará responsable por dichas penalidades, reparaciones y/o multas, asumiendo el importe de las mismas, sin reserva ni limitación alguna.

proceedings, the Public Prosecutor's Office brings charges against the COMPANY or the Related Persons.

The resources, funds, monies, assets, goods that are part of its patrimony and business activity, come from lawful activities and are not linked to any of the crimes indicated in paragraph (i); and that the destination of the resources received by virtue of the business relationship it maintains with BANBIF will not be destined for the financing of terrorism or any type of illicit activity or criminal conduct.

Neither the COMPANY nor any of the Related Persons are included in any of the sanctioning and/or terrorist lists or lists related to money laundering and financing of terrorism administered by any national or foreign authority; nor those mentioned in Annex No. 1 of SBS Resolution No. 2660-2015 or any regulation that amends, repeals and/or replaces it;

Neither the COMPANY nor the Related Persons have been publicly denounced by any recognised and widely disseminated media for being linked to crimes of money laundering, financing of terrorism or corruption of officials and/or public servants.

Complies with and has adopted reasonable measures to ensure that Related Persons comply with the obligation not to engage in criminal conduct that damages or could damage the interests, reputation, property or assets of BANBIF and not to commit any of the offences mentioned in paragraph (i).

It has implemented measures to prevent its operations and/or structure from being used with or without its knowledge and/or consent as instruments for the commission of criminal conduct contemplated in the Peruvian Criminal Code, in special criminal laws or in any other regulation that modifies or adds to them, especially the offences referred to in paragraph (i).

In the event BANBIF incurs costs and/or fines established by an administrative resolution or final judgment, as a consequence of the breach of the provisions of this clause, the COMPANY shall be liable for such penalties, repairs and/or fines, assuming the amount thereof, without reservation or limitation whatsoever.



La **EMPRESA** declara conocer y aceptar que el incumplimiento de esta cláusula dará lugar a la resolución automática del presente **CONTRATO**, la cual implicará la devolución inmediata de la información y/o documentación que pudo haber sido entregada o puesta a disposición de éste, sin obligación de pago ni indemnización alguna por parte de **BANBIF**.

De la misma manera, la **EMPRESA** declara expresamente que las personas indicadas en la sección introductoria del presente **CONTRATO** han sido otorgadas los poderes necesarios, por lo que cuentan con absoluta capacidad para firmar el presente documento en representación dla **EMPRESA**, liberando de responsabilidad a **BANBIF** e incurriendo en incumplimiento de la presente declaración, en el caso de que la misma sea inexacta.

2. FRAUDE Y ANTICORRUPCIÓN

Las **PARTES** deberán cumplir con las leyes, reglamentos y requisitos administrativos aplicables a los negocios desarrollados tanto en el Perú como en otras jurisdicciones en las que operan, esto último en caso sea aplicable. Por tal razón, las **PARTES** exigen a la otra (incluyendo directivos, socios, asociados, funcionarios, agentes, empleados, contratistas, subcontratistas, apoderados y asesores) que, observen, las leyes, reglamentos y requisitos indicados en las etapas de selección, suscripción y ejecución del presente **CONTRATO**.

Por lo tanto, las **PARTES**, en el marco del presente documento:

- (a) Se obligan a no participar en actos de corrupción y/o soborno que puedan involucrar a la otra parte o que puedan ser considerados como un beneficio ilegítimo por la contraparte.
- (b) Se obligan a evitar influir en la decisión de funcionarios públicos a través del otorgamiento de beneficios personales con el propósito de obtener algún beneficio a nombre o a favor de La otra parte.
- (c) Se obligan a no realizar pagos de facilitación por encargo o cuyo beneficio sea a favor de la otra parte.
- (d) Las **PARTES** están obligadas a no otorgar beneficios personales a funcionarios de otras entidades privadas con quienes sea necesario tratar si se tiene evidencia o sospecha que las decisiones de dicho funcionario obedecen a algún beneficio personal distinto al beneficio de la entidad que representa.
- (e) Se obliga a informar cualquier conducta desleal o propuesta por parte de algún colaborador de la contraparte que no se encuentre alineado al presente contrato.
- (f) Aseguran no tener entre sus representantes a un funcionario público ni relacionados con alguno; en caso se encuentre en alguno de estos casos, deberá informarlo al momento de suscripción del presente contrato o inmediatamente haya tenido conocimiento del hecho.

The **COMPANY** declares that it is aware of and accepts that non-compliance with this clause will result in the automatic termination of this **CONTRACT**, which will entail the immediate return of any information and/or documentation that may have been provided or made available to it, without any obligation of payment or compensation on the part of **BANBIF**.

Likewise, the **COMPANY** expressly declares that the individuals indicated in the introductory section of this **CONTRACT** have been granted the necessary powers and therefore have full capacity to sign this document on behalf of the **COMPANY**, releasing **BANBIF** from any liability and incurring a breach of this declaration if it is found to be inaccurate.

2. FRAUD AND ANTI-CORRUPTION

The **PARTIES** must comply with the applicable laws, regulations, and administrative requirements governing the business activities conducted both in Peru and in other jurisdictions where they operate, if applicable. Therefore, the **PARTIES** require each other (including executives, partners, associates, officers, agents, employees, contractors, subcontractors, attorneys-in-fact, and advisors) to observe these laws, regulations, and requirements during the selection, execution, and performance stages of this **CONTRACT**.

Accordingly, under this document, the **PARTIES**:

Commit not to engage in acts of corruption and/or bribery that may involve the other party or that may be considered as an illegitimate benefit by the counterparty.

Commit to avoiding any attempt to influence the decisions of public officials through the granting of personal benefits with the purpose of obtaining any advantage on behalf of or in favor of the other party.

Commit not to make facilitation payments on behalf of or for the benefit of the other party.

Are obligated not to grant personal benefits to officials of other private entities with whom they must engage, if there is evidence or suspicion that such officials' decisions are influenced by personal benefits rather than the interests of the entity they represent.

Commit to reporting any dishonest conduct or proposal from any employee of the counterparty that is not aligned with this contract.

Ensure that none of their representatives is a public official or related to one; if this is the case, they must disclose it at the time of signing this contract or as soon as they become aware of the situation.

Accept that if it is demonstrated that they have engaged



- (g) Acepta que en caso se demuestre que ha incurrido en una conducta impropia o que haya incumplido normas aplicables respecto a anticorrupción, la parte afectada podrá resolver el contrato unilateralmente sin necesidad de aviso previo.
- (h) Aceptan que en caso realice algún acto en contra de lo dispuesto en las normas contra la corrupción y soborno y generen reclamos, denuncias, pérdidas o daños producto de su actuación se cumplirá con pagar la indemnización correspondiente a la parte afectada.
- (i) Adoptar las medidas adecuadas para informar a su personal respecto a las condiciones de esta cláusula.

in improper conduct or have violated applicable anti-corruption regulations, the affected party may unilaterally terminate the contract without prior notice.

Accept that in the event of any act against the provisions of the anti-corruption and anti-bribery rules and generate claims, complaints, losses or damages as a result of their actions, they will pay the corresponding compensation to the affected party.

Take appropriate measures to inform your personnel of the terms of this clause.

3. LAVADO DE ACTIVOS

La **EMPRESA** declara tener conocimiento de lo dispuesto por la Ley N° 27693, ley que crea la Unidad de Inteligencia Financiera; y del Reglamento de Gestión de Riesgos de Lavado de Activos y del Financiamiento al Terrorismo, aprobado por Resolución SBS N° 2660-2015, así como sus normas reglamentarias, modificatorias y sustitutorias.

La **EMPRESA** declara que, a la fecha de suscripción del presente **CONTRATO**, ni ella, ni sus accionistas, directores, gerentes, apoderados, asesores, funcionarios o empleados, filiales, subsidiarias y/o subcontratistas, representantes legales y otros colaboradores que la **EMPRESA** ejerza autoridad sobre ellos; y/o persona natural, no hayan sido condenados o se encuentran procesados y/o incurso en investigaciones por Lavado de Activos o Financiamiento al Terrorismo.

Adicionalmente, la **EMPRESA** se compromete a, (i) brindar su información de forma completa y veraz, respecto a sus accionistas, directores, gerentes, apoderados, asesores, funcionarios o empleados, filiales, subsidiarias y/o subcontratistas, representantes legales y otros colaboradores que la **EMPRESA** ejerza autoridad sobre ellos; y/o persona natural (ii) brindar en el plazo que BANBIF considere razonable, la información complementaria que se requiera, (iii) Informar a **BANBIF** sobre los cambios en la información proporcionada, (iv) Suscribir la declaración jurada que se encuentra en el Anexos del presente **CONTRATO**, y (v) contar con un Oficial de Cumplimiento de Prevención de Lavado de Activos, debidamente registrado ante la SBS, en caso la **EMPRESA** se encuentre comprendido dentro del alcance de la Resolución SBS N° 2660-2015.

La **EMPRESA** declara conocer y aceptar que ante cualquier supuesto de (i) incumplimiento de la presente cláusula, (ii) inicio de una investigación o interposición de denuncia penal a causa de Lavado de Activos y Financiamiento al Terrorismo, se dará por resuelto el presente **CONTRATO**, bastando para ello una Comunicación escrita vía Notarial, con un plazo de anticipación de cinco (5) días útiles.

4. COMPROMISO ÉTICO

3. ANTI-MONEY LAUNDERING

The COMPANY declares that it is aware of the provisions of Law No. 27693, which establishes the Financial Intelligence Unit, as well as the Risk Management Regulation for Money Laundering and Terrorism Financing, approved by SBS Resolution No. 2660-2015, along with its regulatory, amending, and substitutive provisions.

The COMPANY declares that, as of the date of signing this CONTRACT, neither it nor its shareholders, directors, managers, attorneys-in-fact, advisors, officers, employees, affiliates, subsidiaries, subcontractors, legal representatives, or other collaborators under its authority, and/or any natural person, have been convicted of, are currently being prosecuted for, or are under investigation for Money Laundering or Terrorism Financing.

Additionally, the COMPANY commits to:

(i) Providing complete and truthful information regarding its shareholders, directors, managers, attorneys-in-fact, advisors, officers, employees, affiliates, subsidiaries, subcontractors, legal representatives, and other collaborators under its authority, and/or any natural person. (ii) Submitting any additional information requested by BANBIF within the reasonable timeframe it determines. (iii) Informing BANBIF of any changes to the information provided. (iv) Signing the sworn statement included in the Annexes of this CONTRACT. (v) Appointing an Anti-Money Laundering Compliance Officer, duly registered with the SBS, if the COMPANY falls within the scope of SBS Resolution No. 2660-2015.

The COMPANY acknowledges and accepts that in the event of: (i) non-compliance with this clause, or (ii) the initiation of an investigation or the filing of a criminal complaint related to Money Laundering or Terrorism Financing, this CONTRACT will be terminated by means of a notarized written notice, with a prior notice period of five (5) business days.

4. ETHICAL COMMITMENT



Para **BANBIF** es importante promover en la comunidad un comportamiento responsable y ético; en ese sentido, la **EMPRESA** se compromete a cumplir con los compromisos éticos, valores y principios de actuación establecidos por **BANBIF**, los mismos que se resumen a continuación:

- a. Desarrollar relaciones comerciales atendiendo los principios de ética **EMPRESA**rial y gestión transparente.
- b. No permitir el trabajo forzoso, apoyar la erradicación del trabajo infantil y cumplir con las leyes aplicables respecto a la contratación de menores.
- c. Respetar las normas de protección al consumidor y normas de la competencia, impulsando prácticas antimonopólicas y de lealtad comercial.
- d. No ofrecer presentes, invitaciones o atenciones que, directa o indirectamente, puedan llevar a estableces vínculos o compromisos que empañen la transparencia de los negocios.
- e. Cumplir con los lineamientos de prevención y sanción del hostigamiento sexual, de acuerdo a la normativa vigente.
- f. Actuar de manera honesta e íntegra.
- g. Cumplir a cabalidad con las cláusulas de confidencialidad, anticorrupción, lavado de activos, responsabilidad social y conflicto de intereses establecidas en este **CONTRATO**.
- h. Cumplir con los valores de **BANBIF**, los mismos que son: decisión, ejemplaridad, solidez y cercanía.

5. CONFLICTO DE INTERÉS

El incumplimiento por parte d/a **EMPRESA** de cualquiera de las obligaciones contenidas en la presente Cláusula otorgará la facultad a **BANBIF** de resolver el **CONTRATO**, sin perjuicio de otras acciones legales o administrativas que fueran de aplicación.

Las obligaciones contenidas en la presente Cláusula serán extensivas para todos los trabajadores d/a **EMPRESA**, así como con cualquier Persona Vinculada.

Con el propósito de mantener la debida transparencia en todos sus actos y prevenir cualquier acción que pudiera dar como resultado un conflicto de intereses, real o potencial, que pueda afectar independencia de juicio en una decisión, las **PARTES** y sus Personas Vinculadas se comprometen a cumplir las siguientes obligaciones:

- (a) Mantener un comportamiento con los más elevados niveles de honestidad, equidad e integridad personal durante el desarrollo de sus actividades.
- (b) Ejercer el mayor cuidado y hacer todas las diligencias razonables para prevenir cualesquiera acciones, condiciones o circunstancias que pudieran dar como resultado un conflicto de intereses.

For **BANBIF**, promoting responsible and ethical behavior within the community is of utmost importance. In this regard, the **COMPANY** commits to adhering to the ethical commitments, values, and principles of conduct established by **BANBIF**, which are summarized as follows:

Develop business relationships based on corporate ethics principles and transparent management.

Prohibit forced labor, support the eradication of child labor, and comply with applicable laws regarding the employment of minors.

Respect consumer protection and competition laws, promoting fair trade and anti-monopoly practices.

Refrain from offering gifts, invitations, or hospitality that could directly or indirectly establish relationships or commitments that compromise business transparency.

Comply with guidelines for preventing and sanctioning sexual harassment in accordance with applicable regulations.

Act with honesty and integrity.

Fully comply with the confidentiality, anti-corruption, anti-money laundering, corporate social responsibility, and conflict of interest clauses established in this **CONTRACT**.

Uphold **BANBIF**'s core values: determination, exemplary conduct, stability, and closeness.

5. CONFLICT OF INTEREST

Failure by the **COMPANY** to comply with any of the obligations in this clause will entitle **BANBIF** to terminate the **CONTRACT**, without prejudice to any other applicable legal or administrative actions.

The obligations set forth in this clause shall extend to all employees of the **COMPANY**, as well as to any Related Persons.

To ensure full transparency in all transactions and prevent any actions that could result in an actual or potential conflict of interest affecting independent judgment in decision-making, the **PARTIES** and their Related Persons commit to the following obligations:

Maintain the highest standards of honesty, fairness, and personal integrity in conducting their activities.

Exercise due diligence and take all reasonable steps to prevent any actions, conditions, or circumstances that could lead to a conflict of interest.

Neither **PARTY** shall allow its Related Persons to offer



- (c) Ninguna de las **PARTES** permitirá a sus Personas Vinculadas ofrecer o recibir incentivos, atenciones, cortesías u obsequios de la otra Parte, a fin de obtener con ello beneficios para ella misma, o para sus Personas Vinculadas o sus familiares.
- (d) Declaran que a la fecha no mantiene relación financiera, comercial, o de otra índole, ya sea directa o indirecta, con algún trabajador de la otra **PARTE**. En caso, que ocurra algún cambio las **PARTES** se obligan a realizar las declaraciones escritas a fin de mantener informado a la otra **PARTE**.

or receive incentives, hospitality, courtesies, or gifts from the other PARTY to obtain benefits for themselves, their Related Persons, or their family members.

Declare that, as of the date of signing, they do not have any financial, commercial, or other direct or indirect relationship with any employee of the other PARTY. If any changes occur, the PARTIES are required to submit written declarations to keep the other PARTY informed.

6. SECRETO BANCARIO

La **EMPRESA** suscribe la siguiente declaración con la sola firma del presente **CONTRATO**:

"Por la presente quedo notificado de las estipulaciones y penalidades (desde el ámbito civil, penal y administrativo) establecidas por las normas peruanas sobre secreto bancario, tal como ellas se establecen en los artículos 140° a 143° de la Ley N° 26702 – Ley General del Sistema Financiero y del Sistema de Seguros y Orgánica de la Superintendencia de Banca y Seguros, de ser aplicable, así como sus normas complementarias y modificatorias. Por tanto, declaro conocer estar prohibido por ley de suministrar cualquier información relacionada a las operaciones pasivas de los clientes de BANBIF, a menos que ellos lo autoricen por escrito o que la información haya sido excluida por ley del ámbito de aplicación de las normas sobre secreto bancario."

6. BANKING SECRECY

The COMPANY signs the following declaration by merely executing this CONTRACT:

"By this document, I acknowledge being informed of the provisions and penalties (civil, criminal, and administrative) established under Peruvian regulations on banking secrecy, as stipulated in Articles 140 to 143 of Law No. 26702 – General Law of the Financial and Insurance System and Organic Law of the Superintendence of Banking, Insurance, and AFP, if applicable, along with its complementary and amending regulations. Therefore, I declare that I am aware that it is legally prohibited to disclose any information related to BANBIF's passive operations unless expressly authorized in writing by the clients or if the information has been legally excluded from the scope of banking secrecy regulations."

7. RIESGO OPERATIVO

La **EMPRESA** declara conocer que las normas legales vigentes en el Perú requieren el cumplimiento de ciertas condiciones de seguridad respecto de la información proporcionada por **BANBIF**, por lo que se obliga a tomar todas las medidas necesarias para garantizar que el procesamiento y la información materia de este **CONTRATO** se encuentren protegidos en todo momento y bajo cualquier circunstancia.

7. OPERATIONAL RISK

The COMPANY acknowledges that current legal regulations in Peru require compliance with specific security conditions regarding information provided by BANBIF. Consequently, it commits to taking all necessary measures to ensure that the processing and information covered under this CONTRACT remain protected at all times and under all circumstances.

Por la presente cláusula, las partes declaran tener conocimiento y atención de lo dispuesto en: i) El Reglamento de Gobierno Corporativo y Gestión Integral de Riesgos, aprobado por la Resolución SBS N° 272 – 2017, ii) El Reglamento para la Gestión del Riesgo Operacional, aprobado por Resolución SBS N° 2116 – 2009, iii) Reglamento para la Gestión de Continuidad del Negocio, aprobada en resolución SBS N° 877 - 2020, iv) Reglamento de tarjetas de crédito y débito (artículos 15 al 18), aprobado por Resolución SBS N° 6523 - 2013, v) Reglamento para la Gestión de Seguridad de la Información y Ciberseguridad, aprobada en la resolución SBS N° 504 - 2021. La citada normatividad legal tiene como objeto que las **EMPRESAS** supervisadas por la Superintendencia de Banca, Seguros y AFP, cuenten con un sistema de control de los riesgos

Through this clause, the PARTIES declare their awareness of and adherence to: i) The Corporate Governance and Comprehensive Risk Management Regulation, approved by SBS Resolution No. 272 – 2017. ii) The Operational Risk Management Regulation, approved by SBS Resolution No. 2116 – 2009. iii) The Business Continuity Management Regulation, approved by SBS Resolution No. 877 – 2020. iv) The Credit and Debit Card Regulation (Articles 15 to 18), approved by SBS Resolution No. 6523 – 2013. v) The Information Security and Cybersecurity Management Regulation, approved by SBS Resolution No. 504 – 2021.

These legal regulations aim to ensure that companies supervised by the Superintendence of Banking, Insurance, and AFP implement a risk control system to minimize the likelihood of financial losses related to the improper design or execution of



que enfrentan, a fin de minimizar la posibilidad de pérdidas financieras relacionadas al diseño o ejecución inapropiada de procesos considerados como indispensables para la continuidad de sus operaciones y servicios, y cuya falta o ejecución deficiente puede tener un impacto financiero significativo.

De conformidad con lo establecido por el Reglamento para la Gestión del Riesgo Operacional, aprobado por Resolución SBS N° 2116-2009, las **PARTES** convienen que la ejecución de las prestaciones de los **SERVICIOS** aplicables, bajo los términos y condiciones acordadas en el presente **CONTRATO** a cargo d/a **EMPRESA** podrán ser objeto de revisión y supervisión continua por parte del **BANBIF**, incluyendo su Unidad de Auditoría Interna y su Sociedad Auditora Externa así como por el funcionario que la Superintendencia de Banca, Seguros y AFP de la República de Perú (SBS) designe para el fin y en la oportunidad en que lo estimen conveniente. La **EMPRESA** se obliga a otorgar las facilidades necesarias a fin de que se pueda efectuar la revisión y supervisión antes mencionada, en cualquier momento.

La **EMPRESA** reconoce que, con el fin de obtener información sobre la prestación de los **SERVICIOS** a una fecha determinada, la Superintendencia de Banca, Seguros y AFP podría solicitar la revisión de las prestaciones mediante aviso con anticipación de treinta (30) días, siendo el menor de los plazos quince (15) días dependiendo de la solicitud hecha por **BANBIF**. Dicha revisión únicamente se efectuará sobre los servicios prestados a **BANBIF** en salvaguarda del derecho de protección de datos de los clientes de **BANBIF**. Asimismo, la **EMPRESA** podrá limitar el acceso a la información que esté protegida por disposiciones legales y/o contractuales.

El incumplimiento de la obligación que la **EMPRESA** en la presente sección constituye causal de resolución de pleno derecho del presente **CONTRATO**, de conformidad con lo previsto en el artículo 1430° del Código Civil.

8. CONTINUIDAD DEL NEGOCIO

La **EMPRESA** cuenta con un Plan de Continuidad del Negocio de sus instalaciones frente a contingencias para garantizar la continuidad de los servicios de acuerdo a lo acordado en nuestro contrato. La **EMPRESA** declara que este plan de continuidad de negocios cubre los servicios que ofrece a **BANBIF**.

La **EMPRESA** designará un representante ante **BANBIF** para actuar como coordinador en el Plan de Continuidad del Negocio. El coordinador del Plan de Continuidad del Negocio comunicará a **BANBIF** cualquier cambio en el Plan de Continuidad del Negocio y se asegurará de que el mismo sea compatible con los requerimientos d/a **EMPRESA**.

En caso **BANBIF** incurriera en costos, penalidades y/o multas establecidas por una resolución o sentencia firme producto de contingencias y/o algún error o falla en las condiciones de la

critical processes necessary for the continuity of their operations and services. Any failure or deficiency in execution may have a significant financial impact.

In accordance with the Operational Risk Management Regulation, approved by SBS Resolution No. 2116-2009, the **PARTIES** agree that the execution of the applicable **SERVICE** obligations under the terms and conditions set forth in this **CONTRACT** by the **COMPANY** may be subject to ongoing review and supervision by **BANBIF**, including its Internal Audit Unit, External Audit Firm, and any official designated by the Superintendence of Banking, Insurance, and AFP of the Republic of Peru (SBS), at their discretion and at any time they deem appropriate. The **COMPANY** is obligated to provide the necessary facilities to ensure that such review and supervision can be conducted at any time.

The **COMPANY** acknowledges that, in order to obtain information regarding the provision of **SERVICES** as of a specific date, the Superintendence of Banking, Insurance, and AFP may request a review of the services upon prior notice of thirty (30) days, with a minimum notice period of fifteen (15) days, depending on **BANBIF**'s request. Such review will be limited exclusively to the services provided to **BANBIF**, safeguarding **BANBIF** clients' data protection rights. Furthermore, the **COMPANY** may restrict access to information that is protected by legal and/or contractual provisions.

Failure by the **COMPANY** to comply with this obligation shall constitute grounds for the automatic termination of this **CONTRACT** in accordance with Article 1430 of the Civil Code.

8. BUSINESS CONTINUITY

The **COMPANY** has a Business Continuity Plan for its facilities to address contingencies and ensure service continuity in accordance with the terms agreed upon in this contract. The **COMPANY** declares that this business continuity plan covers the services provided to **BANBIF**.

The **COMPANY** shall designate a representative to act as the Business Continuity Plan Coordinator before **BANBIF**. This coordinator will inform **BANBIF** of any changes to the Business Continuity Plan and ensure that it remains compatible with the **COMPANY**'s requirements.

If **BANBIF** incurs costs, penalties, and/or fines imposed by a



prestación de los **SERVICIOS** por causas imputables al **PROVEEDOR**, éste último se hará totalmente responsable de dichos costos, penalidades y/o multas, asumiendo el importe íntegro de dichos conceptos. Para tal efecto **BANBIF** deberá comunicar al **PROVEEDOR** sobre el inicio del proceso sancionador en un plazo de tres (3) días hábiles previos al vencimiento del plazo para contestar el proceso sancionador a fin de que éste le brinde la información necesaria para la defensa del procedimiento respectivo y defenderse oportuna y diligentemente. Una vez cumplidos estos requisitos, la **EMPRESA** asumirá el monto de la multa que se imponga en la instancia correspondiente.

9. CONFIDENCIALIDAD DE LA INFORMACIÓN

La **EMPRESA** se obliga a mantener y guardar estricta reserva y absoluta confidencialidad sobre las características, términos y condiciones del presente **CONTRATO**.

La **EMPRESA** se compromete a respetar y aplicar lo acordado en los **SERVICIOS**; así como informar e instruir a sus empleados, las políticas, procedimientos, estándares y todo tipo de controles de seguridad de la información establecidos por las normativas en Protección de datos personales, Protección de tarjetas y Seguridad de la Información de los Entes Reguladores Públicos, entre otros. Los mismos quede claro conocer y aceptar.

La **EMPRESA** se obliga a mantener y guardar en estricta reserva y absoluta confidencialidad todos los documentos e información de **BANBIF** a los que tenga acceso en ejecución del presente **CONTRATO**. Se entiende que la obligación asumida por la **EMPRESA** está referida no sólo a los documentos e información confidencial sino a todos los documentos e información que en razón del presente **CONTRATO** o vinculado con la ejecución del mismo, pueda ser conocida por cualquier medio por la **EMPRESA**.

En consecuencia, la **EMPRESA** deberá abstenerse de divulgar tales documentos e información, sea en forma directa o indirecta. La **EMPRESA** conviene en que toda la información suministrada en virtud de este contrato es confidencial y de propiedad de **BANBIF**, no pudiendo la **EMPRESA** usar dicha información provista para ningún propósito distinto al permitido o requerido para dar cumplimiento a sus obligaciones.

Esta obligación de confidencialidad también se encuentra referida a la información intercambiada durante las negociaciones y se mantiene durante y después de la vigencia del presente **CONTRATO**.

La **EMPRESA** sólo podrá revelar al personal que estrictamente sea necesario para la realización de las actividades materia del presente **CONTRATO**, los documentos e información a los que se refiere el numeral precedente. Asimismo, la **EMPRESA** se obliga a tomar las medidas y precauciones necesarias para que

final resolution or ruling due to contingencies, errors, or failures in the provision of **SERVICES** attributable to the **SUPPLIER**, the latter shall assume full responsibility for such costs, penalties, and/or fines. The full amount of these expenses shall be covered by the **SUPPLIER**.

To this end, **BANBIF** must notify the **SUPPLIER** of the initiation of the sanctioning process at least three (3) business days before the deadline to respond to the process. This will allow the **SUPPLIER** to provide the necessary information for its defense and respond to the procedure in a timely and diligent manner. Once these requirements have been met, the **COMPANY** shall assume full responsibility for any fine imposed in the relevant proceeding.

9. CONFIDENTIALITY OF INFORMATION

The **COMPANY** is obligated to maintain strict secrecy and absolute confidentiality regarding the characteristics, terms, and conditions of this **CONTRACT**.

The **COMPANY** commits to respecting and applying the agreed-upon provisions in the **SERVICES**, as well as informing and instructing its employees on policies, procedures, standards, and all types of information security controls established by regulations on Personal Data Protection, Card Protection, and Information Security issued by Public Regulatory Entities, among others. It is understood that the **COMPANY** acknowledges and accepts these requirements.

The **COMPANY** is obligated to maintain strict secrecy and absolute confidentiality concerning all documents and information of **BANBIF** to which it has access in the execution of this **CONTRACT**. This obligation applies not only to confidential documents and information but also to any documents and information that, by reason of this **CONTRACT** or its execution, may become known to the **COMPANY** by any means.

Consequently, the **COMPANY** shall refrain from disclosing such documents and information, either directly or indirectly. The **COMPANY** agrees that all information provided under this contract is confidential and the property of **BANBIF**. The **COMPANY** may not use such information for any purpose other than that which is permitted or required to fulfill its obligations.

This confidentiality obligation also applies to information exchanged during negotiations and remains in effect both during and after the term of this **CONTRACT**.

The **COMPANY** may only disclose documents and information referenced in the preceding paragraph to personnel strictly



sus trabajadores, directores, accionistas, proveedores y en general cualquier persona que tenga relación con la **EMPRESA** no divulgue a ningún tercero los documentos e información a la que tenga acceso, haciéndose responsable por la divulgación que se pueda producir y asumiendo el pago de la indemnización por daños y perjuicios que la autoridad competente determine. Sin perjuicio de lo anteriormente establecido, el incumplimiento de esta obligación importa una causal de resolución inmediata sin responsabilidad para **BANBIF**.

En el caso que la **EMPRESA** fuera requerido por alguna autoridad administrativa, la **EMPRESA** deberá notificar anticipadamente al **BANBIF** para que éste adopte las medidas que considere necesarias para proteger la confidencialidad de la información.

Se deja expresamente establecido que el deber de confidencialidad opera desde el inicio de la ejecución de los **SERVICIOS** y se mantendrá vigente indefinidamente, incluso ante la resolución o término del plazo del mismo. En los casos que la **EMPRESA** requiera involucrar a terceros proveedores para la prestación de los servicios materia del presente contrato, requerirá previamente la autorización expresa y por escrito por cualquier medio escrito por parte de **BANBIF**, obligándose en estos casos a incorporar en los acuerdos de contratos de trabajo que suscriba con éstos la obligación de reserva con respecto a la Información Confidencial a la que puedan tener acceso, quedando de esta forma los terceros proveedores igualmente sujetos a la obligación de confidencialidad de la información.

La **EMPRESA** se compromete a avisar oportunamente y por escrito a **BANBIF**, en caso de enterarse de cualquier apropiación ilícita o uso ilegal por parte de cualquier persona de dicha información confidencial.

Si la **EMPRESA** o sus representantes fueren requeridos por un tribunal de justicia o por una autoridad gubernamental, en forma legalmente obligatoria, y por escrito, a revelar la existencia y/o contenido de este acuerdo o de Información Confidencial, ésta se obliga a informar este hecho a **BANBIF** dentro de un día hábil de recibido el requerimiento, solicitud o notificación, con la finalidad de que éste pueda tomar las medidas correctivas o de defensa que sean pertinentes.

La **EMPRESA** suscribe el Compromiso de Confidencialidad adjunto en el Anexo I del presente **CONTRATO**. Las **PARTES** acuerdan que lo dispuesto en el Anexo I será extensivo a los trabajadores y/o personal contratado dlla **EMPRESA**, siendo responsabilidad absoluta dlla **EMPRESA** velar por el cumplimiento de lo dispuesto en la presente cláusula como Anexo I, por sus trabajadores y/o personal, incluso cuando los trabajadores y/o personal contratado hayan concluido su relación laboral con la **EMPRESA** durante la vigencia del **CONTRATO**

necessary for the performance of the activities covered by this **CONTRACT**. Additionally, the **COMPANY** is obligated to take all necessary precautions to ensure that its employees, directors, shareholders, suppliers, and any other persons related to the **COMPANY** do not disclose to any third party the documents and information to which they have access. The **COMPANY** shall be held liable for any unauthorized disclosure and shall assume responsibility for any damages determined by the competent authority. Without prejudice to the above, any breach of this obligation shall be grounds for immediate termination of the **CONTRACT** without liability for **BANBIF**.

If the **COMPANY** is required by an administrative authority to disclose information, it must notify **BANBIF** in advance so that **BANBIF** may take the necessary measures to protect the confidentiality of the information.

It is expressly established that the duty of confidentiality takes effect from the commencement of the **SERVICES** and remains indefinitely, even after the termination or expiration of the **CONTRACT**. If the **COMPANY** needs to engage third-party providers for the provision of services under this contract, it must first obtain express and written authorization from **BANBIF** by any written means. In such cases, the **COMPANY** is required to incorporate into its agreements with these third-party providers a confidentiality obligation regarding any confidential information they may access. These third-party providers shall thus be equally subject to the confidentiality obligation.

The **COMPANY** commits to promptly notifying **BANBIF** in writing if it becomes aware of any unlawful appropriation or unauthorized use of such confidential information.

If the **COMPANY** or its representatives are legally required by a court of law or a government authority, in writing, to disclose the existence and/or content of this agreement or any Confidential Information, the **COMPANY** is obligated to inform **BANBIF** of this requirement within one business day of receiving the request, notification, or summons, so that **BANBIF** may take the appropriate corrective or defensive measures.

The **COMPANY** signs the Confidentiality Commitment attached in Annex I of this **CONTRACT**. The **PARTIES** agree that the provisions of Annex I shall also apply to the **COMPANY**'s employees and/or contracted personnel, and the **COMPANY** shall bear full responsibility for ensuring compliance with this clause and Annex I by its employees and/or personnel, even after their employment relationship with the **COMPANY** has ended during the term of the **CONTRACT**.



0. SEGURIDAD DE LA INFORMACIÓN

De acuerdo a las leyes vigentes referidas a la responsabilidad penal o civil del inadecuado uso de la información, normas de la industria de Medios de Pago y atención a las disposiciones normativas establecidas por la Superintendencia de Bancos, Seguros y AFPs, BANBIF ha implementado un Sistema de Gestión de Seguridad de Información cuyo objetivo es dar cabal cumplimiento a su deber de resguardar de manera efectiva la seguridad de la información de mayor valor para **BANBIF**, en términos de su confidencialidad, integridad y disponibilidad. Este sistema de gestión incluye la relación de **BANBIF** con sus contratistas, subcontratistas, la **EMPRESA** y cualquier otra **EMPRESA**, organismo o entidad con la cual contrate, sea de carácter público o privado.

Además de las definiciones establecidas en las disposiciones normativas antes mencionadas, para efectos de este anexo del **CONTRATO** serán aplicables la siguiente definición:

- Leyes y regulaciones aplicables: Se entenderá por tal, todas las normas y disposiciones legales referidas al manejo y gestión de la seguridad de información aplicable al contrato, que vincula al Banco con contratista, subcontratista, la **EMPRESA** y cualquier otra **EMPRESA**, organismo o entidad con la cual contrate, sea de carácter público o privado.

Para efectos de este contrato, la **EMPRESA** declara y garantiza que

- La **EMPRESA** se obliga a mantener y guardar estricta reserva y absoluta confidencialidad sobre las características, términos y condiciones del presente **CONTRATO**.
- La **EMPRESA** se compromete a respetar el presente **CONTRATO**; así como, informar e instruir a sus empleados, en temas de confidencialidad y seguridad de la información, asimismo, declara conocer, aceptar y cumplir con la Política de nombre “Política Seguridad de Información para Proveedores” el cual se encuentra en la Página Web de **BANBIF**. Ver link en donde se encuentra dicha política <https://www.banbif.com.pe/Portals/0/PortalOld/BIFSegInformacion/seguridad.html>.
- La **EMPRESA** se compromete atender el servicio bajo estándares de Seguridad de Información.
- La **EMPRESA** se compromete a estar alineado las normativas en Protección de datos personales (Ley 29733 y su reglamento), estándar PCI DSS vigente, así como a marcos de trabajo sobre Seguridad de la Información y Ciberseguridad, de acuerdo al alcance del servicio que brinda a **BANBIF**.

10. INFORMATION SECURITY

In accordance with the applicable laws regarding criminal or civil liability for the improper use of information, industry regulations for Payment Media, and the regulatory provisions established by the Superintendency of Banks, Insurance, and Pension Fund Administrators, BANBIF has implemented an Information Security Management System. The objective of this system is to fully comply with its duty to effectively safeguard the security of BANBIF's most valuable information in terms of confidentiality, integrity, and availability. This management system also applies to BANBIF's relationships with its contractors, subcontractors, the COMPANY, and any other company, organization, or entity it contracts with, whether public or private.

In addition to the definitions established in the aforementioned regulations, the following definition applies for the purposes of this contract annex:

- Applicable laws and regulations: This refers to all laws and legal provisions related to the handling and management of information security applicable to the contract, which binds the Bank to the contractor, subcontractor, the COMPANY, and any other company, organization, or entity with which it contracts, whether public or private.

For the purposes of this contract, the COMPANY declares and guarantees that:

- The COMPANY is obligated to maintain strict secrecy and absolute confidentiality regarding the characteristics, terms, and conditions of this CONTRACT.
- The COMPANY agrees to comply with this CONTRACT, as well as inform and instruct its employees on confidentiality and information security. Furthermore, it declares that it acknowledges, accepts, and complies with the policy titled “Information Security Policy for Suppliers”, which is available on BANBIF's website: Information Security Policy - <https://www.banbif.com.pe/Portals/0/PortalOld/BIFSegInformacion/seguridad.html>.
- The COMPANY commits to delivering the service under Information Security standards.
- The COMPANY agrees to align with the applicable regulations on Personal Data Protection (Law 29733 and its regulations), the current PCI DSS standard, as well as information security and cybersecurity frameworks, depending on the scope of the services



La **EMPRESA** podrá ser evaluado de forma anual, desde un enfoque de Seguridad de la información y con respecto al servicio. Ello será realizado por **BANBIF** o por una **EMPRESA** designada por este último, previa coordinación con la **EMPRESA**. Las evaluaciones o auditorías deberán ser coordinadas por las **PARTES** con al menos 5 días hábiles de antelación, y deberán ser realizadas en cumplimiento de las políticas de seguridad de la información de la **EMPRESA**. La **EMPRESA** asignada por **BANBIF** para estos efectos no podrá ser considerada por la **EMPRESA** como su competencia.

Acerca de la Información:

La **EMPRESA** se obliga a mantener en custodia y guardar en estricta reserva y absoluta confidencialidad todos los documentos e información de **BANBIF** a los que tenga acceso en ejecución del presente contrato como CDs, cintas magnéticas, USBs, documentación escrita, códigos, e-mails u otros medios físicos o electrónicos de intercambio de información. Se entiende que la obligación asumida por la **EMPRESA** está referida no sólo a los documentos e información confidencial sino a todos los documentos e información que en razón del presente **CONTRATO** o vinculado con la ejecución del mismo, pueda ser conocida por la **EMPRESA**. En consecuencia, la **EMPRESA** deberá abstenerse de divulgar tales documentos e información, sea en forma directa o indirecta. La **EMPRESA** conviene en que toda la información suministrada por la **EMPRESA** en virtud de este **CONTRATO** es confidencial, no pudiendo usar dicha información provista para ningún propósito distinto al permitido o requerido para dar cumplimiento a sus obligaciones.

La **EMPRESA** sólo podrá revelar al personal que estrictamente sea necesario para la realización de las actividades materia del presente **CONTRATO**, los documentos e información a los que se refiere el numeral precedente.

En el caso que al **PROVEEDOR** le fuera requerida por alguna autoridad administrativa o judicial revelar la información y/o documentación a la que se refiere la presente cláusula, la **EMPRESA** deberá comunicar anticipadamente a **BANBIF** para que adopte las medidas que considere necesarias para proteger la confidencialidad de la información.

La **EMPRESA** se obliga a devolver, cuando **BANBIF** lo requiera, todo software, documentación y equipos; así como otros activos de información tales como tarjetas de acceso, manuales, información guardada en medios electrónicos, entre otros que le haya proporcionado la otra parte. El requerimiento no será necesario cuando el contrato haya sido resuelto o haya finalizados el plazo pactado del **CONTRATO**. En todos los casos, la **EMPRESA** deberá cursar comunicación escrita en el plazo máximo de 30 días, contados desde la fecha de requerimiento, fecha resolución o fecha de término del contrato,

provided to BANBIF.

The COMPANY may be subject to an annual evaluation from an information security perspective and in relation to the services provided. This evaluation will be conducted by BANBIF or a company designated by BANBIF, with prior coordination with the COMPANY. The evaluations or audits must be coordinated by the PARTIES at least five (5) business days in advance and must be carried out in compliance with the COMPANY's information security policies. The company designated by BANBIF for these purposes shall not be considered a competitor by the COMPANY.

Regarding Information:

The COMPANY is obligated to safeguard and maintain strict secrecy and absolute confidentiality concerning all BANBIF documents and information accessed during the execution of this contract, including CDs, magnetic tapes, USB drives, written documents, codes, emails, or any other physical or electronic means of information exchange. This obligation applies not only to confidential documents and information but also to all documents and information that, due to this CONTRACT or its execution, may become known to the COMPANY. Consequently, the COMPANY shall refrain from disclosing such documents and information, either directly or indirectly. The COMPANY acknowledges that all information provided by BANBIF under this CONTRACT is confidential and cannot be used for any purpose other than that which is permitted or required to fulfill its obligations.

The COMPANY may only disclose the referenced documents and information to personnel strictly necessary for performing the activities under this CONTRACT.

If the SUPPLIER is required by any administrative or judicial authority to disclose the information and/or documentation covered by this clause, the COMPANY must notify BANBIF in advance so that BANBIF may take any necessary measures to protect the confidentiality of the information.

The COMPANY is obligated to return, upon BANBIF's request, all software, documentation, and equipment, as well as other information assets such as access cards, manuals, and electronically stored information, among others, provided by BANBIF. Such a request will not be necessary if the contract has been terminated or has reached the agreed term. In all cases, the COMPANY must issue a written confirmation within a maximum period of 30 days from the date of the request, contract termination, or expiration, stating that it no longer



en la que deberá dejar constancia de que no obra en su poder información de propiedad de **BANBIF**.

La **EMPRESA** se obliga a borrar toda información que le pertenece a **BANBIF**, además, asegura que cumplirá con el periodo de confidencialidad de 5 años posterior a la finalización del servicio contratado. La **EMPRESA** se obliga a brindar las facilidades de ingreso a sus instalaciones para realizar entrevistas relacionadas al cumplimiento de las buenas prácticas relacionadas a Seguridad de la Información

Se deja expresamente establecido que el deber de confidencialidad opera desde el inicio de la ejecución de los **SERVICIOS** materia de este **CONTRATO** y se mantendrá vigente incluso hasta cinco (5) años posteriores a la resolución o término del plazo del mismo.

La **EMPRESA** que brinde servicios en Nube garantiza el soporte técnico 24x7x365, la seguridad en la plataforma, aplicaciones y APIs, la aplicabilidad de cifrado de datos, la protección de las comunicaciones, los respaldos y redundancia de datos, compartir con **BANBIF** los contratos y política de datos de la **EMPRESA** que almacena la aplicación.

La **EMPRESA** se compromete a brindar los sustentos de pruebas de seguridad como Ethical Hacking, Pentesting, análisis y vulnerabilidades de acuerdo a la característica de los **SERVICIOS**.

La **EMPRESA** se compromete a realizar mejoras a nivel de seguridad de la información de acuerdo a resultados del cuestionario de diligencia debida.

DECLARACIÓN JURADA

La **EMPRESA** acepta y afirma que:

- (i) En cumplimiento de nuestras responsabilidades en calidad de Proveedor de **BANBIF**, declaro que ninguno de nuestros accionistas, directores, gerentes, apoderados, asesores, funcionarios o empleados, filiales, subsidiarias y/o subcontratistas, representantes legales y otros colaboradores han sido investigados, procesados y/o condenados por el delito de Lavado de Activos o financiamiento al terrorismo.
- (ii) En cumplimiento con la Resolución SBS N° 2660-2015 y modificatorias, nuestra entidad no se encuentra sancionada por el incumplimiento del Sistema de Prevención de Lavado de Activos o Financiamiento al Terrorismo.

possesses any information owned by **BANBIF**.

The COMPANY is obligated to erase all information belonging to **BANBIF** and ensures compliance with a confidentiality period of five (5) years following the completion of the contracted service. The COMPANY is also required to facilitate access to its facilities for interviews related to compliance with best practices in Information Security.

It is expressly established that the duty of confidentiality takes effect from the commencement of the **SERVICES** under this **CONTRACT** and remains in force for up to five (5) years after its termination or expiration.

If the COMPANY provides cloud services, it guarantees 24x7x365 technical support, platform security, application and API security, data encryption enforcement, communication protection, data backups and redundancy, and the sharing of contracts and data policies of the COMPANY storing the application with **BANBIF**.

The COMPANY commits to providing security test reports, including Ethical Hacking, Penetration Testing, analysis, and vulnerability assessments, according to the nature of the **SERVICES**.

The COMPANY agrees to implement security improvements based on the results of the due diligence questionnaire.

SWORN DECLARATION

The COMPANY accepts and affirms that:

In compliance with our responsibilities as a **BANBIF** supplier, I declare that none of our shareholders, directors, managers, attorneys-in-fact, advisors, officers, employees, affiliates, subsidiaries, subcontractors, legal representatives, or other collaborators have been investigated, prosecuted, and/or convicted of Money Laundering or Terrorism Financing.

In compliance with Superintendence Resolution SBS No. 2660-2015 and its amendments, our entity has not been sanctioned for non-compliance with the Anti-Money Laundering and Terrorism Financing Prevention System.



Adicionalmente, ratifica y afirma que, si llega a tomar conocimiento de cualquier actividad indebida antes mencionada, notificará de inmediato al representante autorizado por **BANBIF** a tal efecto.

Additionally, the COMPANY affirms that if it becomes aware of any of the aforementioned illicit activities, it will immediately notify BANBIF's authorized representative.



Certificate Of Completion

Envelope Id: 349B9583-75CF-4311-806F-A6910C2D0673

Status: Completed

Subject: Complete with Docusign: EN-ES Ethicontrol_SaaS_Agreement_BanBif v4 04.03.2025 MA.docx.pdf

Source Envelope:

Document Pages: 76

Signatures: 2

Envelope Originator:

Certificate Pages: 2

Initials: 0

Oleg Lagodiyenko

AutoNav: Enabled

oleg@ethicontrol.com

Envelopeld Stamping: Enabled

IP Address: 139.162.166.148

Time Zone: (UTC+02:00) Helsinki, Kyiv, Riga, Sofia, Tallinn, Vilnius

Record Tracking

Status: Original

Holder: Oleg Lagodiyenko

Location: DocuSign

03/12/2025 | 14:23

oleg@ethicontrol.com

Signer Events

ELVIRA CATHERINE PREVOST ZARATE

CPREVOST@BANBIF.COM.PE

Security Level: Email, Account Authentication (None)

Firmado por:

ELVIRA CATHERINE PREVOST ZARATE

8A96F7D532AC4EA...

Signature Adoption: Pre-selected Style

Using IP Address: 191.98.133.69

Timestamp

Sent: 03/12/2025 | 14:33

Viewed: 03/14/2025 | 16:33

Signed: 03/14/2025 | 16:36

Electronic Record and Signature Disclosure:

Not Offered via Docusign

José Antonio Osorio Balarezo

josorio@banbif.com.pe

Security Level: Email, Account Authentication (None)

Firmado por:

José Antonio Osorio Balarezo

46F75473290B4C5...

Signature Adoption: Pre-selected Style

Using IP Address: 191.98.133.69

Timestamp

Sent: 03/12/2025 | 14:33

Viewed: 03/13/2025 | 01:22

Signed: 03/13/2025 | 01:24

Electronic Record and Signature Disclosure:

Not Offered via Docusign

In Person Signer Events

Editor Delivery Events

Agent Delivery Events

Intermediary Delivery Events

Certified Delivery Events

Carbon Copy Events

Witness Events

Notary Events

Envelope Summary Events

Envelope Sent

Hashed/Encrypted

03/12/2025 | 14:33

Certified Delivered

Security Checked

03/13/2025 | 01:22

Signing Complete

Security Checked

03/13/2025 | 01:24

Completed

Security Checked

03/14/2025 | 16:36

Payment Events	Status	Timestamps
----------------	--------	------------

Certificate Of Completion

Envelope Id: 1075F62C-A381-40B1-9795-88F58BA30EEF	Status: Completed
Subject: Complete with Docusign: Complete_with_Docusign_EN-ES_Ethicontrol_Saa.pdf	
Source Envelope:	
Document Pages: 78	Signatures: 1
Certificate Pages: 1	Initials: 0
AutoNav: Enabled	Envelope Originator:
Envelopeld Stamping: Enabled	Oleg Lagodiyenko
Time Zone: (UTC+02:00) Helsinki, Kyiv, Riga, Sofia, Tallinn, Vilnius	oleg@ethicontrol.com
	IP Address: 139.162.166.148

Record Tracking

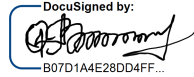
Status: Original	Holder: Oleg Lagodiyenko	Location: DocuSign
03/17/2025 17:19	oleg@ethicontrol.com	

Signer Events

Oleg Lagodiyenko
oleg@ethicontrol.com
CEO

Ethicontrol OÜ, 14338530
Security Level: Email, Account Authentication
(None)

Signature

DocuSigned by:

B07D1A4E28DD4FF...

Signature Adoption: Drawn on Device
Using IP Address: 139.162.166.148

Timestamp

Sent: 03/17/2025 | 17:20
Viewed: 03/17/2025 | 17:20
Signed: 03/17/2025 | 17:20
Freeform Signing

Electronic Record and Signature Disclosure:
Not Offered via Docusign

In Person Signer Events

Signature

Timestamp

Editor Delivery Events

Status

Timestamp

Agent Delivery Events

Status

Timestamp

Intermediary Delivery Events

Status

Timestamp

Certified Delivery Events

Status

Timestamp

Carbon Copy Events

Status

Timestamp

Witness Events

Signature

Timestamp

Notary Events

Signature

Timestamp

Envelope Summary Events

Status

Timestamps

Envelope Sent	Hashed/Encrypted	03/17/2025 17:20
Certified Delivered	Security Checked	03/17/2025 17:20
Signing Complete	Security Checked	03/17/2025 17:20
Completed	Security Checked	03/17/2025 17:20

Payment Events

Status

Timestamps